

CIS Oracle Database Server 11g R2 on Oracle

v1.0.0

The CIS Security Benchmarks division provides consensus-oriented information security products, services, tools, metrics, suggestions, and recommendations (the "SB Products") as a public service to Internet users worldwide. Downloading or using SB Products in any way signifies and confirms your acceptance of and your binding agreement to these CIS Security Benchmarks Terms of Use.

CIS SECURITY BENCHMARKS TERMS OF USE

BOTH CIS SECURITY BENCHMARKS DIVISION MEMBERS AND NON-MEMBERS MAY:

- Download, install, and use each of the SB Products on a single computer, and/or
- Print one or more copies of any SB Product that is in a .txt, .pdf, .doc, .mcw, or .rtf format, but only if each such copy is printed in its entirety and is kept intact, including without limitation the text of these CIS Security Benchmarks Terms of Use.

UNDER THE FOLLOWING TERMS AND CONDITIONS:

- **SB Products Provided As Is.** CIS is providing the SB Products "as is" and "as available" without: (1) any representations, warranties, or covenants of any kind whatsoever (including the absence of any warranty regarding: (a) the effect or lack of effect of any SB Product on the operation or the security of any network, system, software, hardware, or any component of any of them, and (b) the accuracy, utility, reliability, timeliness, or completeness of any SB Product); or (2) the responsibility to make or notify you of any corrections, updates, upgrades, or fixes.
- **Intellectual Property and Rights Reserved.** You are not acquiring any title or ownership rights in or to any SB Product, and full title and all ownership rights to the SB Products remain the exclusive property of CIS. All rights to the SB Products not expressly granted in these Terms of Use are hereby reserved.
- **Restrictions.** You acknowledge and agree that you may not: (1) decompile, dis-assemble, alter, reverse engineer, or otherwise attempt to derive the source code for any software SB Product that is not already in the form of source code; (2) distribute, redistribute, sell, rent, lease, sublicense or otherwise transfer or exploit any rights to any SB Product in any way or for any purpose; (3) post any SB Product on any website, bulletin board, ftp server, newsgroup, or other similar mechanism or device; (4) remove from or alter these CIS Security Benchmarks Terms of Use on any SB Product; (5) remove or alter any proprietary notices on any SB Product; (6) use any SB Product or any component of an SB Product with any derivative works based directly on an SB Product or any component of an SB Product; (7) use any SB Product or any component of an SB Product with other products or applications that are directly and specifically dependent on such SB Product or any component for any part of their functionality; (8) represent or claim a particular level of compliance or consistency with any SB Product; or (9) facilitate or otherwise aid other individuals or entities in violating these CIS Security Benchmarks Terms of Use.
- **Your Responsibility to Evaluate Risks.** You acknowledge and agree that: (1) no network, system, device, hardware, software, or component can be made fully secure; (2) you have the sole responsibility to evaluate the risks and benefits of the SB Products to your particular circumstances and requirements; and (3) CIS is not assuming any of the liabilities associated with your use of any or all of the SB Products.
- **CIS Liability.** You acknowledge and agree that neither CIS nor any of its employees, officers, directors, agents or other service providers has or will have any liability to you whatsoever (whether based in contract, tort, strict liability or otherwise) for any direct, indirect, incidental, consequential, or special damages that arise out of or are connected in any way with your use of any SB Product.
- **Indemnification.** You agree to indemnify, defend, and hold CIS and all of CIS's employees, officers, directors, agents and other service providers harmless from and against any liabilities, costs and expenses incurred by any of them in connection with your violation of these CIS Security Benchmarks Terms of Use.
- **Jurisdiction.** You acknowledge and agree that: (1) these CIS Security Benchmarks Terms of Use will be governed by and construed in accordance with the laws of the State of Maryland; (2) any action at law or in equity arising out of or relating to these CIS Security Benchmarks Terms of Use shall be filed only in the courts located in the State of Maryland; and (3) you hereby consent and submit to the personal jurisdiction of such courts for the purposes of litigating any such action.
- **U.S. Export Control and Sanctions laws.** Regarding your use of the SB Products with any non-U.S. entity or country, you acknowledge that it is your responsibility to understand and abide by all U.S. sanctions and export control laws as set from time to time by the U.S. Bureau of Industry and Security (BIS) and the U.S. Office of Foreign Assets Control (OFAC).

SPECIAL RULES FOR CIS MEMBER ORGANIZATIONS: CIS reserves the right to create special rules for: (1) CIS Members; and (2) Non-Member organizations and individuals with which CIS has a written contractual relationship. CIS hereby grants to each CIS Member Organization in good standing the right to distribute the SB Products within such Member's own organization, whether by manual or electronic means. Each such Member Organization acknowledges and agrees that the foregoing grants in this paragraph are subject to the terms of such Member's membership arrangement with CIS and may, therefore, be modified or terminated by CIS at any time.

Table of Contents

Overview	13
Recommendations.....	18
1 Rejected - OS-specific settings for the Oracle installation	18
1.1 Set kernel.shmall value (Scored).....	18
1.2 Set fs.file-max value (Scored)	18
1.3 Set kernel.msgmni value (Scored).....	19
1.4 Set kernel.sem value (Scored).....	20
1.5 Set kernel.shmmni value (Scored)	20
1.6 Set net.core.rmem_default value (Scored)	21
1.7 Set net.core.rmem_max value (Scored).....	22
1.8 Set net.core.wmem_max value (Scored)	22
1.9 Set net.core.wmem_default value (Scored)	23
1.10 Set vm.min_free_kbytes value (Scored).....	23
1.11 Limit OS-based access to the Oracle directory (Scored)	24
1.12 Install Oracle software of a separate partition (Scored)	25
1.13 REMOVE ME - Install Oracle Control Files on a separate partition (Scored)	25
1.14 REMOVE ME - Install Oracle Redo Log files on separate partitions (Scored)	26
1.15 REMOVE ME - Verify access for the DBMS_OBSFUCATION_TOOLKIT (Scored)	27
1.16 REMOVE ME - Verify access for the DBMS_CRYPTO_TOOLKIT (Scored).....	28
2 Oracle Database Installation and Patching Requirements	28
2.1 Change the Oracle default account passwords	28
2.1.1 Change the default password for 'SYS' (Not Scored)	29
2.1.2 Change the default password for SYSTEM (Scored)	30
2.1.3 Change the default password for OUTLN (Scored)	30
2.1.4 Change the default password for DIP (Scored).....	31
2.1.5 Change the default password for ORACLE_OCM (Scored)	31
2.1.6 Change the default password for APPQOSSYS (Scored)	32
2.1.7 Change the default password for WMSYS (Scored)	32
2.1.8 Change the default password for EXFSYS (Scored)	33

2.1.9 Change the default password for CTXSYS (Scored)	33
2.1.10 Change the default password for XDB (Scored)	34
2.1.11 Change the default password for ANONYMOUS (Scored)	34
2.1.12 Rejected - Change the default password for XS\$NULL (Scored)	35
2.1.13 Change the default password for ORDPLUGINS (Scored)	36
2.1.14 Change the default password for MDSYS (Scored)	36
2.1.15 Change the default password for ORDDATA (Scored)	37
2.1.16 Change the default password for ORDSYS (Scored)	37
2.1.17 Change the default for SI_INFORMTN_SCHEMA (Scored)	38
2.1.18 Change the default password for OLAPSYS (Scored)	38
2.1.19 Change the default password for MDDATA (Scored)	39
2.1.20 Change the default password of SPATIAL_WFS_ADMIN_USR (Scored)	40
2.1.21 Change the default password of SPATIAL_CSW_ADMIN_USR (Scored)	40
2.1.22 Change the default password of SYSMAN (Scored)	41
2.1.23 Change the default password of MGMT_VIEW (Scored)	41
2.1.24 Change the default password of OWBSYS (Scored)	42
2.1.25 Change the default password of OWBSYS_AUDIT (Scored)	42
2.1.26 Change the default password of DBSNMP (Scored)	43
2.1.27 Rejected - Change the default password of WK_TEST (Scored)	44
2.1.28 Change the default password of WK_TEST (Scored)	44
2.1.29 Change the default password for FLOWS_030100 (Scored)	45
2.1.30 Change the default password for FLOWS_FILES (Scored)	45
2.1.31 Change the default password for FLOWS_030000 (Scored)	46
2.1.32 Change the default password for APEX_030200 (Scored)	46
2.1.33 Change the default password for APEX_040000 (Scored)	47
2.1.34 Change the default password for APEX_040100 (Scored)	48
2.1.35 Change the default password for APEX_040200 (Scored)	48
2.1.36 Change the default password for LBACSYS (Scored)	49
2.1.37 Change the default password of WKPROXY (Scored)	49
2.1.38 Change the default password for WKSYS (Scored)	50
2.1.39 Change the default password for APEX_PUBLIC_USER (Scored)	50
2.2 Remove Oracle Sample Users	51

2.2.1 Remove the sample user 'SCOTT' (Scored)	51
2.2.2 Change the default password of SH (Scored)	51
2.2.3 Change the default password of IX (Scored)	52
2.2.4 Change the default password of BI (Scored)	53
2.2.5 Change the default password of PM (Scored)	53
2.2.6 Change the default password of HR (Scored)	54
2.2.7 Change the default password of OE (Scored)	54
2.3 Rejected - Ensure installation limits access to \$TEMP in Oracle (Scored)	55
2.4 Ensure the latest version/patches for Oracle software is installed (Scored)	56
2.5 Rejected - Ensure that the tkprof tool is removed or restricted (Scored).....	56
2.6 Rejected - Ensure the Oracle listener default name is changed (Scored)	57
2.7 Rejected - Ensure the Oracle listener file uses IPs instead of hostnames (Scored)	58
2.8 Rejected - Ensure the Oracle otrace *.dat files are removed (Scored)	58
2.9 Rejected - Ensure third-party accounts put on Oracle get new passwords (Scored)	59
2.10 Rejected - Change the Oracle default service identifier (sid) (Scored)	59
2.11 Change/lock the default Oracle software owner account (Scored)	60
3 Oracle Directory and File Permissions.....	61
3.1 Rejected - Verify/set permissions for any ifile targets.....	61
3.1.1 Verify/set permissions for any ifile targets in listener.ora (Scored)	61
3.1.2 Verify/set permissions for any ifile targets in init.ora (Scored)	62
3.1.3 Verify/set permissions for any ifile targets in tnsnames.ora (Scored)	62
3.2 Verify/set ownership of the \$ORACLE_HOME/bin directory (Scored)	63
3.3 Verify/set the umask for the oracle user .profile file (Not Scored)	63
3.4 Verify/set permissions for the init.ora file (Scored)	64
3.5 Verify/set permissions for the spfileorcl.ora file (Scored).....	65
3.6 Verify/set permissions for the database datafiles (*.dbs) (Scored)	66
3.7 Verify/set permissions for the audit_file_dest file target (Scored)	66
3.8 Verify/set permissions for the diagnostic_dest file target (Scored)	67
3.9 Verify/set permissions for the control_files file target (Scored)	68
3.10 Verify/set permissions for the log_archive_dest_n file targets (Scored)	68
3.11 Verify/set permissions on the \$ORACLE_HOME/network/admin/ directory files (Scored)	69
3.12 Rejected - Verify/set permissions on the sqlnet.ora file (Scored)	70

3.13 Verify/set permissions on the log_directory_client= target (Scored)	70
3.14 Verify/set permissions on the log_directory_server= target (Scored)	71
3.15 Verify/set permissions on the trace_directory_client target (Scored)	72
3.16 Verify/set permissions on the trace_directory_server target (Scored)	72
3.17 Verify/set permissions on the listener.ora file (Scored).....	73
3.18 Verify/set permissions on the log_file_listener file (Scored)	73
3.19 Verify/set permissions on the trace_directory_listener_name directory target (Scored)	74
3.20 Verify/set permissions on the trace_file_listener_name file target (Scored)	75
3.21 Verify/set permissions on the sqlplus binaries directory (Scored)	75
3.22 Rejected - Verify/set permissions on the postDBCreation.log file (Scored)	76
3.23 Rejected - Verify/set the umask for the oracle system in the /etc/skel/.bash_profile file (Scored)	77
3.24 Permissions settings for the radius.key file (Not Scored)	77
4 Oracle Parameter Settings.....	78
4.1 listener.ora Settings	78
4.1.1 Setting for the inbound_connect_timeout parameter (Scored).....	78
4.1.2 secure_control_listenername settings in listener.ora (Scored).....	79
4.1.3 extprocs_dlls settings in listener.ora (Scored)	80
4.1.4 Rejected - Dynamic listener registration settings in listener.ora (Scored)	80
4.1.5 Listener registration connection settings in listener.ora (Scored)	81
4.1.6 Listener administration protocol settings in listener.ora (Scored)	82
4.1.7 Settings for the admin_restrictions_listener_name parameter (Scored)	82
4.1.8 Setting for the logging_listener parameter (Scored)	83
4.1.9 Ensure there are no passwords in the listener.ora file (Scored).....	84
4.1.10 Change the default port numbers that connect to Oracle (Scored)	84
4.1.11 extprocs configuration in listener.ora (Scored)	85
4.1.12 secure_register_listener settings in listener.ora (Scored).....	86
4.2 sqlnet.ora settings.....	86
4.2.1 Setting for the sqlnet.expire_time parameter (Scored)	86
4.2.2 Settings for the tcp.invited_nodes parameter (Scored)	87
4.2.3 Settings for the tcp.excluded_nodes parameter (Scored).....	88
4.2.4 Setting for the sqlnet.inbound_connect_timeout parameter (Scored)	88

4.2.5 Setting for the SQLNET.ALLOWED_LOGON_VERSION parameter (Scored)	89
4.2.6 Setting for the tcp.validnode_checking parameter (Scored).....	90
4.3 Settings for the global_names parameter (Scored)	90
4.4 Block trace files from being read by PUBLIC users (Scored)	91
4.5 Settings for the remote_os_roles parameter (Scored)	92
4.6 Settings for the remote_listener parameter (Scored).....	92
4.7 Settings for the audit_trail parameter (Scored)	93
4.8 Settings for the os_authent_prefix parameter (Scored)	94
4.9 Settings for the os_roles parameter (Scored).....	94
4.10 Settings for the remote_os_roles parameter (Scored)	95
4.11 Settings for the utl_file_dir parameter (Scored).....	96
4.12 Rejected - Settings for the redo log on duplexed physical disk locations (Scored)	97
4.13 Rejected - Settings for successful redo log disk writes (Scored)	97
4.14 Settings for the sql92_security parameter (Scored)	98
4.15 Setting for the O7_dictionary_accessibility parameter (Scored)	99
4.16 Rejected - Setting for the spfile<sid>.ora parameter (Scored)	99
4.17 Setting for the audit_sys_operations parameter (Scored)	100
4.18 Rejected - Setting account access for the application schema owner (Scored)	101
4.19 Setting for the remote_login_passwordfile parameter (Scored).....	101
4.20 Rejected - Remote Administration via the Oracle Connection Manager (Scored)	102
4.21 Setting for sec_return_server_release_banner (Scored)	103
4.22 Rejected - Setting the DB_SECUREFILE parameter in init.ora (Scored).....	103
4.23 Setting for sec_case_sensitive_logon_settings (Scored).....	104
4.24 Rejected - Login requirements settings by version (Scored)	105
4.25 Setting for sec_max_failed_login_attempts (Scored)	105
4.26 Setting for sec_protocol_error_further_action (Scored)	106
4.27 Setting for sec_protocol_error_trace_action (Scored)	107
4.28 Settings for the local_listener parameter (Scored)	107
5 Possibly Rejected - Encryption-specific Requirements and Settings	108
5.1 Advanced Security Options.....	108
5.1.1 Encryption of server-to-client communications in sqlnet.ora (Scored)	108
5.1.2 Encryption of client-to-server communications in sqlnet.ora (Scored)	109

5.1.3 Integrity of server-to-client communications in sqlnet.ora (Scored)	110
5.1.4 Integrity of client-to-server communications in sqlnet.ora (Scored)	110
5.1.5 Type of server-to-client integrity checks in sqlnet.ora (Scored)	111
5.1.6 Type of client-to-server integrity checks in sqlnet.ora (Scored)	112
5.1.7 Encryption algorithm/strength of server-to-client connections (Scored)	113
5.1.8 Encryption algorithm/strength of client-to-server connections (Scored)	113
5.1.9 Secure Sockets Layer (SSL) version setting in sqlnet.ora (Scored)	114
5.1.10 Secure Sockets Layer (SSL) cipher suites in sqlnet.ora (Scored)	115
5.1.11 SSL certificate Distinguished Name (DN) in sqlnet.ora (Scored)	115
5.1.12 SSL Client certificate usage requirements in sqlnet.ora (Scored)	116
5.1.13 SSL certificate revocation check requirements in sqlnet.ora (Scored)	117
5.1.14 SSL certificate Distinguished Name check in sqlnet.ora (Scored)	117
5.2 FIPS-compliant communications setting in fips.ora (Scored)	118
5.3 Certificate-request key size in the Oracle wallet (Scored)	119
5.4 Auto-login to the Oracle wallet for SSL connections (Scored)	119
6 Oracle client/user connection and login restrictions	120
6.1 Rejected - Database Profile	121
6.2 Restrictions on failed login attempts via the default DB profile (Scored)	121
6.3 Requirements for account locking via on the default DB profile (Scored)	121
6.4 Restrictions on password duration via the default DB profile (Scored)	122
6.5 Restrictions on password history via the default DB profile (Scored)	122
6.6 Restrictions on password use (reuse) via a DB profile (Scored)	123
6.7 Requirements for account locking (grace time) via a DB profile (Scored)	124
6.8 Requirements for limiting EXTERNAL user login capability (Scored)	124
6.9 Requirement for setting the password verification function (Scored)	125
6.10 Rejected - Requirements for limiting user CPU resource allocations (Scored)	126
6.11 Rejected - Requirements for limiting System Global Area resources (Scored)	126
6.12 Rejected - Requirements for limiting amount of disk-access per session (Scored)	127
6.13 Requirements for limiting the number of sessions per user (Scored)	128
6.14 Rejected - Requirements for limiting the connect time for users (Scored)	128
6.15 Rejected - Requirements for limiting the idle time for users (Scored)	129
7 Oracle user access and authorization restrictions	129

7.1 Default Public Privileges for Packages and Object Types	129
7.1.1 Privilege access for the DBMS_OBFUSCATION_TOOLKIT (Not Scored)	130
7.1.2 Privilege access for the DBMS_CRYPTO package (Not Scored)	130
7.1.3 Limiting user access to the UTL_FILE package (Not Scored)	131
7.1.4 Limiting user access to the UTL_TCP package (Not Scored)	131
7.1.5 Limiting user access to the DBMS_JOB package (Not Scored)	132
7.1.6 Limiting user access to the DBMS_SQL package (Not Scored)	133
7.1.7 Limit public access to the DBMS_RANDOM (Not Scored)	133
7.1.8 Limiting user access to the DBMS_LOB package (Not Scored)	134
7.1.9 Limiting user access to the UTL_SMTP package (Not Scored)	134
7.1.10 Limiting user access to the UTL_HTTP package (Not Scored)	135
7.1.11 Limiting user access to the DBMS_SCHEDULER package (Not Scored)	135
7.1.12 Limiting user access to the HTTPURITYPE (Not Scored)	136
7.1.13 Limiting user access to the DBMS_ADVISOR package (Not Scored)	136
7.1.14 Limiting user access to the UTL_INADDR package (Not Scored)	137
7.1.15 Limiting user access to the DBMS_LDAP package (Not Scored)	138
7.1.16 Limiting user access to the DBMS_XMLGEN package (Not Scored)	138
7.1.17 Limiting user access to the DBMS_JAVA package (Not Scored)	139
7.1.18 Limiting user access to the DBMS_JAVA_TEST package (Not Scored)	139
7.1.19 Limiting user access to the DBMS_XMLQUERY package (Not Scored)	140
7.1.20 Limiting user access to the UTL_MAIL package (Not Scored)	140
7.1.21 Limiting user access to the UTL_DBWS package (Not Scored)	141
7.1.22 Limiting user access to the UTL_ORAMTS package (Not Scored)	141
7.2 Non-Default Public Privileges for Packages and Object Types	142
7.2.1 Limiting public user access to the DBMS_SYS_SQL package (Not Scored)	142
7.2.2 Limit public access to the DBMS_BACKUP_RESTORE (Not Scored)	143
7.2.3 Limiting public user access to the DBMS_AQADM_SYSCALLS package (Not Scored)	143
7.2.4 Limiting public user access to the DBMS_REPACT_SQL_UTL package (Not Scored)	144
7.2.5 Limiting public user access to the INITJVMAUX package (Not Scored)	144
7.2.6 Limiting public user access to the DBMS_STREAMS_ADM_UTL package (Not Scored)	145
7.2.7 Limiting public user access to the DBMS_AQADM_SYS package (Not Scored)	145
7.2.8 Limiting public user access to the DBMS_STREAMS_RPC package (Not Scored)	146

7.2.9 Limiting public user access to the DBMS_AQADM_SYS package (Not Scored)	146
7.2.10 Limiting public user access to the DBMS_PRIVTAQIM package (Not Scored)	147
7.2.11 Limiting public user access to the LTADM package (Not Scored)	147
7.2.12 Limiting public user access to the WWV_DBMS_SQL package (Not Scored)	148
7.2.13 Limiting public user access to the WWV_EXECUTE_IMMEDIATE package (Not Scored)	148
7.2.14 Limiting public user access to the DBMS_IJOB package (Not Scored)	149
7.2.15 Limiting public user access to the DBMS_FILE_TRANSFER package (Not Scored)	149
7.3 System Privileges	150
7.3.1 Limiting users by restricting the SELECT ANY DICTIONARY privilege (Not Scored)	150
7.3.2 Limiting users by restricting the SELECT ANY TABLE privilege (Not Scored)	150
7.3.3 Limiting users by restricting the AUDIT SYSTEM privilege (Not Scored)	151
7.3.4 Limiting users by restricting the EXEMPT ACCESS POLICY (Not Scored)	152
7.3.5 Limiting users by restricting the BECOME USER privilege (Not Scored)	152
7.3.6 Limiting users by restricting the CREATE PROCEDURE privilege (Not Scored)	153
7.3.7 Limiting users by restricting the ALTER SYSTEM privilege (Not Scored)	153
7.3.8 Limiting users by restricting the CREATE LIBRARY privilege (Not Scored)	154
7.3.9 Limiting users by restricting GRANT ANY OBJECT PRIVILEGE (Not Scored)	155
7.3.10 Limiting users by restricting GRANT ANY ROLE (Not Scored)	155
7.3.11 Limiting users by restricting GRANT ANY PRIVILEGE (Not Scored)	156
7.3.12 Limiting users by restricting GRANT ALL PRIVILEGES (Not Scored)	156
7.4 Role Privileges	157
7.4.1 Limiting user authorizations for the DELETE_CATALOG_ROLE (Not Scored)	157
7.4.2 Limiting user authorizations for the SELECT_CATALOG_ROLE (Not Scored)	158
7.4.3 Limiting user authorizations for the EXECUTE_CATALOG role (Not Scored)	158
7.4.4 Limiting users by restricting the DBA role (Not Scored)	159
7.5 Table and View privileges	159
7.5.1 Limiting authorizations for the SYS.AUD\$ table (Not Scored)	160
7.5.2 Limiting authorizations for the SYS.USER_HISTORY\$ table (Not Scored)	160
7.5.3 Limiting authorizations for the SYS.LINK\$ table (Not Scored)	161
7.5.4 Limiting authorizations for the SYS.USER\$ table (Not Scored)	161
7.5.5 Rejected - Limiting authorizations for the SYS.SOURCE\$ table (Not Scored)	162
7.5.6 Limiting user authorizations for the \$X tables (Not Scored)	162

7.5.7 Limiting user authorizations for the DBA_% views (Not Scored)	163
7.5.8 Limiting user authorizations for the \$V_ views (Not Scored)	164
7.5.9 Rejected - Limiting user authorizations for the \$V synonym(s) (Not Scored)	164
7.5.10 Limiting authorizations for the SCHEDULER\$_CREDENTIAL table (Not Scored)	165
7.5.11 Drop table sys.user\$mig (Not Scored)	166
7.6 Other Privileges.....	166
7.6.1 Access to ACL privileges (Not Scored)	166
7.7 Limiting user authorizations for the SYSTEM tablespace (Not Scored)	167
7.8 Rejected - Limiting application/developer resources on a tablespace (Not Scored)	167
7.9 Rejected - Limiting authorizations for edition-based upgrade versioning (Not Scored)	168
7.10 Rejected - Limiting authorizations for the PERFSTAT.STATS\$SQLTEXT table (Not Scored)	169
7.11 Rejected - Limiting authorizations to PERFSTAT.STATS\$SQL_SUMMARY table (Not Scored) ..	169
7.12 Rejected - Limiting user authorizations for the ALL_SOURCE view (Not Scored)	170
7.13 Rejected - Limiting user authorizations for the DBA_ROLES view (Not Scored)	170
7.14 Rejected - Limiting user authorizations for the DBA_SYS_PRIVS view (Not Scored)	171
7.15 Rejected - Limiting user authorizations for the DBA_ROLE_PRIVS view (Not Scored)	172
7.16 Rejected - Limiting user authorizations for the DBA_TAB_PRIV view (Not Scored)	172
7.17 Rejected - Limiting user authorizations for the ROLE_ROLE_PRIVS view (Not Scored)	173
7.18 Rejected - Limiting user authorizations for the USER_TAB_PRIVS view (Not Scored)	173
7.19 Rejected - Limiting user authorizations for the USER_ROLE_PRIVS view (Not Scored)	174
7.20 Rejected - Limiting user authorizations for the RECOVERY_CATALOG_OWNER (Not Scored)	175
7.21 Rejected - Limiting basic user privileges to CREATE_SESSION (Not Scored)	175
7.22 Limiting basic user privileges to restrict the ANY keyword (Not Scored)	176
7.23 Limiting users by restricting the WITH_ADMIN privilege (Not Scored)	177
7.24 Limiting PUBLIC by restricting the WITH_GRANT (SELECT) privilege (Not Scored)	177
7.25 Limiting PUBLIC by restricting the WITH_GRANT (EXECUTABLE) privilege (Not Scored)	178
7.26 Rejected - Limiting users by restricting the CREATE privilege (Not Scored)	178
7.27 Rejected - Limiting users by restricting privileges on PUBLIC (Not Scored)	179
7.28 Rejected - Limiting users by restricting the RESOURCE role (Not Scored)	180
7.29 Rejected - Limit public access to views beginning with ALL_ (Not Scored)	180
7.30 Rejected - Limit access to standard database roles (Not Scored)	181
7.31 Limit direct privileges for proxy user (Not Scored)	182

7.32 Revoke execute any procedure from user OUTLN (Not Scored)	182
7.33 Revoke execute any procedure from user DBSNMP (Not Scored)	183
8 Rejected - General Policies and Procedures	183
8.1 Prohibit the database accessing a Public network interface card (Not Scored)	183
8.2 Permissions for database creation scripts (Not Scored)	184
8.3 Limit membership in the DBA users group (Not Scored)	185
8.4 Remove the username "oracle" from software account ownership (Not Scored)	186
9 Audit/Logging Policies and Procedures	187
9.1 Audit all CREATE SESSION (logon/logoff) activities (Not Scored)	187
9.2 Rejected - Audit all user CLUSTER activities/requests (Not Scored)	187
9.3 Rejected - Audit all user CONTEXT activities/requests (Not Scored)	188
9.4 Audit all user DATABASE LINK activities/requests (Not Scored)	189
9.5 Audit all user SELECT ANY DICTIONARY activities/requests (Not Scored)	190
9.6 Rejected - Audit all user DIMENSION activities/requests (Not Scored)	191
9.7 Audit all user DIRECTORY activities/requests (Not Scored)	191
9.8 Rejected - Audit all user INDEX activities/requests (Not Scored)	192
9.9 Rejected - Audit all user MATERIALIZED VIEW activities/requests (Not Scored)	193
9.10 Audit all user GRANT ANY OBJECT PRIVILEGE activities/requests (Not Scored)	194
9.11 Audit all user GRANT ANY PRIVILEGE activities/requests (Not Scored)	195
9.12 Audit all user PROCEDURE activities/requests (Not Scored)	195
9.13 Audit all user PROFILE activities/requests (Not Scored)	197
9.14 Audit all user PUBLIC DATABASE LINK activities/requests (Not Scored)	198
9.15 Audit all user PUBLIC SYNONYM activities/requests (Not Scored)	199
9.16 Audit all user ROLE activities/requests (Not Scored)	200
9.17 Rejected - Audit all user ROLLBACK SEGMENT activities/requests (Not Scored)	201
9.18 Rejected - Audit all user SEQUENCE activities/requests (Not Scored)	202
9.19 Audit all user SYNONYM activities/requests (Not Scored)	203
9.20 Rejected - Audit all user TABLE activities/requests (Not Scored)	203
9.21 Rejected - Audit all user TABLESPACE activities/requests (Not Scored)	204
9.22 Audit all user TRIGGER activities/requests (Not Scored)	205
9.23 Rejected - Audit all user TYPE activities/requests (Not Scored)	206
9.24 Audit all USER object activities/requests (Not Scored)	207

9.25 Rejected - Audit all VIEW object activities/requests (Not Scored)	208
9.26 Rejected - Audit all unsuccessful table SELECT activities (Not Scored)	209
9.27 Rejected - Audit all SELECT ANY TRANSACTION activities (Not Scored)	209
9.28 Set AUDIT ALL ON SYS.AUD\$ activities (Not Scored)	210
Appendix: Change History.....	212

Overview

This document is intended to address the recommended security settings for the Oracle 11g, r2 Database ©, running on either an x86 (32-bit) or x64 (64-bit) AMD/Intel chip platform. Specifically, the requirements included in this document have been designed for and tested against the Intel x64 chip running a 64-bit version of Oracle Linux © 2.6.18-194 configured as a stand-alone system, running as a "Database server," including all Oracle CPUs up through April 15, 2012. Future Oracle 11g r2 critical patch updates (CPUs) may impact the recommendations included in this document.

To obtain the latest version of this guide, please visit <http://benchmarks.cisecurity.org>. If you have questions, comments, or have identified ways to improve this guide, please write us at feedback@cisecurity.org.

Intended Audience

This benchmark is intended for system and application administrators, security specialists, auditors, help desk, and platform deployment personnel who plan to develop, deploy, assess, or secure solutions that incorporate Oracle Database Server 11g R2 on Oracle Linux 5.

Consensus Guidance

This benchmark was created using a consensus review process comprised of volunteer and contract subject matter experts. Consensus participants provide perspective from a diverse set of backgrounds including consulting, software development, audit and compliance, security research, operations, government, and legal.

Each CIS benchmark undergoes two phases of consensus review. The first phase occurs during initial benchmark development. During this phase, subject matter experts convene to discuss, create, and test working drafts of the benchmark. This discussion occurs until consensus has been reached on benchmark recommendations. The second phase begins after the benchmark has been released to the public Internet. During this phase, all feedback provided by the Internet community is reviewed by the consensus team for incorporation in the benchmark. If you are interested in participating in the consensus review process, please send us a note to feedback@cisecurity.org.

Typographical Conventions

The following typographical conventions are used throughout this guide:

Convention	Meaning
Stylized Monospace font	Used for blocks of code, command, and script examples. Text should be interpreted exactly as presented.
Monospace font	Used for inline code, commands, or examples. Text should be interpreted exactly as presented.
<italic font in brackets>	Italic texts set in angle brackets denote a variable requiring substitution for a real value.
Italic font	Used to denote the title of a book, article, or other publication.
Note	Additional information or caveats

Scoring Information

A scoring status indicates whether compliance with the given recommendation impacts the assessed target's benchmark score. The following scoring statuses are used in this benchmark:

Scored

Failure to comply with "Scored" recommendations will decrease the final benchmark score. Compliance with "Scored" recommendations will increase the final benchmark score.

Not Scored

Failure to comply with "Not Scored" recommendations will not decrease the final benchmark score. Compliance with "Not Scored" recommendations will not increase the final benchmark score.

Profile Definitions

The following configuration profiles are defined by this Benchmark:

- **Level 1 - 11.2 on Oracle Linux 5**

Items in this profile intend to:

- be practical and prudent;
 - provide a clear security benefit; and
 - not negatively inhibit the utility of the technology beyond acceptable means.
- **Level 2 - 11.2 on Oracle Linux 5**

This profile extends the "Level 1" profile. Items in this profile exhibit one or more of the following characteristics:

- are intended for environments or use cases where security is paramount.
 - acts as defense in depth measure.
 - may negatively inhibit the utility or performance of the technology.
- **Level 1 - 11.x on any platform**
 - **Level 1 - 11.2 on any platform**
 - **Level 1 - 11.2 on Windows**

Acknowledgements

This benchmark exemplifies the great things a community of users, vendors, and subject matter experts can accomplish through consensus collaboration. The CIS community thanks the entire consensus team with special recognition to the following individuals who contributed greatly to the creation of this guide:

Author

Alan Covell, *Qualys, Inc*

Editor

Stephen Willis, *Qualys, Inc*

TBD

This section defines the scoring statuses used within this document. The scoring status indicates whether compliance with the given recommendation is discernible in an automated manner.

Scored

The platform's compliance with the given recommendation can be determined via automated means.

Not Scored

The platform's compliance with the given recommendation cannot be determined via automated means.

Recommendations

1 Rejected - OS-specific settings for the Oracle installation

The Oracle database will require OS-specific settings for shared memory and semaphores, which vary by operating system, as well as the establishment of specific user/group accounts. Post-installation, these unnecessary privileges should be removed.

1.1 Set `kernel.shmall` value (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle DB system requires shared memory settings that will support the size of the instance's requirements. The `kernel.shmall` value will set the total for the shared memory pages available system-wide.

Rationale:

As the Oracle system needs sufficient shared memory values set to prevent a loss of services, the `kernel.shmall` value should be set according to the needs of the organization.

Audit:

```
grep kernel.shmall /etc/sysctl.conf
```

Remediation:

```
# cd /etc
# if [ "$(grep '^kernel.shmall' sysctl.conf)" ]; then awk '/^kernel.shmall/ { $3 =
"1073741824" } { print }' sysctl.conf > sysctl.conf.new mv sysctl.conf.new
sysctl.conf; else echo kernel.shmall = 1073741824 >> sysctl.conf;
fi
```

1.2 Set `fs.file-max` value (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle DB system requires shared settings that will support the size of the instance's requirements. The `fs.file-max` value will set the memory parameters for this.

Rationale:

As the Oracle system will need basic levels of shared memory and semaphore values set to prevent a loss of services, the `fs.file-max` value should be set according to the needs of the organization.

Audit:

```
#grep fs.file-max /etc/sysctl.conf
```

Remediation:

```
# cd /etc
# if [ "`grep '^fs.file-max ' sysctl.conf`" ]; then awk '/^ fs.file-max / { $3 =
"327679" } { print }' sysctl.conf > sysctl.conf.new mv sysctl.conf.new sysctl.conf;
else echo fs.file-max = 327679 >> sysctl.conf
fi
```

1.3 Set kernel.msgmni value (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle DB system requires shared memory settings that will support the size of the instance's requirements. The `kernel.msgmni` value will set the `max_queues_system` wide vale.

Rationale:

As the Oracle system will need basic levels of shared memory and semaphore values set to prevent a loss of services, the `kernel.msgmni` value should be set according to the needs of the organization.

Audit:

```
#grep kernel.msgmni /etc/sysctl.conf
```

Remediation:

```
# cd /etc
# if [ "`grep '^kernel.msgmni' sysctl.conf`" ]; then awk '/^ kernel.msgmni / { $3 =
```

```
"2878" } { print }' sysctl.conf > sysctl.conf.new mv sysctl.conf.new sysctl.conf;
else echo kernel.msgmni = 2878 >> sysctl.conf
fi
```

1.4 Set kernel.sem value (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle DB system requires semaphore settings that will support the size of the instance's requirements. The `kernel.sem` will set these semaphore values.

Rationale:

As the Oracle system will need basic levels of shared memory and semaphore values set to prevent a loss of services, the `kernel.sem` value should be set according to the needs of the organization.

Audit:

```
#grep kernel.sem /etc/sysctl.conf
```

Remediation:

```
# cd /etc
# if [ "`grep '^kernel.sem' sysctl.conf`" ]; then awk '/^ kernel.sem / { $3 = "250" }
{ $4 = "32000" } { $5 = "100" } { $6 = "142" } { print }' sysctl.conf >
sysctl.conf.new mv sysctl.conf.new sysctl.conf; else echo kernel.sem = 250 32000 100
142 >> sysctl.conf
fi
```

1.5 Set kernel.shmmni value (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle DB system requires semaphore settings that will support the size of the instance's requirements. The `kernel.shmmni` value will set the system wide maximum number of shared memory segments.

Rationale:

As the Oracle system will need basic levels of shared memory and semaphore values set to prevent a loss of services, the `kernel.shmmni` value should be set according to the needs of the organization.

Audit:

```
#grep kernel.shmmni /etc/sysctl.conf
```

Remediation:

```
# cd /etc
# if [ "`grep '^kernel.shmmni' sysctl.conf`" ]; then awk '/^ kernel.shmmni / { $3 =
"4096" } { print }' sysctl.conf > sysctl.conf.new mv sysctl.conf.new sysctl.conf;
else echo kernel.shmmni = 4096 >> sysctl.conf
fi
```

1.6 Set net.core.rmem_default value (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle DB system requires semaphore settings that will support the size of the instance's requirements. The `net.core.rmem_default` value will set the default OS receive buffer size for all types of connections.

Rationale:

As the Oracle system will need basic levels of shared memory and semaphore values set to prevent a loss of services, the `net.core.rmem_default` value should be set according to the needs of the organization.

Audit:

```
#grep net.core.rmem_default /etc/sysctl.conf
```

Remediation:

```
# cd /etc
# if [ "`grep '^net.core.rmem_default' sysctl.conf`" ]; then awk
'/^net.core.rmem_default/ { $3 = "262144" } { print }' sysctl.conf > sysctl.conf.new
mv sysctl.conf.new sysctl.conf; else echo net.core.rmem_default = 262144 >>
sysctl.conf
fi
```

1.7 Set *net.core.rmem_max* value (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle DB system requires semaphore settings that will support the size of the instance's requirements. The `net.core.rmem_max` value will set the max OS receive buffer size for all types of connections.

Rationale:

As the Oracle system will need basic levels of shared memory and semaphore values set to prevent a loss of services, the `net.core.rmem_max` value should be set according to the needs of the organization.

Audit:

```
#grep net.core.rmem_max /etc/sysctl.conf
```

Remediation:

```
# cd /etc
# if [ "`grep '^net.core.rmem_max' sysctl.conf`" ]; then awk '/^net.core.rmem_max/ {
$3 = "4194304" } { print }' sysctl.conf > sysctl.conf.new mv sysctl.conf.new
sysctl.conf; else echo net.core.rmem_max = 4194304 >> sysctl.conf
fi
```

1.8 Set *net.core.wmem_max* value (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle DB system requires semaphore settings that will support the size of the instance's requirements. The `net.core.wmem_max` value will set the default OS send buffer size for all types of connections.

Rationale:

As the Oracle system will need basic levels of shared memory and semaphore values set to prevent a loss of services, the `net.core.wmem_max` value should be set according to the needs of the organization.

Audit:

```
#grep net.core.wmem_max /etc/sysctl.conf
```

Remediation:

```
# cd /etc
# if [ "`grep '^net.core.wmem_max' sysctl.conf`" ]; then awk '/^net.core.wmem_max/ {
$3 = "1048576" } { print }' sysctl.conf > sysctl.conf.new mv sysctl.conf.new
sysctl.conf; else echo net.core.wmem_max = 1048576 >> sysctl.conf
fi
```

1.9 Set net.core.wmem_default value (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle DB system requires semaphore settings that will support the size of the instance's requirements. The `net.core.wmem_default` value sets the default OS send buffer size for all types of connections.

Rationale:

As the Oracle system will need basic levels of shared memory and semaphore values set to prevent a loss of services, the `net.core.wmem_default` value should be set according to the needs of the organization.

Audit:

```
#grep net.core.wmem_default /etc/sysctl.conf
```

Remediation:

```
# cd /etc
# if [ "`grep '^net.core.wmem_default' sysctl.conf`" ]; then awk
'/^net.core.wmem_default/ { $3 = "262144" } { print }' sysctl.conf > sysctl.conf.new
mv sysctl.conf.new sysctl.conf; else echo net.core.wmem_default = 262144 >>
sysctl.conf
fi
```

1.10 Set vm.min_free_kbytes value (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle DB system requires settings that will support the size of the instance's requirements. The `vm.min_free_kbytes` value will force the Linux VM to keep a minimum number of kilobytes free.

Rationale:

As the Oracle system will need basic levels of shared memory and semaphore values set to prevent a loss of services, the `vm.min_free_kbytes` value should be set according to the needs of the organization.

Audit:

```
# grep vm.min_free_kbytes /etc/sysctl.conf
```

Remediation:

```
# cd /etc
# if [ "`grep '^vm.min_free_kbytes' sysctl.conf`" ]; then awk '/^vm.min_free_kbytes/ {
$3 = "51200" } { print }' sysctl.conf > sysctl.conf.new mv sysctl.conf.new
sysctl.conf; else echo vm.min_free_kbytes = 51200 >> sysctl.conf
fi
```

1.11 Limit OS-based access to the Oracle directory (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle DB system directory, containing all configuration files/settings should not require access except for the administrator, system, and Oracle-specific OS accounts.

Rationale:

The Oracle instance should have all of its files in a single location for monitoring and access controls. As restricting access to the Oracle files on the system to the absolute minimum of accounts can help prevent file corruption or theft of proprietary information, these permissions should be set according to the needs of the organization.

Audit:

```
$ ls -ald $ORACLE_HOME
```

Remediation:

```
$ chmod 751 $ORACLE_HOME
```

1.12 Install Oracle software of a separate partition (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5
- Level 2 - 11.2 on Oracle Linux 5

Description:

Ideally, the Oracle software installation would be on its own system. At minimum, Oracle should be installed on a single disk partition, with only Oracle-specific files required for database operations, with the data/control files and installed on separate partitions of their own, not under the "/oracle" partition.

Rationale:

As the Oracle instance's database and/or OS operations can potentially be corrupted by non-Oracle software if Oracle is not on a separate disk partition, the Oracle partition structuring should be established according to the needs of the organization.

Audit:

```
$ df $ORACLE_HOME  
$ cd $ORACLE_HOME  
$ ls -al | awk '{print $3,$6,$7,$8,$9}' | grep -v oracle
```

Remediation:

Ensure that Oracle is installed on a distinct Oracle partition during initial setup

1.13 REMOVE ME - Install Oracle Control Files on a separate partition (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5
- Level 2 - 11.2 on Oracle Linux 5

Description:

The Oracle software installation should be on its own host, with specific partitions for the Control Files, ideally on separate disks. (Oracle recommends having 3 separate Control Files.) At minimum, the Control Files should be installed on multiple disk partitions and not under the "oracle" (software) partition.

Rationale:

As the Oracle instance's data recovery capabilities can potentially be compromised by corrupted control files, the Oracle partition structuring should be established according to the needs of the organization.

Audit:

(The variable \$ORACLE_CTL was created for test consistency.)

```
$ ORACLE_CTL=/home/oracle/app/oracle/oradata/orcl (test ctl file)
$ export ORACLE_CTL
$ df $ORACLE_CTL/control*
Filesystem      1K-blocks  Used    Available Use%    Mounted on
/dev/hdb1       12184796   8355048   3200808    73%    /home

This can also be done by using PL/SQL to extract the control file names:

SELECT VALUE FROM V$PARAMETER WHERE NAME = 'control_files';
Then do a "df control_file_path" on the result(s):
```

Remediation:

Database control files need to be moved to at least two separate partitions

1.14 REMOVE ME - Install Oracle Redo Log files on separate partitions (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5
- Level 2 - 11.2 on Oracle Linux 5

Description:

The Oracle software installation should be on its own host, with specific partitions for the Redo Log Files, ideally on separate disks. (Oracle recommends having 3 separate Redo Log Files.) At minimum, the Redo Logs should be split between multiple disk partitions, not under the "oracle" partition, to avoid a single point of failure if a disk is corrupted.

Rationale:

As the Oracle instance's data recovery capabilities can potentially be compromised by corrupted Redo Log files, the Oracle partition structuring should be established according to the needs of the organization.

Audit:

(The variable \$ORACLE_CTL was created for test consistency.)

```
$ ORACLE_CTL=/home/oracle/app/oracle/oradata/orcl (test ctl file)
$ export ORACLE_CTL
$ df $ORACLE_CTL/redo*
Filesystem    1K-blocks    Used      Available Use%    Mounted on
/dev/hdb1     12184796    8365928    3189928   73%    /home
/dev/hdb1     12184796    8365928    3189928   73%    /home
/dev/hdb1     12184796    8365928    3189928   73%    /home
```

Remediation:

Database Redo Log files need to be moved to at least two separate partitions

1.15 REMOVE ME - Verify access for the DBMS_OBSFUCATION_TOOLKIT (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `DBMS_OBSFUCATION_TOOLKIT` settings provide one of the tools that determine the strength of the encryption algorithm used to encrypt application data and is part of the SYS schema. (The DES (56-bit key) and 3DES (168-bit key) are the two types available and `PUBLIC` is granted the `EXECUTE` permission by default.) The encryption functions of the `DBMS_OBSFUCATION_TOOLKIT` have been replaced by the `DBMS_CCRYPTO` package (see below), but this has been kept for backwards compatibility.

Rationale:

As encrypted data storage procedures can become a Denial-of-Service if unauthorized users with `PUBLIC` privileges encrypt the data stream to an unknown key, this value should be set according to the needs of the organization.

Audit:

```
SELECT TABLE_NAME FROM DBA_TAB_PRIVS WHERE GRANTEE='PUBLIC' AND PRIVILEGE='EXECUTE'
AND TABLE_NAME='DBMS_OBSFUCATION_TOOLKIT';
```

Remediation:

```
REVOKE EXECUTE ON DBMS_OBSFUCATION_TOOLKIT to PUBLIC;
```

1.16 REMOVE ME - Verify access for the DBMS_CRYPTO_TOOLKIT (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `DBMS_CRYPTO_TOOLKIT` settings provide one of the tools that determine the strength of the encryption algorithm used to encrypt application data and is part of the `SYS` schema. (The DES (56-bit key), 3DES (168-bit key), AES-128/192/256 (128/192/256-bit keys), and RC4 (a unique key per session), are the types available and `PUBLIC` is granted the `EXECUTE` permission by default.) The encryption functions of the `DBMS_CRYPTO_TOOLKIT` replace the `DBMS_OBFUSCATION_TOOLKIT`, with the prior package being kept for backwards compatibility.

Rationale:

As encrypted data storage procedures can become a Denial-of-Service if unauthorized users with `PUBLIC` privileges encrypt the data stream to an unknown key, this value should be set according to the needs of the organization.

Audit:

```
SELECT TABLE_NAME FROM DBA_TAB_PRIVS WHERE GRANTEE='PUBLIC' AND PRIVILEGE='EXECUTE'
AND TABLE_NAME='DBMS_CRYPTO_TOOLKIT';
```

Remediation:

```
REVOKE EXECUTE ON DBMS_CRYPTO_TOOLKIT TO PUBLIC;
```

2 Oracle Database Installation and Patching Requirements

One of the best ways to ensure secure Oracle security is to implement Critical Patch Updates (CPUs) as they come out, along with any applicable OS patches that will not interfere with system operations.

2.1 Change the Oracle default account passwords

The Oracle 11gR2 installation creates a number of well-known, default accounts, which are shown in the `DBA_USERS` view, "locking and expiring" about half of these, (excepting the

system accounts needed for immediate operation, such as SYS, SYSMAN, SYSTEM, etc.) to help prevent exploitation of these accounts and their privileges by unauthorized users. For Oracle versions prior to 11g, with unchanging salt DES encryption, system accounts could be broken in anything from less than minute (for those with defaults still in place) to 2 days, for an 8-character, case-insensitive ASCII password. This has been changed in 11g, with passwords now being hashed with SHA-1, but these passwords remain crackable, due to the inclusion of the old password hash in the same Oracle table for reverse compatibility, so care should be taken to mix cases and use whatever special characters are available, to expand the symbol-space to $x \geq 10^{256}$, which will greatly strengthen dba and system passwords. Any of these accounts that are not required can potentially be deleted, but extensive testing should be done in a non-Production environment prior to removing a default account, to avoid breaking critical processes associated with legacy applications. The accounts for used for testing such as SCOTT and accounts installed via sample DBs, such as HR will not be dealt with here.

2.1.1 Change the default password for 'SYS' (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The SYS account is the highest level user created by the database installation.

Rationale:

As the default SYS account created by Oracle has a well-known password and with the "SYS and SYSDBA" login provides the most powerful a point for an unauthorized user if left at the default setting, this value should be changed according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM SYS.USER$ WHERE NAME='SYS';
```

Remediation:

```
Execute the following command to change the password
SQL> password sys
```

```
Enter the new password twice:
Changing password for sys
New password:
Retype new password:
Password changed
```

2.1.2 Change the default password for SYSTEM (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `SYSTEM` user does not have dba privileges by default, but is created for administrative purposes during the database installation.

Rationale:

As the default `SYSTEM` account created by Oracle has a well-known password and can provide a point for full dba access by unauthorized users if left at the default setting, this value should be changed according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='SYSTEM';
```

Remediation:

```
SQL> ALTER USER SYSTEM IDENTIFIED BY newpassword;
```

2.1.3 Change the default password for OUTLN (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `OUTLN` user helps preserve application stability by preventing changes to the database environment from overly impacting system performance characteristics.

Rationale:

As the default `OUTLN` account created by Oracle has a well-known password and can provide a point for database access by unauthorized users if left at the default setting, this value should be changed according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='OUTLN';
```

Remediation:

```
SQL> ALTER USER OUTLN IDENTIFIED BY newpassword;
```

2.1.4 Change the default password for DIP (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `DIP` account supports the operation of the Oracle Internet Directory and Oracle Label Security.

Rationale:

As the default `DIP` account created by Oracle has a well-known password and can provide a point for database access by unauthorized users if left at the default setting, this value should be changed according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='DIP';
```

Remediation:

```
SQL> ALTER USER DIP IDENTIFIED BY newpassword;
```

2.1.5 Change the default password for ORACLE_OCM (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `ORACLE_OCM` account supports the operation of the Configuration Manager with the instance and the OracleMetaLink.

Rationale:

As the default `ORACLE_OCM` account created by Oracle has a well-known password and can provide a point for database access by unauthorized users if left at the default setting, this value should be changed according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME=' ORACLE_OCM ';
```

Remediation:

```
SQL> ALTER USER ORACLE_OCM IDENTIFIED BY newpassword;
```

2.1.6 Change the default password for APPQOSSYS (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `APPQOSSYS` account manages/owns all Quality of Service objects and provides an intuitive, policy-driven system to manage service level requirements.

Rationale:

As the default `APPQOSSYS` account created by Oracle has a well-known password and can provide a point for database access by unauthorized users if left at the default setting, this value should be changed according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='APPQOSSYS';
```

Remediation:

```
SQL> ALTER USER APPQOSSYS IDENTIFIED BY newpassword;
```

2.1.7 Change the default password for WMSYS (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `WMSYS` account stores manages all metadata for the Workspace manager, which provides a virtual environment to isolate workspaces, such as a collection of changes to production data, or keep a changes history, allowing the creation of "what if" scenarios.

Rationale:

As the default `WMSYS` account created by Oracle has a well-known password and can provide a point for database access by unauthorized users if left at the default setting, this value should be changed according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='WMSYS';
```

Remediation:

```
SQL> ALTER USER WMSYS IDENTIFIED BY newpassword;
```

2.1.8 Change the default password for EXFSYS (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `EXFSYS` account accesses the `EXFSYS` schema, which facilitates use of the Rules Manager and Expression Filter feature and allows the user to build complex PL/SQL rules and expressions.

Rationale:

As the default `EXFSYS` account created by Oracle has a well-known password and can provide a point for database access by unauthorized users if left at the default setting, this value should be changed according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='WMSYS';
```

Remediation:

```
SQL> ALTER USER WMSYS IDENTIFIED BY newpassword;
```

2.1.9 Change the default password for CTXSYS (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `CTXSYS` account enables the building of Oracle text query applications and provides indexing, theme/word search capabilities, and viewing of text.

Rationale:

As the default `CTXSYS` account created by Oracle has a well-known password and can provide a point for database access by unauthorized users if left at the default setting, this value should be changed according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='CTXSYS';
```

Remediation:

```
SQL> ALTER USER CTXSYS IDENTIFIED BY newpassword;
```

2.1.10 Change the default password for XDB (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `XDB` account enables high-performance storage and retrieval of XML data.

Rationale:

As the default `XDB` account created by Oracle has a well-known password and can provide a point for database access by unauthorized users if left at the default setting, this value should be changed according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='XDB';
```

Remediation:

```
SQL> ALTER USER XDB IDENTIFIED BY newpassword;
```

2.1.11 Change the default password for ANONYMOUS (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `ANONYMOUS` account provides HTTP access for the XML portion of the Oracle database and enables the Oracle Application Express (APEX), which comes pre-installed from version 11g onwards.

Rationale:

As the default `ANONYMOUS` account created by Oracle has a well-known password and can provide a point for database access by unauthorized users if left at the default setting, this value should be changed according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='ANONYMOUS';
```

Remediation:

```
SQL> ALTER USER ANONYMOUS IDENTIFIED BY newpassword;
```

2.1.12 Rejected - Change the default password for `XS$NULL` (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `XS$NULL` represents the "absent user" that might occur in a session and can only be accessed by the database instance.

Rationale:

As the default `XS$NULL` account created by Oracle has a well-known password and can be potentially corrupted to cause a Denial-of-Service incident, this value should be changed according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='XS$NULL';
```

Remediation:

```
SQL> ALTER USER XS$NULL IDENTIFIED BY newpassword;
```

2.1.13 Change the default password for ORDPLUGINS (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `ORDPLUGINS` provide the plugins to enable the database to store, manage, and retrieve audio/video images, such as the DICOM medical data format.

Rationale:

As the default `ORDPLUGINS` account created by Oracle has a well-known password and can be potentially corrupted to allow the installation of malware disguised and AV plugins, this value should be reset according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='ORDPLUGINS';
```

Remediation:

```
SQL> ALTER USER ORDPLUGINS IDENTIFIED BY newpassword;
```

2.1.14 Change the default password for MDSYS (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `MDSYS` is the user in that operationalizes the Oracle Multimedia Locator, which serves as part of the storage, management, and retrieval of audio/video images, when the Oracle Spatial is not installed. (While Oracle Multimedia is installed with versions of 11g, Oracle "Spatial" is not installed on 11gR(1-2) unless the Enterprise version is loaded on the host.)

Rationale:

As the default `MDSYS` account created by Oracle has a well-known password and can be potentially corrupted to allow the installation of malware disguised and AV plugins, this value should be reset according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='MDSYS';
```

Remediation:

```
SQL> ALTER USER MDSYS IDENTIFIED BY newpassword;
```

2.1.15 Change the default password for ORDDATA (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `ORDDATA` user operationalizes/owns the Oracle Multimedia DICOM modality: Digital Imaging and Communications in Medicine (DICOM), which is the industry standard for medical imaging, enables the Database to store, manage, and manipulate all DICOM format medical content.

Rationale:

As the default `ORDDATA` account created by Oracle has a well-known password and can be potentially corrupted to allow the installation of malware disguised as AV plugins, or cause a Denial-of-Service condition by deleting the account, this value should be reset according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='MDSYS';
```

Remediation:

```
SQL> ALTER USER MDSYS IDENTIFIED BY newpassword;
```

2.1.16 Change the default password for ORDSYS (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `ORDSYS` user functions as the Oracle Multimedia administrator. DICOM modality: Digital Imaging and Communications in Medicine (DICOM), which is the industry standard for medical imaging, enables the Database to store, manage, and manipulate all DICOM format medical content.

Rationale:

As the default `ORDDATA` account created by Oracle has a well-known password and can be potentially corrupted to allow the installation of malware disguised as AV plugins, or cause a Denial-of-Service condition by deleting the account, this value should be reset according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='MDSYS';
```

Remediation:

```
SQL> ALTER USER MDSYS IDENTIFIED BY newpassword;
```

2.1.17 Change the default for `SI_INFORMTN_SCHEMA` (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `SI_INFORMTN_SCHEMA` functions as the location for storing plugins supplied by Oracle and all other third-party plugins.

Rationale:

As the default `SI_INFORMTN_SCHEMA` account created by Oracle has a well-known password and can be potentially corrupted to allow the installation of malware disguised as third-party multimedia plugins, this value should be reset according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='SI_INFORMTN_SCHEMA';
```

Remediation:

```
SQL> ALTER USER SI_INFORMTN_SCHEMA IDENTIFIED BY newpassword;
```

2.1.18 Change the default password for `OLAPSYS` (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `OLAPSYS` account owns the online analytical processing (OLAP) catalog. OLAP applications are developed/operate to use business intelligence and data warehousing systems and OLAP is optimized for this type of application.

Rationale:

As the default `OLAPSYS` account created by Oracle has a well-known password and can be potentially corrupted to allow the installation of malware disguised as a business process, this value should be reset according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='OLAPSYS';
```

Remediation:

```
SQL> ALTER USER OLAPSYS IDENTIFIED BY newpassword;
```

2.1.19 Change the default password for MDDATA (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `MDDATA` account owns the schema used by Oracle Spatial for storing Geocoder and router data, which allows the plotting of datapoints, such as market locations/types, against latitude and longitude on a map, in a way similar to a GPS presentation.

Rationale:

As the default `MDDATA` account created by Oracle has a well-known password and can be potentially corrupted to allow the installation of malware disguised as a business process, this value should be reset according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='MDDATA';
```

Remediation:

```
SQL> ALTER USER MDDATA IDENTIFIED BY newpassword;
```


2.1.20 Change the default password of SPATIAL_WFS_ADMIN_USR (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `SPATIAL_WFS_ADMIN_USR` account owns the Web Feature Service (WFS) capabilities, which are used by Oracle to load feature instance/metadata from the DB into the main memory when these are pulled from a cache.

Rationale:

As the default `SPATIAL_WFS_ADMIN_USR` account created by Oracle has a well-known password and can be potentially corrupted to allow the installation of malware disguised as a business process, this value should be reset according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='SPATIAL_WFS_ADMIN_USR';
```

Remediation:

```
SQL> ALTER USER SPATIAL_WFS_ADMIN_USR IDENTIFIED BY newpassword;
```

2.1.21 Change the default password of SPATIAL_CSW_ADMIN_USR (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `SPATIAL_CSW_ADMIN_USR` account owns the Catalog Services for the Web (CSW) capabilities, which are used by Oracle to load record-type metadata and instances from the DB into the main memory when these records are cached.

Rationale:

As the default `SPATIAL_CSW_ADMIN_USR` account created by Oracle has a well-known password and can be potentially corrupted to allow the installation of malware disguised as a business process, this value should be reset according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='SPATIAL_CSW_ADMIN_USR';
```

Remediation:

```
SQL> ALTER USER SPATIAL_CSW_ADMIN_USR IDENTIFIED BY newpassword;
```

2.1.22 Change the default password of SYSMAN (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `SYSMAN` account handles Oracle Enterprise Manager (OEM) database administrative tasks, which can create and modify other EM admin accounts as well as admin the database instance itself.

Rationale:

As the default `SYSMAN` account created by Oracle has a well-known password and can be potentially used to take over the database instance, this value should be reset according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='SYSMAN';
```

Remediation:

```
SQL> ALTER USER SYSMAN IDENTIFIED BY newpassword;
```

2.1.23 Change the default password of MGMT_VIEW (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `MGMT_VIEW` account handles Oracle Enterprise Manager (OEM) database administrative tasks, which can create and modify other EM admin accounts as well as admin the database instance itself.

Rationale:

As the default `MGMT_VIEW` account created by Oracle has a well-known password and can be potentially used to take over the database instance, this value should be reset according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='MGMT_VIEW';
```

Remediation:

```
SQL> ALTER USER MGMT_VIEW IDENTIFIED BY newpassword;
```

2.1.24 Change the default password of OWBSYS (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `OWBSYS` account handles Oracle Warehouse Builder database administrative tasks, which is created during installation and defines the language of repository for the Warehouse Builder workspaces and user analysis/query operations.

Rationale:

As the default `OWBSYS` account created by Oracle has a well-known password and can be potentially used to take over the database warehouse structures or access user queries, this value should be reset according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='OWBSYS';
```

Remediation:

```
SQL> ALTER USER OWBSYS IDENTIFIED BY newpassword;
```

2.1.25 Change the default password of OWBSYS_AUDIT (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `OWBSYS_AUDIT` account handles access to the OWBSYS audit/logging tables, which record Warehouse Builder workspace and user analysis/query operations.

Rationale:

As the default `OWBSYS_UDIT` account created by Oracle has a well-known password and can be potentially used to take alter the audit/logging tables to alter/delete forensic data that can reveal unauthorized access/alteration of data, this value should be reset according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='OWBSYS_AUDIT';
```

Remediation:

```
SQL> ALTER USER OWBSYS_AUDIT IDENTIFIED BY newpassword;
```

2.1.26 Change the default password of DBSNMP (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `DBSNMP` account handles database information carried across the network (Simple Network Management Protocol or SNMP), which informs the Oracle Enterprise Manager of the instance constituents/operational status of the database it is connected to.

Rationale:

As the default `DBSNMP` account created by Oracle has a well-known password and can be potentially used to take tap into the data stream on database operations and alter/shut down the instance, this value should be reset according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='DBSNMP';
```

Remediation:

```
SQL> ALTER USER DBSNMP IDENTIFIED BY newpassword;
```

2.1.27 Rejected - Change the default password of WK_TEST (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `WK_TEST` is the account that handles access to the Oracle Ultra Search instance (`WK_INST`) and schema.

Rationale:

As the default `WK_TEST` account created by Oracle has a well-known password and can be potentially used to discover information about the instance, this value should be reset according to the needs of the organization.

Audit:

```
SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='WK_TEST';
```

Remediation:

```
ALTER USER WK_TEST IDENTIFIED BY newpassword;
```

2.1.28 Change the default password of WK_TEST (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `WK_TEST` account handles access to the OWBSYS audit/logging tables, which record Warehouse Builder workspace and user analysis/query operations.

Rationale:

As the default `OWBSYS_UDIT` account created by Oracle has a well-known password and can be potentially used to take alter the tables or alter/delete forensic data, this value should be reset according to the needs of the organization.

Audit:

```
SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='OWBSYS_AUDIT';
```

Remediation:

```
ALTER USER OWBSYS_AUDIT IDENTIFIED BY newpassword;
```

2.1.29 Change the default password for FLOWS_030100 (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `FLOWS_030100` account owns the greatest part of the objects created by the database during the installation of Oracle Database Application Express (ODAE).

Rationale:

As the default `FLOWS_030100` account created by Oracle has a well-known password and can provide a point for database access/control by unauthorized users, opening up the tables, views, etc. created during the ODAE creation process, this value should be changed according to the needs of the organization.

Audit:

```
SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='FLOWS_030100';
```

Remediation:

```
ALTER USER FLOWS_030100 IDENTIFIED BY newpassword;
```

2.1.30 Change the default password for FLOWS_FILES (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `FLOWS_FILES` account owns the greatest part of the objects created by the database during the installation of Oracle Database Application Express (ODAE) specific to `modsql` document conveyance.

Rationale:

As the default `FLOWS_FILES` account created by Oracle has a well-known password and can provide a point for database access/control by unauthorized users, opening up the tables,

views, etc. created during the ODAE creation process, this value should be changed according to the needs of the organization.

Audit:

```
SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='FLOWS_FILES';
```

Remediation:

```
ALTER USER FLOWS_FILES IDENTIFIED BY newpassword;
```

2.1.31 Change the default password for FLOWS_030000 (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `FLOWS_300000` account owns the greatest part of the objects created by the database during the installation of Oracle Database Application Express (ODAE).

Rationale:

As the default `FLOWS_030000` account created by Oracle has a well-known password and can provide a point for database access/control by unauthorized users, opening up the tables, views, etc. created during the ODAE creation process, this value should be changed according to the needs of the organization.

Audit:

```
SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='FLOWS_030000';
```

Remediation:

```
ALTER USER FLOWS_030000 IDENTIFIED BY newpassword;
```

2.1.32 Change the default password for APEX_030200 (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `APEX_030200` account owns the greatest part of the objects created by the database during the installation of Oracle Database Application Express (ODAE).

Rationale:

As the default `APEX_030200` account created by Oracle has a well-known password and can provide a point for database access/control by unauthorized users, opening up the tables, views, etc. created during the ODAE creation process, this value should be changed according to the needs of the organization.

Audit:

```
SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='APEX_030200';
```

Remediation:

```
ALTER USER APEX_030200 IDENTIFIED BY newpassword;
```

2.1.33 Change the default password for APEX_040000 (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `APEX_040000` account owns the greatest part of the objects created by the database during the installation of Oracle Database Application Express (ODAE).

Rationale:

As the default `APEX_040000` account created by Oracle has a well-known password and can provide a point for database access/control by unauthorized users, opening up the tables, views, etc. created during the ODAE creation process, this value should be changed according to the needs of the organization.

Audit:

```
SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='APEX_040000';
```

Remediation:

```
ALTER USER APEX_040000 IDENTIFIED BY newpassword;
```


2.1.34 Change the default password for APEX_040100 (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The APEX_040100 account owns the greatest part of the objects created by the database during the installation of Oracle Database Application Express (ODAE).

Rationale:

As the default APEX_040100 account created by Oracle has a well-known password and can provide a point for database access/control by unauthorized users, opening up the tables, views, etc. created during the ODAE creation process, this value should be changed according to the needs of the organization.

Audit:

```
SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='APEX_040100';
```

Remediation:

```
ALTER USER APEX_040100 IDENTIFIED BY newpassword;
```

2.1.35 Change the default password for APEX_040200 (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The APEX_040200 account owns the greatest part of the objects created by the database during the installation of Oracle Database Application Express (ODAE).

Rationale:

As the default APEX_040200 account created by Oracle has a well-known password and can provide a point for database access/control by unauthorized users, opening up the tables, views, etc. created during the ODAE creation process, this value should be changed according to the needs of the organization.

Audit:

```
SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='APEX_040200';
```

Remediation:

```
ALTER USER APEX_040200 IDENTIFIED BY newpassword;
```

2.1.36 Change the default password for LBACSYS (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The LBACSYS account administers the Oracle Label Security (OLS) feature.

Rationale:

As the default LBACSYS account created by Oracle has a well-known password and can provide a point for database access/control by unauthorized users, opening up the tables, views, etc. This value should be changed according to the needs of the organization.

Audit:

```
SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='LBACSYS';
```

Remediation:

```
ALTER USER LBACSYS IDENTIFIED BY newpassword;
```

2.1.37 Change the default password of WKPROXY (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The WKPROXY account handles the Oracle 9i Application Ultra Search.

Rationale:

As the default WKPROXY account created by Oracle has a well-known password and can be potentially used to take alter the tables or alter/delete forensic data, this value should be reset according to the needs of the organization.

Audit:

```
SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='WKPROXY';
```

Remediation:

```
ALTER USER WKPROXY IDENTIFIED BY newpassword;
```

2.1.38 Change the default password for WKSYS (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `WKSYS` account is the Ultra Search administrator.

Rationale:

As the default `WKSYS` account created by Oracle has a well-known password and can provide a point for database access by unauthorized users if left at the default setting, this value should be changed according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='WKSYS';
```

Remediation:

```
SQL> ALTER USER WKSYS IDENTIFIED BY newpassword;
```

2.1.39 Change the default password for APEX_PUBLIC_USER (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `APEX_PUBLIC_USER` account is the connect user for Oracle APEX.

Rationale:

As the default APEX_PUBLIC_USER account created by Oracle has a well-known password and can provide a point for database access by unauthorized users if left at the default setting, this value should be changed according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='APEX_PUBLIC_USER';
```

Remediation:

```
SQL> ALTER USER APEX_PUBLIC_USER IDENTIFIED BY newpassword;
```

2.2 Remove Oracle Sample Users

Remove Oracle sample users

2.2.1 Remove the sample user 'SCOTT' (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The SCOTT account is used in examples throughout the Oracle database and is loaded along with the 11gR2 software.

Rationale:

As the default SCOTT account created by Oracle has a well-known password and can be potentially used to alter the database or to launch exploits against Production to gain unauthorized access to user data, this value should be reset according to the needs of the organization.

Audit:

```
SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='SCOTT';
```

Remediation:

```
ALTER USER SCOTT IDENTIFIED BY newpassword;
```

2.2.2 Change the default password of SH (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The SH account is used to manage the SH sales schema, which stores business data and is loaded along with the 11gR2 software.

Rationale:

As the default SH account created by Oracle has a well-known password and can be potentially used to alter the database to launch exploits against Production to gain unauthorized access to user data, this value should be reset according to the needs of the organization.

Audit:

```
SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='SH';
```

Remediation:

```
ALTER USER SH IDENTIFIED BY newpassword;
```

2.2.3 Change the default password of IX (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The PM account is used to manage the Information Exchange (IX) sample schema for Business-to-Business shipping applications which is loaded along with the 11gR2 software.

Rationale:

As the default PM account created by Oracle has a well-known password and can be potentially used to alter the database to launch exploits against Production to gain unauthorized access to user data, this value should be reset according to the needs of the organization.

Audit:

```
SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='PM';
```

Remediation:

```
ALTER USER PM IDENTIFIED BY newpassword;
```

2.2.4 Change the default password of BI (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `BI` account owns the Business Intelligence sample schema which is loaded along with the 11gR2 software.

Rationale:

As the default `BI` account created by Oracle has a well-known password and can be potentially used to alter the database to launch exploits against Production to gain unauthorized access to user data, this value should be reset according to the needs of the organization.

Audit:

```
SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='BI';
```

Remediation:

```
ALTER USER BI IDENTIFIED BY newpassword;
```

2.2.5 Change the default password of PM (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `PM` account is used to manage the Product Media (PM) sample schema which is loaded along with the 11gR2 software.

Rationale:

As the default `PM` account created by Oracle has a well-known password and can be potentially used to alter the database to launch exploits against Production to gain unauthorized access to user data, this value should be reset according to the needs of the organization.

Audit:

```
SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='PM';
```

Remediation:

```
ALTER USER PM IDENTIFIED BY newpassword;
```

2.2.6 Change the default password of HR (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `HR` account is used to manage the HR sample schema which is loaded along with the 11gR2 software.

Rationale:

As the default `HR` account created by Oracle has a well-known password and can be potentially used to alter the database to launch exploits against Production to gain unauthorized access to user data, this value should be reset according to the needs of the organization.

Audit:

```
SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='BI';
```

Remediation:

```
ALTER USER BI IDENTIFIED BY newpassword;
```

2.2.7 Change the default password of OE (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `OE` account is used to manage the Order Entry (OE) sample schema which is loaded along with the 11gR2 software.

Rationale:

As the default `OE` account created by Oracle has a well-known password and can be potentially used to alter the database to launch exploits against Production to gain unauthorized access to user data, this value should be reset according to the needs of the organization.

Audit:

```
SELECT * FROM DBA_USERS_WITH_DEFPWD WHERE USERNAME='OE';
```

Remediation:

```
ALTER USER OE IDENTIFIED BY newpassword;
```

2.3 Rejected - Ensure installation limits access to \$TEMP in Oracle (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

During the Oracle installation, the database can potentially create temporary files or settings with PUBLIC privileges.

Rationale:

As these temporary files or settings with PUBLIC privileges can potentially be altered and/or subverted by any connected user, limitations on connections other than those required during setup for the installation should be established according to the needs of the organization.

Audit:

```
$ echo $ORACLE_TEMP
```

Remediation:

(The variable `$ORACLE_TEMP` was created for test consistency.)

```
$ ORACLE_TEMP=pathname
$ export ORACLE_TEMP
$ chmod 750 $ORACLE_TEMP
$ ls -ald $ORACLE_TEMP | awk '{print $1,$3,$4,$9}'
$ drwxr-x--- orauser oragroup (path for /oracle/tmp)
```


2.4 Ensure the latest version/patches for Oracle software is installed (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle installation version, along with the patch level, should be the most recent that is compatible with the organizations' operational needs.

Rationale:

As using the most recent Oracle database software, along with all applicable patches can help limit the possibilities for vulnerabilities in the software, the installation version and/or patches applied during setup should be established according to the needs of the organization.

Audit:

```
# opatch lsinventory -detail
```

Remediation:

```
Check the results of opatch against the current list of Oracle patches on metalink
```

2.5 Rejected - Ensure that the tkprof tool is removed or restricted (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `TKPROF` program allows conversion of the trace files into a human-readable text, to allow diagnostics of database problem areas.

Rationale:

As retaining TKPROF on a Production system could allow an unauthorized user to discover database weaknesses, it should be removed or restricted according to the needs of the organization.

Audit:

```
# find $ORACLE_HOME -name tkprof
# (path for tkprof)
```

Remediation:

```
# cd (path for tkprof)
# rm tkprof
OR
# chmod 700 tkprof
# ls -ald tkprof | awk '{print $1,$3,$4,$9}'
# drwxr-x--- oracle oracle tkprof
```

2.6 Rejected - Ensure the Oracle listener default name is changed (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle `listener` provides network connections to the database with the name of the connection, protocol addresses, and services offered by the database.

Rationale:

As the default name of the listener is well known and could facilitate network-based Denial-of-Service attacks against its bandwidth capabilities, it should be renamed according to the needs of the organization.

Audit:

```
$ grep "default = listener"
$ ORACLE_HOME/network/admin/listener.ora
```

Remediation:

```
$ if [ "`grep '^LISTENER = listener' $ORACLE_HOME/network/admin/listener.ora`" ]; then
awk '/^LISTENER/ { $3 = "" } {print}' $ORACLE_HOME/network/admin/listener.ora >
$ORACLE_HOME/network/admin/listener.ora.new; mv
$ORACLE_HOME/network/admin/listener.ora.new $ORACLE_HOME/network/admin/listener.ora;
fi
```

2.7 Rejected - Ensure the Oracle listener file uses IPs instead of hostnames (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5
- Level 2 - 11.2 on Oracle Linux 5

Description:

The Oracle `listener` provides network connections to the database with the name of the connection, protocol addresses, and services offered by the database. The `listener.ora` file can contain connection information based on host names or IP addresses.

Rationale:

As using host names in `listener.ora` file could allow DNS server cache-poisoning to facilitate a network-based Denial-of-Service attacks on the system, the requisite hostnames should be listed as IP addresses, according to the needs of the organization.

Audit:

```
$ grep "HOST = " $ORACLE_HOME/network/admin/listener.ora | awk '{print $6,$7}'
```

Remediation:

```
Use vi or another editor to change the hostnames in the listener.ora file to IP addresses
```

2.8 Rejected - Ensure the Oracle `otrace *.dat` files are removed (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle "Trace" (`otrace`) utility provides a way to trace SQL statement executions, as well as data on the duration, frequency, and resources the database uses for all parse, execution, and fetch events

Rationale:

As the `*.dat` files generated by the `otrace` utility contain sensitive information that could facilitate attacks on the system, these files should be removed according to the needs of the organization.

Audit:

```
# cd ORACLE_HOME/otrace/admin
# ls -alt *.dat
```

Remediation:

```
# cd $ORACLE_HOME/otrace/admin
# rm -f process.dat regid.dat
```

2.9 Rejected - Ensure third-party accounts put on Oracle get new passwords (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5
- Level 2 - 11.2 on Oracle Linux 5

Description:

Various third-party programs create well-known default `DBA_USER` accounts on the Oracle database during their installation, which leaves them open to exploitation of the account privileges by unauthorized users.

Rationale:

As the default accounts created on Oracle by third-party software often have well-known passwords and can provide a point for access by unauthorized users if the passwords are unchanged, all the accounts remaining after unnecessary ones have been deleted or locked should have the default passwords changed according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_USERS_WITH_DEFPWD; SELECT USERNAME, ACCOUNT_STATUS FROM DBA_USERS;
```

Remediation:

```
SQL> ALTER USER <username> IDENTIFIED BY <password>; or
ALTER USER <username> ACCOUNT LOCK PASSWORD EXPIRE;
```

2.10 Rejected - Change the Oracle default service identifier (sid) (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle installation creates a default site identifier value (`orcl`).

Rationale:

As the default ports created by Oracle can provide a target for exploits by unauthorized users, the ports should be changed according to the needs of the organization.

Audit:

```
$grep -i "^orcl" /etc/oratab  
$ orcl:/home/oracle/app/oracle/product/11.2.0/dbhome_2:Y
```

Remediation:

```
Change the Oracle 11gR2 sid:  
  
1.      First, make certain to have a complete cold backup.  
Then ALTER DATABASE BACKUP CONTROLFILE TO TRACE AS  
'/home/oracle/something/create_ctl.sql';  
  
2.  Extract the "create controlfile" command from the  
    background-dump-destination tracefile.  
  
3.  Shutdown the DB cleanly: shutdown immediate.  
  
4.  Change the DB Name in your init<SID>.ora to the new SID  
    value in init<NEWSID>.ora .  
  
5.  Change the SID in /etc/oratab or /var/opt/oracle/oratab  
  
6.  Change the SID in your environment and source it.  
  
7.  Startup the database to mount-status: startup mount  
  
8.  Re-Create the control file with the statement from number 2  
  
9.  Do an: alter database rename global_name to <SID> .  
  
10. Change the listener and network configurations accordingly:  
    $ORACLE_HOME/network/admin/*.ora files
```

2.11 Change/lock the default Oracle software owner account (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle installation requires a software account owner, which is named `oracle` by default.

Rationale:

As the use of the name "oracle" for the software account owner is well known and provides a target for exploits by unauthorized users, the name of this account should be chosen according to the needs of the organization, *preferably* before first installation.

Audit:

```
$grep -i "^orcl" /etc/oratab  
$ orcl:/home/oracle/app/oracle/product/11.2.0/dbhome_2:Y
```

Remediation:

```
# useradd -g oinstall -G dba[,oper] -d /newhome/newdir \ -s /shell/path newname
```

3 Oracle Directory and File Permissions

The role of access control through file ownership and permissions is self-evident--the major difficulty with Oracle is determining which files it is critical to control OS-based access to. In the below, the names "**orauser**" and "**oragroup**" will substitute for whatever the organization has chosen for the primary Oracle user/group names. The primary criterion for compliance in this regard is that the instance has had the user/group names changed from the default values given by Oracle.

3.1 Rejected - Verify/set permissions for any files listed as an ifile target

The IFILE setting is used to embed another parameter, to specify an alternate file target for a prior location, within the listener.ora, init.ora, or tnsnames.ora file(s).

3.1.1 Verify/set permissions for any ifile targets in listener.ora (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

Rationale:

As lax permissions on any target file(s) listed as IFILE=* could allow unauthorized users to overwrite the file(s) listed as IFILES and through launch exploits, access to these should be restricted according to the needs of the organization.

Audit:

```
$ cat $ORACLE_HOME/network/admin/listener.ora | grep -i ^IFILE
```

Remediation:

```
$ chown IFILE target(s)
$ chmod 750 IFILE target(s)
```

3.1.2 Verify/set permissions for any ifile targets in init.ora (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

Rationale:

As lax permissions on any target file(s) listed as IFILE=* could allow unauthorized users to overwrite the file(s) listed as IFILES and through launch exploits, access to these should be restricted according to the needs of the organization.

Audit:

```
$ cat $ORACLE_HOME/dbs/init.ora | grep -i ^IFILE
```

Remediation:

```
$ chown IFILE target(s)
$ chmod 750 IFILE target(s)
```

3.1.3 Verify/set permissions for any ifile targets in tnsnames.ora (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

Rationale:

As lax permissions on any target file(s) listed as IFILE=* could allow unauthorized users to overwrite the file(s) listed as IFILES and through launch exploits, access to these should be restricted according to the needs of the organization.

Audit:

```
$ cat $ORACLE_HOME/network/admin/tnsnames.ora | grep -i ^IFILE
```

Remediation:

```
$ chown orauser IFILE target(s)
$ chmod orauser.oragrpoup IFILE target(s)
```

3.2 Verify/set ownership of the \$ORACLE_HOME/bin directory (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `$ORACLE_HOME/bin` directory contains all the primary system binaries.

Rationale:

As lax permissions on this directory could allow unauthorized users to alter/substitute the directory contents to launch exploits, access should be restricted according to the needs of the organization.

Audit:

```
$ ls -ald $ORACLE_HOME/bin
$ drwxr-xr-x 2 orauser oragrp 12288 $ORACLE_HOME /bin
```

Remediation:

```
$ chown orauser $ORACLE_HOME/bin
$ chgrp oragrp $ORACLE_HOME/bin
$ chmod 755 $ORACLE_HOME/bin/*
```

3.3 Verify/set the umask for the oracle user .profile file (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `umask` setting can be in a number of places, such as the users' "`*.rc`" shells, to set the default permissions for all files created by that user or in `/etc/profile`, to provide a basic `umask` for all users.

Rationale:

As lax `umask` settings could allow access to unauthorized users who could alter/substitute the contents of any with the wrong permissions file to launch exploits, this value should be set according to the needs of the organization.

Audit:

```
$ cat /etc/profile | grep umask
```

```
$ umask 022
```

Remediation:

```
$ sed -e 's/umask 022/umask 027/' </etc/profile> /etc/profile.new mv /etc/profile.new /etc/profile
```

OR

If the above Audit script produced no output use:

```
$ echo umask 027 >> /etc/profile
```

If using `sed` is discouraged, the `vi` text editor can add the "`umask 027`" value to the `/etc/profile` or the `/etc/skel/.bashrc`

3.4 Verify/set permissions for the `init.ora` file (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `init.ora` file contains all the primary system startup (`init`) settings. This file is stored in the `$ORACLE_HOME/dbs` directory and can have between 200-300 instance startup parameters.

Rationale:

As lax permissions on this file could allow unauthorized users to alter/substitute the contents of the file to launch exploits, access should be restricted according to the needs of the organization.

Audit:

```
$ ls -ald $ORACLE_HOME/dbs/init.ora
$ -rw-r--r-- 1 orauser oragrp (truncated)
```

Remediation:

```
$ chown orauser $ORACLE_HOME/dbs/init.ora
$ chgrp oragrp $ORACLE_HOME/dbs/init.ora
$ chmod 644 $ORACLE_HOME/dbs/init.ora
```

3.5 Verify/set permissions for the `spfileorcl.ora` file (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5
- Level 2 - 11.2 on Oracle Linux 5

Description:

When creating an Oracle database via the Database Configuration Assistant, a "Server Parameter File" (SPFILE) is created from the "Initialization Parameter File," then the initialization parameter file is renamed. Oracle will not recognize the former initialization file on future DB startups, nor is it used after the instance is started. This new SPFILE is located in the `$ORACLE_HOME/dbs` directory by default. The new SPFILE filename is `spfileorcl.ora`, which contains all the Oracle Database configurations for the Automatic Storage Management (ASM) instance in a separate server parameter file (SPFILE).

Rationale:

As lax permissions on this file could allow unauthorized users to overwrite the file to launch exploits, access should be restricted according to the needs of the organization.

Audit:

```
$ ls -ald $ORACLE_HOME/dbs/spfileorcl.ora
$ -rw-r--r-- 1 orauser oragrp (truncated)
```

Remediation:

```
$ chown orauser $ORACLE_HOME/dbs/spfileorcl.ora
$ chgrp oragrp $ORACLE_HOME/dbs/spfileorcl.ora
$ chmod 640 $ORACLE_HOME/dbs/spfileorcl.ora
```

3.6 Verify/set permissions for the database datafiles (*.dbs) (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The ORACLE_HOME/dbs directory contains configuration files, such as the "/u01/oracle/prod/rbs01.dbs," "/u01/oracle/prod/users01.dbs," and "/u01/oracle/prod/temp01.dbs," which hold sensitive user information.

Rationale:

As lax permissions on this directory could allow unauthorized users to overwrite the files to launch exploits, access should be restricted according to the needs of the organization.

Audit:

```
$ ls -ald $ORACLE_HOME/dbs
$ drwxr-xr-x 2 oracle oracle
```

Remediation:

```
$ chmod 750 $ORACLE_HOME/dbs
$ chown orauser $ORACLE_HOME/dbs/*
$ chgrp oragroup $ORACLE_HOME/dbs/*
```

3.7 Verify/set permissions for the audit_file_dest file target (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `audit_file_dest` log file in `init.ora` target specifies the location where the DB instance's audit dump files are kept, which is set to `$ORACLE_BASE/admin/orcl/adump` by default. It is also the location where the `audit_sys_operations`, records for the full auditing of SYS, are written.

Rationale:

As lax permissions on `audit_file_dest` file target could allow unauthorized users to overwrite the file(s) and launch exploits to corrupt the log files, access to the log file should be restricted according to the needs of the organization.

Audit:

```
$ ls -ald $ORACLE_BASE/admin/orcl/adump
$ drwxr-x--- 2 orauser oragrp (output truncated)
```

Remediation:

```
$ chmod 750 $ORACLE_BASE/admin/orcl/adump
```

3.8 Verify/set permissions for the `diagnostic_dest` file target (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `diagnostic_dest` directory parameter identifies the location of the Automatic Diagnostic Repository (ADR), which contains data such as the alert log, dumps, [db health] monitor reports, and traces and is set to the `$ORACLE_BASE` directory by default. In Oracle 11gR2 the Diagnostic Destination replaces the initialization parameter settings for background dump, user dump, and core dump destinations.

Rationale:

As lax permissions on `diagnostic_dest` directory target could allow unauthorized users to overwrite the file(s) and launch exploits to corrupt the log files, access to the log file should be restricted according to the needs of the organization.

Audit:

```
$ ls -ald $ORACLE_BASE
$ drwxr-xr-x 9 orauser oragrp (output truncated)
```

Remediation:

```
$ chmod 750 $ORACLE_BASE
```

3.9 Verify/set permissions for the control_files file target (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The database `control_files` parameter sets the "physical" structure of the database in the way a complex building's creation is specified by engineering drawings. The `*.ctl` file's contents are absolutely essential to the DB's operation and may contain, but are not limited to the following:

- Archive log mode setting,
- Archive log history,
- DB information (RESETLOGS SCN and their time stamp),
- DB name,
- Redo log threads, and
- Tablespace/datafile records-- checkpoints, filenames, on/offline, etc.

Rationale:

As lax permissions on the `control_files` file targets could allow unauthorized users to overwrite the file(s) and launch exploits to corrupt/destroy the database, access to the control files should be restricted according to the needs of the organization.

Audit:

```
SQL: SELECT NAME FROM V$CONTROLFILE;
(Then check the resulting file paths from the SQL CLI)
$ ls -al /control/file/path/name(s)
```

Remediation:

```
$ chown orauser /control/file/name(s)
$ chgrp oragrp /control/file/name(s)
$ chmod 750 /control/file/name(s)
```

3.10 Verify/set permissions for the log_archive_dest_n file targets (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `log_archive_dest_n` initialization parameter provides from 1-10 destinations that specify where each of the `LOCATION` or the `SERVICE` attributes are given that point to where redo data will be archived. If the Enterprise Edition is being used and the new `log_archive_dest_n` has not been applied, the deprecated form that uses the `log_archive_dest` is still valid.

Rationale:

As lax permissions on the `log_archive_dest(_n)` file targets could allow unauthorized users to overwrite the file(s) and launch exploits to corrupt/destroy the database, access to the control files should be restricted according to the needs of the organization.

Audit:

```
$ grep -i log_archive_dest $ORACLE_HOME/dbs/init.ora  
  
OR  
  
SQL> SHOW PARAMETER log_archive_dest;  
(Then check the resulting file paths from the OS/SQL CLI)  
  
$ ls -al $ORACLE_HOME/dbs/log_archive_dest pathname(s)  
$ The default is "" or NULL.
```

Remediation:

```
After using vi or SQL to set the paths, change the ownership/permissions as follows:  
  
$ chmod 750 $ORACLE_HOME/dbs/log_archive_dest pathname(s)  
$ chown orauser.oragrp $ORACLE_HOME/dbs/log_archive_dest pathname(s)
```

3.11 Verify/set permissions on the `$ORACLE_HOME/network/admin/` directory files (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `$ORACLE_HOME/network/admin` directory holds all the files that are restricted to the `dba` group.

Rationale:

As lax permissions on the `$ORACLE_HOME/network/admin` directory files could allow unauthorized users to overwrite these file(s) and launch exploits to corrupt/destroy the database, directory access should be restricted according to the needs of the organization.

Audit:

```
$ ls -ald $ORACLE_HOME/network/admin/*
```

Remediation:

```
$ chmod 644 $ORACLE_HOME/network/admin/*
$ chown orauser.oragrp $ORACLE_HOME/network/admin/*
```

3.12 Rejected - Verify/set permissions on the sqlnet.ora file (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `sqlnet.ora` file contains the parameters for communication between the networked user and the server containing the database instance.

Rationale:

As lax permissions on the `sqlnet.ora` file could allow unauthorized users to overwrite the file(s) and launch exploits to corrupt/destroy the database, file access should be restricted according to the needs of the organization.

Audit:

```
$ ls -al $ORACLE_HOME/network/admin/sqlnet.ora
```

Remediation:

```
$ chmod 644 $ORACLE_HOME/network/admin/sqlnet.ora
$ chown orauser.oragrp \
  $ORACLE_HOME/network/admin/sqlnet.ora
```

3.13 Verify/set permissions on the log_directory_client= target (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `sqlnet.ora` file contains many database and system parameters, including the `log_directory_client= (directory target)` as the destination directory for the client's log files.

Rationale:

As lax permissions on the `log_directory_client=(dirpath)` could allow unauthorized users to overwrite the client log file(s) and corrupt/obscure any forensic evidence within it, access to this file target access should be restricted according to the needs of the organization.

Audit:

```
$ grep log_directory_client \
  $ORACLE_HOME/network/admin/sqlnet.ora
$ log_directory_client=dirpath
```

Remediation:

```
$ chmod 640 dirpath
$ chown orauser.oragrp log_directory_client dirpath
```

3.14 Verify/set permissions on the `log_directory_server= target` (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `sqlnet.ora` file contains many database and system parameters, including the `log_directory_server=(directory target)` to specify the database server's trace file destination directory.

Rationale:

As lax permissions on the `log_directory_server=(directory target)` could allow unauthorized users to overwrite the database server's log file(s) and corrupt/obscure any forensic evidence within it, access to this file target should be restricted according to the needs of the organization.

Audit:

```
$ grep log_directory_server \ $ORACLE_HOME/network/admin/sqlnet.ora
$ log_directory_server=dirpath
```

Remediation:


```
$ chmod 640 dirpath
$ chown orauser.oragrpoup log_directory_server dirpath
```

3.15 Verify/set permissions on the trace_directory_client target (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `sqlnet.ora` file contains many database and system parameters, including the `trace_directory_client=(directory target)` as the client's destination directory for the trace log files.

Rationale:

As lax permissions on the `trace_directory_client=(directory target)` could allow unauthorized users to overwrite the client trace file(s) and corrupt/obscure any forensic evidence within it, access to this target should be restricted according to the needs of the organization.

Audit:

```
$ grep log_directory_client \
  $ORACLE_HOME/network/admin/sqlnet.ora
$ trace_directory_client=dirpath
```

Remediation:

```
$ chmod 640 dirpath
$ chown orauser.oragrp trace_directory_client dirpath
```

3.16 Verify/set permissions on the trace_directory_server target (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `sqlnet.ora` file contains many database and system parameters, including the `log_directory_server=(directory target)` to specify the database server's trace file destination directory.

Rationale:

As lax permissions on the `log_directory_server=(directory target)` could allow unauthorized users to overwrite the database server's trace file(s) and corrupt/obscure any forensic evidence within it, access to this file target should be restricted according to the needs of the organization.

Audit:

```
$ grep log_directory_server \  
$ORACLE_HOME/network/admin/sqlnet.ora  
$ trace_directory_server=dirpath
```

Remediation:

```
$ chmod 640 dirpath  
$ chown orauser.oragrp trace_directory_server dirpath
```

3.17 Verify/set permissions on the listener.ora file (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `listener.ora` file contains the name of the listener file and the network protocol/address combinations offered by the database services.

Rationale:

As lax permissions on the `listener.ora` file could allow unauthorized users access to obtain, corrupt, or obscure any forensic evidence within it, access to this target should be restricted according to the needs of the organization.

Audit:

```
$ ls -al $ORACLE_HOME/network/admin/listener.ora
```

Remediation:

```
$ chmod 660 $ORACLE_HOME/network/admin/listener.ora  
$ chown orauser.oragrp $ORACLE_HOME/network/admin/listener.ora
```

3.18 Verify/set permissions on the log_file_listener file (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `log_file_listener=( filename)` is the name of the listener log file.

Rationale:

As lax permissions on the `log_file_listener=( file target)` could allow unauthorized users to corrupt/obscure any forensic evidence within it, access to this target should be restricted according to the needs of the organization.

Audit:

```
$ grep log_file_listener \  
$ORACLE_HOME/network/admin/listener.ora  
$ log_file_listener=$ORACLE_HOME/network/log/listener.log  
(This is the default value)
```

Remediation:

```
$ chmod 640 orauser.oragrp log_file_listener filename
```

3.19 Verify/set permissions on the trace_directory_listener_name directory target (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `trace_directory_listener_name=(directory target)` is the location of the directory for listener trace file.

Rationale:

As lax permissions on the

`trace_directory_file_listener_name=(directory target)` could allow unauthorized users to corrupt/obscure any forensic evidence within it, access to this target should be restricted according to the needs of the organization.

Audit:

```
$ grep trace_directory_listener_name \ $ORACLE_HOME/network/admin/listener.ora  
$ TRACE_DIRECTORY_listener=$ORACLE_HOME/network/admin/tracedir
```

Remediation:

```
$ chmod 660 $ORACLE_HOME/network/admin/tracedir  
$ chown orauser.oragrp $ORACLE_HOME/network/admin/tracedir
```

3.20 Verify/set permissions on the trace_file_listener_name file target (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The trace_file_listener_name=(file target) is the location/name of the listener for the trace file.

Rationale:

As lax permissions on the trace_file_listener_name=(file target) could allow unauthorized users to corrupt/obscure any forensic evidence within it, access to this target should be restricted according to the needs of the organization.

Audit:

```
$ grep trace_file_listener_name \  
$ORACLE_HOME/network/admin/listener.ora  
$ $ORACLE_HOME/network/trace/list.trc (default) $ ls -al (resulting file path)
```

Remediation:

```
$ chown orauser.oragrp (resulting file path)  
$ chmod 660 (resulting file path)
```

3.21 Verify/set permissions on the sqlplus binaries directory (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `sqlplus` binaries support the operations of the Oracle command-line utility program SQL and PL/SQL, which can perform any database operation.

Rationale:

As lax permissions on the `sqlplus` binaries directory could allow unauthorized users to launch exploits against the database, access to this target should be restricted according to the needs of the organization.

Audit:

```
$ which -a sqlplus
$ $ORACLE_HOME/bin/sqlplus (default result)
$ ls -ald $ORACLE_HOME/bin/sqlplus
$ -rwxr-x--x 1 orauser oragrp (output truncated)
```

Remediation:

```
$ chown orauser.oragrp $ORACLE_HOME/bin/sqlplus
$ chmod 750 $ORACLE_HOME/bin/sqlplus
```

3.22 Rejected - Verify/set permissions on the `postDBCreation.log` file (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `postDBCreation.log` file contains the printout from the database creation. It also contains a printout of the passwords for the `DBSNMP` and/or `SYSMAN` users if either of those two accounts have a password that contains one or more exclamation points.

Rationale:

As printouts of the passwords for the `DBSNMP` and/or `SYSMAN` users could allow unauthorized users to launch privilege escalation exploits against the database, access to the `postDBCreation.log` should be restricted according to the needs of the organization.

Audit:

```
$ ls -al \ /home/oracle/app/oracle/cfgtoollogs/dbca/orcl/postDBCreation.log $ -rw-r---
-- 1 orauser oragroup (output truncated)
```

Remediation:

```
$ chmod 640 /home/oracle/app/oracle/cfgtoollogs/dbca/orcl/postDBCreation.log
$ chown orauser oragroup \
/home/oracle/app/oracle/cfgtoollogs/dbca/orcl/postDBCreation.log
```

3.23 Rejected - Verify/set the umask for the oracle system in the /etc/skel/.bash_profile file (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5
- Level 2 - 11.2 on Oracle Linux 5

Description:

The umask setting can be in a number of places, such as the users' " *.rc" shells, to set the default permissions for all files created by that user or in /etc/skel/.bash_profile, to provide a basic umask for all users.

Rationale:

As lax umask settings could allow access to unauthorized users who could alter/substitute the contents of any with the wrong permissions file to launch exploits, this value should be set according to the needs of the organization.

Audit:

```
$ cat /etc/skel/.bash_profile | grep umask
$ umask 022
```

Remediation:

```
$ Use a text editor to add the "umask" 027 value in the system /etc/skel/.bash_profile
or the profile in the oracle user's ~/.bashrc ~/.cshrc
```

Or use the following script for /etc/skel/.bash_profile:

```
$ if [ "`grep -i '^umask' /etc/skel/.bash_profile`" ]; then awk '/umask/ { $2 = "027"
} {print}' /etc/skel/.bash_profile > /etc/skel/.bash_profile.new; mv
/etc/skel/.bash_profile.new /etc/skel/.bash_profile; else echo umask 027 >>
/etc/skel/.bash_profile; fi
```

3.24 Permissions settings for the radius.key file (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `radius.key` file in the `ORACLE_BASE\ORACLE_HOME\network\security\directory` contains the shared-secret password (16 characters or less) that is used to participate in the RADIUS client-server authentication, to authenticate remote client connections; this process treats each Oracle server as a Client connecting to the RADIUS server.

Rationale:

As protecting the contents of this file is critical to maintaining the confidentiality of the remote connection process, the file permissions value should be set according to the needs of the organization.

Audit:

```
$ ls -al $ORACLE_HOME/network/security/radius.key
```

Remediation:

```
$ chmod 440 $ORACLE_HOME/network/security/radius.key
```

4 Oracle Parameter Settings

The operation of the Oracle database instance is governed by numerous parameters that are set in specific configuration files and are instance-specific in scope. As alterations of these parameters can cause problems ranging from denial -of-service to theft of proprietary information, these configurations should be carefully considered and maintained.

Note:

For all files that have parameters that can be modified with the OS and/or SQL commands/scripts, these will both be listed where appropriate.

4.1 listener.ora Settings

Settings for the TNS Listener `listener.ora`

4.1.1 Setting for the `inbound_connect_timeout` parameter (Scored)

Profile Applicability:

- Level 2 - 11.2 on Oracle Linux 5

Description:

The `inbound_connect_timeout_listenername` setting in the `listener.ora` file determines how long "half-open" connections will be maintained before the connection is closed by the database.

Rationale:

As the maintenance of half-open connections uses up database networking resources and can ultimately result in a denial-of-service condition, this value should be set according to the needs of the organization.

Audit:

```
$ grep inbound_connect $ORACLE_HOME/network/admin/listener.ora
$ (not set by default)
```

Remediation:

```
$ if [ `grep '^inbound_connect_timeout_listenername = .*'
$ORACLE_HOME/network/admin/listener.ora` ]; then awk
'/^inbound_connect_timeout_listenername/ { $3 = "2" } {print}'
<$ORACLE_HOME/network/admin/listener.ora>
$ORACLE_HOME/network/admin/listener.ora.new; mv
$ORACLE_HOME/network/admin/listener.ora.new $ORACLE_HOME/network/admin/listener.ora;
else echo inbound_connect_timeout_listenername = 2 >>
$ORACLE_HOME/network/admin/listener.ora; fi
```

4.1.2 *secure_control_listenername settings in listener.ora (Scored)*

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `SECURE_CONTROL_listener_name` setting determines the type of control connection the Oracle server requires for remote configuration of the listener.

Rationale:

As listener configuration changes via unencrypted remote connections can result in unauthorized users sniffing the control configuration information from the network, these control values should be set according to the needs of the organization.

Audit:

```
$ grep SECURE_CONTROL \
$ORACLE_HOME/network/admin/listener.ora
```


Remediation:

```
Use a text editor such as vi to set the SECURE_CONTROL_listener_name=TCPS or  
SECURE_CONTROL_listener_name=IPC under the SECURE_CONTROL_listenername= parameter  
found in $ORACLE_HOME/network/admin/listener.ora
```

4.1.3 extprocs_dlls settings in listener.ora (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `EXTPROCS_DLLS` setting determines whether or not the Oracle server will allow external DLLs and/or libraries to be loaded into the database when external procedures are called. These external procedures work through external routines and allow communication with external applications through PL/SQL.

Rationale:

As allowing external DLLs and/or libraries to be loaded into the database when external procedures are called could allow system security protocols to be overwritten or corrupted, this capability should be restricted/disabled according to the needs of the organization.

Audit:

```
$ grep -i extproc \  
$ORACLE_HOME/network/admin/listener.ora
```

Remediation:

```
Use a text editor such as vi to set the EXTPROCS_DLLS =ONLY value along with absolute  
pathnames, to set values such as  
ENV="EXTPROC_DLLS=ONLY:<custom_dll_directory>/<custom_shared  
_library>, LD_LIBRARY_PATH=<oracle_home_directory>/lib")
```

4.1.4 Rejected - Dynamic listener registration settings in listener.ora (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `DYNAMIC_REGISTRATION_listener_name` setting determines whether or not the Oracle server will accept all registration connections to the listener.

Rationale:

As unauthorized registration connection requests to the listener, which have the same name as a pre-existing instance, if successful, are treated as "valid" RAC or Cluster servers for that instance and load-balance the traffic between the unauthorized and authorized servers, facilitating attacks where unauthorized users can sniff the database transmissions from the network, this capability should be restricted/disabled according to the needs of the organization.

Audit:

```
$ grep DYNAMIC_REGISTRATION \  
$ORACLE_HOME/network/admin/listener.ora
```

Remediation:

Use a text editor such as vi to set the `DYNAMIC_REGISTRATION_listener_name=off` parameter found in `$ORACLE_HOME/network/admin/listener.ora`

4.1.5 Listener registration connection settings in listener.ora (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `SECURE_REGISTER_listener_name` setting determines the type of protocol the Oracle server requires for remote registration connections to the listener.

Rationale:

As registration connections to the listener via unencrypted remote connections can result in unauthorized users sniffing the registration information from the network, these protocol values should be set according to the needs of the organization.

Audit:

```
$ grep SECURE_REGISTER \  
$ORACLE_HOME/network/admin/listener.ora
```

Remediation:

```
Use a text editor such as vi to set the
Set the SECURE_REGISTER_listener_name=TCPS or another valid secure protocol under the
LISTENER= parameter found in $ORACLE_HOME/network/admin/listener.ora
```

4.1.6 Listener administration protocol settings in listener.ora (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `SECURE_PROTOCOL_listener_name` setting determines the type of protocol the Oracle server requires for remote administrative connections to the listener.

Rationale:

As administrative connections to the listener via unencrypted remote connections can result in unauthorized users sniffing the administrative information from the network, these protocol values should be set according to the needs of the organization.

Audit:

```
$ grep SECURE_PROTOCOL \
$ORACLE_HOME/network/admin/listener.ora
```

Remediation:

```
Use a text editor such as vi to set the
Set the SECURE_PROTOCOL_listener_name=TCPS or another valid secure protocol under the
LISTENER= parameter found in $ORACLE_HOME/network/admin/listener.ora
```

4.1.7 Settings for the `admin_restrictions_listener_name` parameter (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `admin_restrictions_listener_name` setting in the `listener.ora` file can require that any attempted real-time alteration of the parameters in the `listener` via the `set` command file be refused unless the `listener.ora` file is manually altered then restarted by a privileged user.

Rationale:

As blocking unprivileged users from making alterations of the `listener.ora` file, where remote data/services are specified, will help protect data confidentiality, this value should be set to the needs of the organization.

Audit:

```
$ grep admin_restrictions_listener_name \  
$ORACLE_HOME/network/admin/listener.ora  
$ (not set by default)
```

Remediation:

```
$ if [ `grep '^admin_restrictions=.*' $ORACLE_HOME/network/admin/listener.ora` ]; then  
awk '/^ admin_restrictions_listener_name/ { $1 = "  
admin_restrictions_listener_name=on" } {print}'  
<$ORACLE_HOME/network/admin/listener.ora>  
$ORACLE_HOME/network/admin/listener.ora.new; mv  
$ORACLE_HOME/network/admin/listener.ora.new $ORACLE_HOME/network/admin/listener.ora;  
else echo admin_restrictions_listener_name=on >>  
$ORACLE_HOME/network/admin/listener.ora a; fi
```

4.1.8 Setting for the `logging_listener` parameter (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `logging_listener` setting in the `listener.ora` file requires that all listener actions be logged to create an audit trail.

Rationale:

As the logging of all actions by the listener will create an audit trail that is invaluable to forensic investigations of unauthorized activities, this value should be set to the needs of the organization.

Audit:

```
$ grep logging_listener $ORACLE_HOME/network/admin/listener.ora $ (not set by default)
```

Remediation:

```
$ if [ `grep '^logging_listener=.*' $ORACLE_HOME/network/admin/listener.ora` ]; then
awk '/^ logging_listener/ { $1 = "logging_listener=on" } {print}'
<$ORACLE_HOME/network/admin/listener.ora>
$ORACLE_HOME/network/admin/listener.ora.new; mv
$ORACLE_HOME/network/admin/listener.ora.new $ORACLE_HOME/network/admin/listener.ora;
else echo logging_listener=on >> $ORACLE_HOME/network/admin/listener.ora a; fi
```

4.1.9 Ensure there are no passwords in the listener.ora file (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle `listener` provides network connections to the database with the name of the connection, protocol addresses, and services offered by the database. In database versions prior to 11gr2, there was an option to include a password in the `listener.ora` file or to have OS-based authentication for `listener` connections; now only OS-based authentication is allowed and `listener.ora` file password use has been deprecated.

Rationale:

As using the default OS-based authentications for `listener` connections can remove the need to include a clear-text password in the `listener.ora` file, any password in this file should be removed according to the needs of the organization.

Audit:

```
grep PASSWORDS_LISTENER=
$ORACLE_HOME/network/admin/listener.ora file
```

Remediation:

```
$ if [ "`grep '^PASSWORDS_LISTENER=' ORACLE_HOME/network/admin/listener.ora`" ]; then
awk '/^PASSWORDS_LISTENER=/ { $1 = "" } {print}'
ORACLE_HOME/network/admin/listener.ora > ORACLE_HOME/network/admin/listener.ora.new;
mv ORACLE_HOME/network/admin/listener.ora.new ORACLE_HOME/network/admin/listener.ora;
fi
```

4.1.10 Change the default port numbers that connect to Oracle (Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle installation creates a number of well-known ports for connections to the `listener` service; these ports which are often targeted by unauthorized users' automated exploits.

Rationale:

As the default ports created by Oracle can provide a target for exploits by unauthorized users, the ports should be changed according to the needs of the organization.

Audit:

```
$ grep 1521 $ORACLE_HOME/network/admin/listener.ora
```

Remediation:

(new port example is "1527")

```
$ sed -e 's/1521/1527/' <$ORACLE_HOME/network/admin/listener.ora>
$ORACLE_HOME/network/admin/listener.ora.new mv
$ORACLE_HOME/network/admin/listener.ora.new $ORACLE_HOME/network/admin/listener.ora;
fi
```

4.1.11 *extprocs configuration in listener.ora (Scored)*

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

remove extproc

Rationale:

remove extproc

Audit:

```
$ grep -i extproc \
$ORACLE_HOME/network/admin/listener.ora
```

Remediation:

Use a text editor such as `vi` to set the `EXTPROCS_DLLS =ONLY` value along with absolute pathnames, to set values such as

```
ENV="EXTPROC_DLLS=ONLY:<custom_dll_directory>/<custom_shared_library>,LD_LIBRARY_PATH=<oracle_home_directory>/lib")
```

4.1.12 *secure_register_listener settings in listener.ora (Scored)*

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `SECURE_REGISTER_listener_name` setting specifies the protocols which are used to connect to the TNS listener.

Rationale:

As listener configuration changes via unencrypted remote connections can result in unauthorized users sniffing the control configuration information from the network, these control values should be set according to the needs of the organization.

Audit:

```
$ grep SECURE_CONTROL \  
$ORACLE_HOME/network/admin/listener.ora
```

Remediation:

```
Use a text editor such as vi to set the SECURE_CONTROL_listener_name=TCPS or  
SECURE_CONTROL_listener_name=IPC under the SECURE_CONTROL_listenername= parameter  
found in $ORACLE_HOME/network/admin/listener.ora
```

4.2 *sqlnet.ora settings*

Settings for sqlnet.ora

4.2.1 *Setting for the sqlnet.expire_time parameter (Scored)*

Profile Applicability:

- Level 2 - 11.2 on Oracle Linux 5

Description:

The `sqlnet.expire_time` setting in the `sqlnet.ora` file determines how long database connections that are inactive remain open, before the connection is expired by the database.

Rationale:

As the maintenance of open connections uses up database networking resources and can ultimately result in a denial-of-service condition, this value should be set according to the needs of the organization.

Audit:

```
$ grep sqlnet.expire_time \  
  $ORACLE_HOME/network/admin/sqlnet.ora  
$ (not set by default)
```

Remediation:

```
$ if [ `grep '^sqlnet.expire_time =.*' $ORACLE_HOME/network/admin/sqlnet.ora` ]; then  
  awk '/^ sqlnet.expire_time/ {$1 = "sqlnet.expire_time=10"} {print}'  
  <$ORACLE_HOME/network/admin/sqlnet.ora> $ORACLE_HOME/network/admin/sqlnet.ora.new; mv  
  $ORACLE_HOME/network/admin/sqlnet.ora.new $ORACLE_HOME/network/admin/sqlnet.ora; else  
  echo sqlnet.expire_time=10 >> $ORACLE_HOME/network/admin/sqlnet.ora; fi
```

4.2.2 Settings for the tcp.invited_nodes parameter (Scored)

Profile Applicability:

- Level 2 - 11.2 on Oracle Linux 5

Description:

The `tcp.invited_nodes` setting in the `sqlnet.ora` file provides a list, based on hostname and/or ip addresses, of nodes permitted to make incoming connections to the Oracle listener.

Rationale:

As limiting connections to the system by listing invited nodes will sharply limit the number of systems that can connect to the instance, thus reducing attack surfaces, this value should be set according to the needs of the organization.

Audit:

(The host ip addresses will vary according to your organization)

```
$ grep tcp.invited_nodes $ORACLE_HOME/network/admin/sqlnet.ora  
$ (not included as default)
```

Remediation:


```
$ if [ `grep '^tcp.invited_nodes=.*' $ORACLE_HOME/network/admin/sqlnet.ora` ]; then
awk '/^ tcp.invited_nodes/ {$1 = " tcp.invited_nodes=your_org_ips"} {print}'
<$ORACLE_HOME/network/admin/sqlnet.ora> $ORACLE_HOME/network/admin/sqlnet.ora.new; mv
$ORACLE_HOME/network/admin/sqlnet.ora.new $ORACLE_HOME/network/admin/sqlnet.ora; else
echo tcp.invited_nodes=(your_org_ips) >> $ORACLE_HOME/network/admin/sqlnet.ora; fi
```

4.2.3 Settings for the *tcp.excluded_nodes* parameter (Scored)

Profile Applicability:

- Level 2 - 11.2 on Oracle Linux 5

Description:

The *tcp.excluded_nodes* setting in the *sqlnet.ora* file provides a list, based on hostname and/or ip addresses, of nodes not allowed to make incoming connections to the Oracle listener.

Rationale:

As limiting connections to the system by listing excluded nodes will sharply limit the number of systems that can connect to the instance, thus reducing attack surfaces, this value should be set according to the needs of the organization.

Audit:

```
$ grep tcp.excluded_nodes $ORACLE_HOME/network/admin/sqlnet.ora
$ (not set by default)
```

Remediation:

```
$ if [ `grep '^tcp.excluded_nodes=.*' $ORACLE_HOME/network/admin/sqlnet.ora` ]; then
awk '/^ tcp.excluded_nodes/ {$1 = " tcp.excluded_nodes=your_org_ips"} {print}'
<$ORACLE_HOME/network/admin/sqlnet.ora> $ORACLE_HOME/network/admin/sqlnet.ora.new; mv
$ORACLE_HOME/network/admin/sqlnet.ora.new $ORACLE_HOME/network/admin/sqlnet.ora; else
echo tcp.excluded_nodes=(your_org_ips) >> $ORACLE_HOME/network/admin/sqlnet.ora; fi
```

4.2.4 Setting for the *sqlnet.inbound_connect_timeout* parameter (Scored)

Profile Applicability:

- Level 2 - 11.2 on Oracle Linux 5

Description:

The `sqlnet.inbound_connect_timeout` setting in the `sqlnet.ora` file determines how long "half-open" connections will be maintained, awaiting the completion of authentication, before the connection is closed by the database.

Rationale:

As the maintenance of half-open connections uses up database networking resources and can ultimately result in a denial-of-service condition, this value should be set according to the needs of the organization.

Audit:

```
$ grep sqlnet.inbound_connect_timeout / $ORACLE_HOME/network/admin/sqlnet.ora
$ (not set by default)
```

Remediation:

```
$ if [ `grep '^sqlnet.inbound_connect_timeout=.*'
$ORACLE_HOME/network/admin/sqlnet.ora` ]; then awk '/^ sqlnet.inbound_connect_timeout
/ {$1 = " sqlnet.inbound_connect_timeout=3"} {print}'
<$ORACLE_HOME/network/admin/sqlnet.ora> $ORACLE_HOME/network/admin/sqlnet.ora.new; mv
$ORACLE_HOME/network/admin/sqlnet.ora.new $ORACLE_HOME/network/admin/sqlnet.ora; else
echo sqlnet.inbound_connect_timeout=3 >> $ORACLE_HOME/network/admin/sqlnet.ora; fi
```

4.2.5 Setting for the `SQLNET.ALLOWED_LOGON_VERSION` parameter (Scored)

Profile Applicability:

- Level 2 - 11.2 on Oracle Linux 5

Description:

The setting for the `SQLNET.ALLOWED_LOGON_VERSION` setting in the `sqlnet.ora` file specifies the versions of the Oracle client that are allowed login privileges.

Rationale:

As the pre-11 versions of the Oracle client do not use strong authentication for client login and could allow unauthorized users to break credentials sniffed from the network, this value should be set according to the needs of the organization.

Audit:

```
$ grep -i SQLNET.ALLOWED_LOGON_VERSION / $ORACLE_HOME/network/admin/sqlnet.ora
```

Remediation:

```
$ if [ `grep '^sqlnet.allowed_logon_version=.*' $ORACLE_HOME/network/admin/sqlnet.ora`
]; then awk '/^ sqlnet.allowed_logon_version/ {$1 = "
sqlnet.allowed_logon_version=11"} {print}' <$ORACLE_HOME/network/admin/sqlnet.ora>
$ORACLE_HOME/network/admin/sqlnet.ora.new; mv
$ORACLE_HOME/network/admin/sqlnet.ora.new $ORACLE_HOME/network/admin/sqlnet.ora; else
echo sqlnet.allowed_logon_version=11 >> $ORACLE_HOME/network/admin/sqlnet.ora; fi
```

4.2.6 Setting for the *tcp.validnode_checking* parameter (Scored)

Profile Applicability:

- Level 2 - 11.2 on Oracle Linux 5

Description:

The *tcp.validnode_checking* setting in the *sqlnet.ora* file allow for the testing of incoming connections to see if these match the "invited" and "excluded" systems list.

Rationale:

As limiting connections to system by listing invited and excluded hosts will sharply limit the number of systems that can connect to the instance, this value should be set according to the needs of the organization.

Audit:

```
$ grep tcp.validnode $ORACLE_HOME/admin/network/sqlnet.ora
$ (not set by default)
```

Remediation:

```
$ if [ `grep '^tcp_validnode_checking=.*' $ORACLE_HOME/network/admin/sqlnet.ora` ];
then awk '/^tcp_validnode_checking/ {$1 = "tcp_validnode_checking=YES"} {print}'
<$ORACLE_HOME/network/admin/sqlnet.ora> $ORACLE_HOME/network/admin/sqlnet.ora.new; mv
$ORACLE_HOME/network/admin/sqlnet.ora.new $ORACLE_HOME/network/admin/sqlnet.ora; else
echo tcp_validnode_checking=YES >> $ORACLE_HOME/network/admin/sqlnet.ora; fi
```

4.3 Settings for the *global_names* parameter (Scored)

Profile Applicability:

- Level 2 - 11.2 on Oracle Linux 5

Description:

The *global_names* setting in *init.ora* requires that the name of a database link matches that of the remote database it will connect to.

Rationale:

As not requiring database connections to match the domain that is being called remotely could allow unauthorized domain sources to potentially connect via brute-force tactics, this value should be set according to the needs of the organization.

Audit:

```
$ grep -i global_names= $ORACLE_HOME/dbs/init.ora
$ global_names=false
```

Remediation:

```
$ sed -e 's/global_names=false/global_names=true/i' <$ORACLE_HOME/dbs/init.ora>
$ORACLE_HOME/dbs/init.ora.new mv $ORACLE_HOME/dbs/init.ora.new
$ORACLE_HOME/dbs/init.ora
```

OR

```
SQL> alter system set global_names = true scope = spfile;
```

4.4 Block trace files from being read by PUBLIC users (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `trace_files_public` setting in `init.ora` determines whether or not the public user can read the system's trace file.

Rationale:

As permitting the `public` user to read the instance's trace files file could release sensitive information about instance operations, this value should be restricted according to the needs of the organization.

Audit:

```
$ grep trace_files_public $ORACLE_HOME/network/admin/init.ora
```

Remediation:

```
sed -e 's/trace_files_public=true/trace_files_public=false/i'
<$ORACLE_HOME/dbs/init.ora> $ORACLE_HOME/dbs/init.ora.new mv
$ORACLE_HOME/dbs/init.ora.new $ORACLE_HOME/dbs/init.ora; fi
```

4.5 Settings for the `remote_os_roles` parameter (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `remote_os_authn` setting in the `init.ora` file determines whether or not OS 'roles' with the attendant privileges are allowed for remote client connections.

Rationale:

As permitting OS roles for database connections to can allow the spoofing of connections and permit granting the privileges of an OS role to unauthorized users to make connections, this value should be restricted according to the needs of the organization.

Audit:

```
$ grep remote_os_authn= $ORACLE_HOME/dbs/init.ora
$ remote_os_authn=true
```

Remediation:

```
$ sed -e 's/remote_os_authn=true/remote_os_authn=false/i'
<$ORACLE_HOME/dbs/init.ora> $ORACLE_HOME/dbs/init.ora.new; mv
$ORACLE_HOME/dbs/init.ora.new $ORACLE_HOME/dbs/init.ora

OR

SQL> alter system set remote_os_authn = false scope = spfile;
```

4.6 Settings for the `remote_listener` parameter (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `remote_listener` setting in the `init.ora` file determines whether or not a valid listener can be established on a system separate from the database instance.

Rationale:

As permitting a remote listener for connections to the database instance can allow for the potential spoofing of connections and that could compromise data confidentiality and

integrity, this value should be disabled/restricted according to the needs of the organization.

Audit:

```
$ grep remote_listener=$ORACLE_HOME/dbs/init.ora
```

Remediation:

```
$ sed -e 's/remote_listener=true/remote_listener=false/i' <$ORACLE_HOME/dbs/init.ora>
$ORACLE_HOME/dbs/init.ora.new; mv $ORACLE_HOME/dbs/init.ora.new
$ORACLE_HOME/dbs/init.ora
```

OR

```
SQL> alter system set remote_listener = false scope = spfile;
```

4.7 Settings for the audit_trail parameter (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `audit_trail` setting in the `init.ora` file determines whether or not Oracle's basic audit features are enabled. These can be set to "Operating System"(OS), "DB," or "DB EXTENDED."

Rationale:

As enabling the basic auditing features for the Oracle instance permits the collection of data to troubleshoot problems, as well as providing value forensic logs in the case of a system breach, this value should be set according to the needs of the organization.

Audit:

```
$ grep audit_trail= $ORACLE_HOME/dbs/init.ora
$ audit_trail=
```

Remediation:

```
$ if [ "`grep '^audit_trail=.*' $ORACLE_HOME/dbs/init.ora`" ]; then awk
'/^audit_trail/ { $1 = "audit_trail=OS" } {print}' <$ORACLE_HOME/dbs/init.ora>
$ORACLE_HOME/dbs/init.ora.new; mv $ORACLE_HOME/dbs/init.ora.new
$ORACLE_HOME/dbs/init.ora; else echo audit_trail=OS >> $ORACLE_HOME/dbs/init.ora; fi
```

OR

```
SQL> alter system set audit_trail = OS scope = spfile;
```

4.8 Settings for the `os_authent_prefix` parameter (Scored)

Profile Applicability:

- Level 2 - 11.2 on Oracle Linux 5

Description:

The `os_authent_prefix` setting in the `init.ora` file specifies the prefix Oracle uses to authenticate connection attempts. (Oracle concatenates this parameter out of the value of the user's OS account name/password.)

Rationale:

As allowing the use of an authentication prefix can permit the roles of the DBA and OS System Administrators to overlap, violating the principle of separation of duties, this value should be set according to the needs of the organization.

Audit:

```
$ grep os_authent_prefix= $ORACLE_HOME/dbs/init.ora
$ os_authent_prefix=OP$ (this is the legacy default)
```

OR

```
SQL> show parameter os_authent_prefix
```

NAME	TYPE	VALUE
os_authent_prefix	string	OP\$

Remediation:

```
$ if [ "`grep '^os_authent_prefix=.*' $ORACLE_HOME/dbs/init.ora`" ]; then awk
'/^os_authent_prefix/ { $1 = "os_authent_prefix=\"\"\" } {print}'
<$ORACLE_HOME/dbs/init.ora> $ORACLE_HOME/dbs/init.ora.new; mv
$ORACLE_HOME/dbs/init.ora.new $ORACLE_HOME/dbs/init.ora; else echo
os_authent_prefix=\"\" >> $ORACLE_HOME/dbs/init.ora; fi
```

OR

```
SQL> alter system set os_authent_prefix = NULL scope = spfile;
```

4.9 Settings for the `os_roles` parameter (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `os_roles` setting in the `init.ora` file permits externally created groups to be applied to database management.

Rationale:

As allowing the OS use external groups for database management could cause privilege overlaps and generally weaken security, this value should be set according to the needs of the organization.

Audit:

```
$ grep os_roles= $ORACLE_HOME/dbs/init.ora
$ (not set by default)

OR

SQL> show parameter os_roles;
```

NAME	TYPE	VALUE
os_roles	boolean	FALSE

Remediation:

```
$ if [ "`grep '^os_roles=.*' $ORACLE_HOME/dbs/init.ora`" ]; then awk '/^os_roles/ { $1 = "os_roles=false" } {print}' <$ORACLE_HOME/dbs/init.ora>
$ORACLE_HOME/dbs/init.ora.new; mv $ORACLE_HOME/dbs/init.ora.new
$ORACLE_HOME/dbs/init.ora; else echo os_roles=false >>$ORACLE_HOME/dbs/init.ora; fi

OR

SQL> ALTER SYSTEM SET OS_ROLES=false SCOPE=SPFILE;
```

4.10 Settings for the `remote_os_roles` parameter (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `remote_os_roles` setting in the `init.ora` file permits remote users' OS roles to be applied to database management.

Rationale:

As allowing remote clients' OS roles to have permissions for database management could cause privilege overlaps and generally weaken security, this value should be set according to the needs of the organization.

Audit:

```
$ grep remote_os_roles= $ORACLE_HOME/dbs/init.ora
$ (not set by default)
```

OR

```
SQL> show parameter remote_os_roles;
```

NAME	TYPE	VALUE
remote_os_roles	boolean	FALSE

Remediation:

```
$ if [ "`grep '^remote_os_roles=.*' $ORACLE_HOME/dbs/init.ora`" ]; then awk
'/^remote_os_roles/ { $1 = "remote_os_roles=false" } {print}'
<$ORACLE_HOME/dbs/init.ora> $ORACLE_HOME/dbs/init.ora.new; mv
$ORACLE_HOME/dbs/init.ora.new $ORACLE_HOME/dbs/init.ora; else echo
remote_os_roles=false >>$ORACLE_HOME/dbs/init.ora; fi

SQL> ALTER SYSTEM SET OS_ROLES=false SCOPE=SPFILE;
```

4.11 Settings for the utl_file_dir parameter (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `utl_file_dir` setting in the `V$PARAMETER` table permits the creation of directories that can be read and written to by all users. (This is deprecated but usable in 11g.)

Rationale:

As using the `utl_file_dir` to create directories allows the potential manipulation of these directories by unauthorized users, use of this capability should be avoided.

Audit:

```
$ grep util_file_dir $ORACLE_HOME/dbs/init.ora
$ (not set by default)
```

OR

```
SQL> SHOW PARAMETER util_file_dir;
```

NAME	TYPE	VALUE
------	------	-------

Remediation:

```
$ if [ "`grep '^util_file_dir=.*' $ORACLE_HOME/dbs/init.ora`" ]; then awk
'/^util_file_dir/ { $1 = "util_file_dir=" } {print}' <$ORACLE_HOME/dbs/init.ora >
$ORACLE_HOME/dbs/init.ora.new; mv $ORACLE_HOME/dbs/init.ora.new
$ORACLE_HOME/dbs/init.ora; else echo util_file_dir="" >> $ORACLE_HOME/dbs/init.ora; fi

OR

SQL> ALTER SYSTEM SET UTIL_FILE_DIR = false SCOPE=SPFILE;
```

4.12 Rejected - Settings for the redo log on duplexed physical disk locations (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `LOG_ARCHIVE_DUPLEX_DEST` setting in the `init.ora` file shows the physical disk location(s) of the redo log files used for system recovery.

Rationale:

As having a separate physical disk location for the redundant redo logs can help ensure the ability to recover the system transactions in the event of a disk failure, this value should be set to the needs of the organization.

Audit:

```
SQL> SHOW PARAMETER log_archive_duplex_dest;
NAME                                TYPE                                VALUE
-----                                -
log_archive_duplex_dest              string
```

Remediation:

```
SQL> ALTER SYSTEM SET PARAMETER log_archive_duplex_dest=paths scope=spfile;
```

4.13 Rejected - Settings for successful redo log disk writes (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `LOG_ARCHIVE_MIN_SUCCEED_DEST` setting in the `init.ora` file shows the requirement for the successful writing of redo log information to two or more of the physical location(s) of the redo log files.

Rationale:

As conforming that successful writes to the redundant redo logs do occur as specified, to ensure redo logs are available in the event of a disk failure, this value should be set to the needs of the organization.

Audit:

```
SQL> SHOW PARAMETER LOG_ARCHIVE_MIN_SUCCEED_DEST;
```

NAME	TYPE	VALUE
log_archive_min_succeed_dest	integer	1

Remediation:

```
SQL> alter system set LOG_ARCHIVE_MIN_SUCCEED_DEST=[x]>=2 scope=spfile;
```

4.14 Settings for the `sql92_security` parameter (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `sql92_security` parameter setting in the `init.ora` file require a user to have the `SELECT` privilege for a table before being allowed to do `UPDATE` or `DELETE` operations that use a `WHERE` clause on the table; this allows a user to delete table data while blocking the possibility of the user being able to guess what other values are in that table.

Rationale:

As blocking users with permissions to one set of data within a table from intuiting the contents of other data can help increase data confidentiality, this value should be set to the needs of the organization (See Caution).

Audit:

```
$ grep sql92_security $ORACLE_HOME/dbs/init.ora
```

Remediation:

```
$ if [ `grep '^ sql92_security=.*' $ORACLE_HOME/dbs/init.ora` ]; then awk
'/^sql92_security/ { $1 = "sql92_security=TRUE" } {print}' <$ORACLE_HOME/dbs/init.ora>
$ORACLE_HOME/dbs/init.ora.new; mv $ORACLE_HOME/dbs/init.ora.new
$ORACLE_HOME/dbs/init.ora; else echo sql92_security=TRUE >> $ORACLE_HOME/dbs/init.ora;
fi

OR

SQL> ALTER SYSTEM SET sql92_security=TRUE SCOPE=SPFILE;
```

4.15 Setting for the O7_dictionary_accessibility parameter (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `O7_dictionary_accessibility` setting in the `init.ora` file is a database initialization parameter that allows/disallows with the EXECUTE ANY PROCEDURE and SELECT ANY DICTIONARY access to objects in the SYS schema; this functionality was created for the ease of migration from Oracle 7 databases to later versions.

Rationale:

As leaving the SYS schema so open to connection could permit unauthorized access to critical data structures, this value should be set according to the needs of the organization.

Audit:

```
$ grep o7_dictionary_accessibility $ORACLE_HOME/dbs/init.ora

OR

SQL> show parameter O7_DICTIONARY_ACCESSIBILITY;

NAME                                TYPE                                VALUE
-----                                -
O7_DICTIONARY_ACCESSIBILITY         boolean                             FALSE
```

Remediation:

```
$ if [ `grep -i '^O7_dictionary_accessibility=.*' $ORACLE_HOME/dbs/init.ora` ]; then
awk '/^O7_dictionary_accessibility/ { $1 = "O7_dictionary_accessibility='FALSE'" }
{print}' <$ORACLE_HOME/dbs/init.ora> $ORACLE_HOME/dbs/init.ora.new; mv
$ORACLE_HOME/dbs/init.ora.new $ORACLE_HOME/dbs/init.ora; else echo
O7_dictionary_accessibility='FALSE' >> $ORACLE_HOME/dbs/init.ora; fi
```

4.16 Rejected - Setting for the spfile<sid>.ora parameter (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `spfile` setting for dispatchers in the `spfile<sid>.ora` file provides ports for TCP connections for `ftp` (2100) and locally generated `http` (8080).

Rationale:

As leaving these ports open can provide attack vectors into the database instance, this value should be set/removed according to the needs of the organization.

Audit:

(Database sid is "orcl")

```
$ grep -i dispatchers=(PROTOCOL=TCP) \
  $ORACLE_HOME/dbs/spfileorcl.ora
$ Binary file $ORACLE_HOME/dbs/spfileorcl.ora matches
```

Remediation:

```
SQL> ALTER SYSTEM SET dispatchers=off SCOPE=SPFILE;
```

4.17 Setting for the `audit_sys_operations` parameter (Scored)

Profile Applicability:

- Level 1 - 11.2 on any platform

Description:

The `AUDIT_SYS_OPERATIONS` setting for dispatchers in the `init.ora` or `spfile<sid>.ora` file provides for the auditing of all user activities conducted under the `SYSDBA` and `SYSDBA` accounts, which are among the highest privilege levels.

Rationale:

As the separation of duties principle requires that audit records of specific user activities not be accessible by the user in question, no matter how privileged the user, this value should be set according to the needs of the organization.

Audit:

```
SQL> SHOW PARAMETER AUDIT_SYS_OPERATIONS;
NAME                                TYPE          VALUE
```

-----	-----	-----
audit_sys_operations	boolean	FALSE

Remediation:

```
SQL> ALTER SYSTEM SET AUDIT_SYS_OPERATIONS = true SCOPE=SPFILE;
```

4.18 Rejected - Setting account access for the application schema owner (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `application schema owner` represents the Oracle user that owns all database objects in a given application's `schema`, such as fields, packages, relationships, tables, views, etc., as well the structural definitions that relate the objects in the database.

Rationale:

As allowing continuous schema owner access can potentially allow an unauthorized user to connect as the schema owner, resulting in the compromise of the entire application, this capability should be disabled/restricted according to the needs of the organization.

Audit:

```
SQL> SELECT <APPLICATION_SCHEMA_OWNER (username)>, ACCOUNT_STATUS FROM DBA_USERS;
```

Remediation:

```
SQL> ALTER USER <APPLICATION_SCHEMA_OWNER (username)> ACCOUNT LOCK PASSWORD EXPIRE;
```

4.19 Setting for the remote_login_passwordfile parameter (Scored)

Profile Applicability:

- Level 1 - 11.2 on any platform

Description:

The `remote_login_passwordfile` setting in the `init.ora` file specifies whether or not Oracle checks for a password file during login and how many databases can use the password file.

Rationale:

As the use of this sort of password login file could permit unsecured, privileged connections to the database, this value should be set according to the needs of the organization.

Audit:

```
SQL> SHOW PARAMETER remote_login_passwordfile;
NAME                                     TYPE        VALUE
-----
remote_login_passwordfile               string      EXCLUSIVE
```

Remediation:

```
SQL> ALTER SYSTEM SET remote_login_passwordfile = none scope = spfile;
```

4.20 Rejected - Remote Administration via the Oracle Connection Manager (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `REMOTE_ADMIN` settings for the database specifies whether or not a remote Oracle Connection Manager Control utility session would be allowed to access the Oracle Connection Manager

Rationale:

As the allowing Oracle Connection Manager Control utility session to connect remotely could facilitate remote system break-in attempts, this value should be set according to the needs of the organization.

Audit:

```
C:\>grep REMOTE_ADMIN $ORACLE_HOME/network/admin/cman.ora
```

Remediation:

```
$ if [ `grep '^REMOTE_ADMIN=.*' $ORACLE_HOME/network/admin/cman.ora` ]; then awk
'/^REMOTE_ADMIN/ {$1 = "REMOTE_ADMIN=NO"} {print}'
<$ORACLE_HOME/network/admin/cman.ora> $ORACLE_HOME/network/admin/cman.ora.new; mv
$ORACLE_HOME/network/admin/cman.ora.new $ORACLE_HOME/network/admin/cman.ora; else
```

```
echo REMOTE_ADMIN=NO >> $ORACLE_HOME/network/admin/cman.ora; else echo
$ORACLE_HOME/network/admin/cman.ora file not found; fi
```

4.21 Setting for `sec_return_server_release_banner` (Scored)

Profile Applicability:

- Level 1 - 11.2 on any platform

Description:

The information about patch/update release number in `init.ora` provides information about the exact patch/update release that is currently running on the database.

Rationale:

As allowing the database to return information about the patch/update release number in `init.ora` could facilitate unauthorized users' attempts to gain access based upon known patch weaknesses, this value should be set according to the needs of the organization.

Audit:

```
SQL> show parameter SEC_RETURN_SERVER_RELEASE_BANNER;
```

NAME	TYPE	VALUE
sec_return_server_release_banner	boolean	FALSE

Remediation:

```
SQL> ALTER SYSTEM SET sec_return_server_release_banner=false scope=spfile;
```

4.22 Rejected - Setting the `DB_SECUREFILE` parameter in `init.ora` (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `DB_SECUREFILE` setting in `init.ora` determines whether or not Large Object (LOB) files can be de-duplicated, encrypted, or compressed during file creation/update operations.

Rationale:

As setting the `DB_SECUREFILE` parameter to `ALWAYS` allows the database to return information about the patch/update release number in `init.ora` to de-duplicate, encrypt, or compress files at need, while files with a `BASIC` setting do not have this capability, this value should be set according to the needs of the organization.

Audit:

```
SQL> show parameter DB_SECUREFILE;
```

NAME	TYPE	VALUE
db_securefile	string	PERMITTED

Remediation:

```
SQL> ALTER SYSTEM SET DB_SECUREFILE=ALWAYS scope=spfile;
```

4.23 Setting for `sec_case_sensitive_logon_settings` (Scored)

Profile Applicability:

- Level 1 - 11.2 on any platform

Description:

The `SEC_CASE_SENSITIVE_LOGIN_SETTINGS` information determines whether or not case-sensitivity is required for passwords during login.

Rationale:

As requiring the database to use case-sensitivity during login increases the symbol space necessary for unauthorized users to successfully complete brute-force login attacks, this value should be set according to the needs of the organization.

Audit:

```
SQL> SHOW PARAMETER SEC_CASE_SENSITIVE_LOGON;
```

NAME	TYPE	VALUE
sec_case_sensitive_logon	boolean	TRUE

Remediation:

```
SQL> ALTER SYSTEM SET SEC_CASE_SENSITIVE_LOGON=TRUE scope=spfile;
```

4.24 Rejected - Login requirements settings by version (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `PASSWORD_VERSIONS` settings information indicates what version of Oracle login a given DBA user account has been created or set at--Oracle 10g where case-sensitivity is not enforced or Oracle 11g, where case-sensitivity is enforced.

Rationale:

As requiring the database to use case-sensitivity during DBA-level login increases the symbol space necessary for unauthorized users to successfully complete brute-force login attacks, this value should be set according to the needs of the organization.

Audit:

```
SQL> SELECT username, password_versions FROM dba_users;
```

USERNAME	PASSWORD
TEST	10G 11G
SPATIAL_WFS_ADMIN_USR	10G 11G
SPATIAL_CSW_ADMIN_USR	10G 11G
SYSTEM	10G 11G
SYS	10G 11G
. . . .	

OUTPUT TRUNCATED

Remediation:

```
SQL> ALTER SYSTEM SET SEC_CASE_SENSITIVE_LOGON = TRUE scope = spfile ; (ABOVE)
```

and:

Require all with 10g password settings to change passwords.

4.25 Setting for `sec_max_failed_login_attempts` (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `SEC_MAX_FAILED_LOGIN_ATTEMPTS` parameter determines how many failed login attempts are allowed before Oracle closes the login connection.

Rationale:

As allowing an unlimited number of login attempts for a user connection can facilitate both brute-force login attacks and the occurrence of Denial-of-Service, this value should be set according to the needs of the organization.

Audit:

```
SQL> SHOW PARAMETER SEC_MAX_FAILED_LOGIN_ATTEMPTS;
```

NAME	TYPE	VALUE
sec_max_failed_login_attempts	integer	10

Remediation:

```
SQL> ALTER SYSTEM SET SEC_MAX_FAILED_LOGIN_ATTEMPTS = 5 scope=spfile;
```

OR

```
if [ "`grep -i '^SEC_MAX_FAILED_LOGIN_ATTEMPTS=.*' $ORACLE_HOME/dbs/init.ora`" ]; then  
awk '/^SEC MAX FAILED LOGIN ATTEMPTS/ { $1 = "SEC MAX FAILED LOGIN ATTEMPTS=5" }  
{print}' <$ORACLE_HOME/dbs/init.ora> $ORACLE_HOME/dbs/init.ora.new; mv  
$ORACLE_HOME/dbs/init.ora.new $ORACLE_HOME/dbs/init.ora; else echo  
SEC_MAX_FAILED_LOGIN_ATTEMPTS=5 >> $ORACLE_HOME/dbs/init.ora; fi
```

4.26 Setting for `sec_protocol_error_further_action` (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `SEC_PROTOCOL_ERROR_FURTHER_ACTION` setting determines the Oracle's server's response to bad/malformed packets received from the client.

Rationale:

As bad packets received from the client can potentially indicate packet-based attacks on the system, such as "TCP SYN Flood" or "Smurf" attacks, which could result in a Denial-of-Service condition, this value should be set according to the needs of the organization.

Audit:

```
SQL> show parameter SEC_PROTOCOL_ERROR_FURTHER_ACTION;
```

NAME	TYPE	VALUE
sec_protocol_error_further_action	string	CONTINUE

Remediation:

```
SQL> ALTER SYSTEM SET SEC_PROTOCOL_ERROR_FURTHER_ACTION = delay,3 scope=spfile ;
```

OR

```
SQL> ALTER SYSTEM SET SEC_PROTOCOL_ERROR_FURTHER_ACTION = drop,3 scope=spfile ;
```

4.27 Setting for sec_protocol_error_trace_action (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `SEC_PROTOCOL_ERROR_TRACE_ACTION` setting determines the Oracle's server's logging response level to bad/malformed packets received from the client, by generating `ALERT`, `LOG`, or `TRACE` levels of detail in the log files.

Rationale:

As bad packets received from the client can potentially indicate packet-based attacks on the system, such as "TCP SYN Flood" or "Smurf" attacks, which could result in a Denial-of-Service condition, this diagnostic/logging value for `ALERT`, `LOG`, or `TRACE` conditions should be set according to the needs of the organization.

Audit:

```
SQL> show parameter SEC_PROTOCOL_ERROR_TRACE_ACTION;
```

NAME	TYPE	VALUE
sec_protocol_error_trace_action	string	TRACE

Remediation:

```
SQL> ALTER SYSTEM SET SEC_PROTOCOL_ERROR_TRACE_ACTION=LOG scope=spfile;
```

4.28 Settings for the local_listener parameter (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `local_listener` setting xxxx in the `init.ora` file determines whether or not a valid listener can be established on a system separate from the database instance.

Rationale:

As permitting a remote listener for connections to the database instance can allow for the potential spoofing of connections and that could compromise data confidentiality and integrity, this value should be disabled/restricted according to the needs of the organization.

Audit:

```
$ grep remote_listener=$ORACLE_HOME/dbs/init.ora
```

Remediation:

```
$ sed -e 's/remote_listener=true/remote_listener=false/i' <$ORACLE_HOME/dbs/init.ora>  
$ORACLE_HOME/dbs/init.ora.new; mv $ORACLE_HOME/dbs/init.ora.new  
$ORACLE_HOME/dbs/init.ora
```

OR

```
SQL> alter system set remote_listener = false scope = spfile;
```

5 Possibly Rejected - Encryption-specific Requirements and Settings

The encryption of the contents of the data tables and traffic can help to ensure that even if the data is compromised by network sniffing or unauthorized access, the data will remain unintelligible to the recipient due to its encrypted state.

5.1 Advanced Security Options

Oracle Advanced Security Options is a non-free security feature.

5.1.1 Encryption of server-to-client communications in `sqlnet.ora` (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `SQLNET.ENCRYPTION_SERVER` setting in `sqlnet.ora` enables the encryption for the database server, which will then allow, reject, request, or require encryption for all client connections.

Rationale:

As the lack of encryption on connection requests could make the traffic vulnerable network sniffers, this capability should be set according to the needs of the organization.

Audit:

```
$ grep SQLNET.ENCRYPTION_SERVER \
  $ORACLE_HOME/network/admin/sqlnet.ora
```

Remediation:

```
$ if [ "`grep -i '^SQLNET.ENCRYPTION_SERVER=.*' $ORACLE_HOME/
network/admin/sqlnet.ora`" ]; then awk '/^SQLNET.ENCRYPTION_SERVER/ { $1 =
"SQLNET.ENCRYPTION_SERVER=required" } {print}' <$ORACLE_HOME/network/admin/sqlnet.ora>
$ORACLE_HOME/network/admin/sqlnet.ora.new; mv $ORACLE_HOME/
network/admin/sqlnet.ora.new $ORACLE_HOME/network/admin/sqlnet.ora; else echo
SQLNET.ENCRYPTION_SERVER=required >> $ORACLE_HOME/network/admin/sqlnet.ora; fi
```

5.1.2 Encryption of client-to-server communications in `sqlnet.ora` (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `SQLNET.ENCRYPTION_CLIENT` setting in `sqlnet.ora` enables the encryption for the client to the database server, which will then allow, reject, request, or require encryption for all connections.

Rationale:

As the lack of encryption on connection requests could make the traffic vulnerable network sniffers, this capability should be set according to the needs of the organization.

Audit:

```
$grep SQLNET.ENCRYPTION_CLIENT \ $ORACLE_HOME/network/admin/sqlnet.ora
```

Remediation:

```
$ if [ "`grep -i '^SQLNET.ENCRYPTION_CLIENT=.*' $ORACLE_HOME/
network/admin/sqlnet.ora`" ]; then awk '/^SQLNET.ENCRYPTION_CLIENT/ { $1 =
"SQLNET.ENCRYPTION_CLIENT=required" } {print}' <$ORACLE_HOME/network/admin/sqlnet.ora>
$ORACLE_HOME/network/admin/sqlnet.ora.new; mv $ORACLE_HOME/
network/admin/sqlnet.ora.new $ORACLE_HOME/network/admin/sqlnet.ora; else echo
SQLNET.ENCRYPTION_CLIENT=required >> $ORACLE_HOME/network/admin/sqlnet.ora; fi
```

5.1.3 Integrity of server-to-client communications in sqlnet.ora (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `SQLNET.CRYPTO_CHECKSUM_SERVER` setting in `sqlnet.ora` specifies the checksum requirement for the database server, which will then accept, reject, request, or require a checksum for all client connections to validate that the datastream is unaltered.

Rationale:

As the lack of checksum integrity checks on traffic can make the datastream vulnerable to undetected alteration, this capability should be set according to the needs of the organization.

Audit:

```
$ grep SQLNET.CRYPTO_CHECKSUM_SERVER \
$ORACLE_HOME/network/admin/sqlnet.ora
```

Remediation:

```
$ if [ "`grep -i '^SQLNET.CRYPTO_CHECKSUM_SERVER=.*'
$ORACLE_HOME/network/admin/sqlnet.ora`" ]; then awk '/^ SQLNET.CRYPTO_CHECKSUM_SERVER/
{ $1 = "SQLNET.CRYPTO_CHECKSUM_SERVER=REQUIRED" } {print}'
<$ORACLE_HOME/network/admin/sqlnet.ora> $ORACLE_HOME/network/admin/sqlnet.ora.new; mv
$ORACLE_HOME/network/admin/sqlnet.ora.new $ORACLE_HOME/network/admin/sqlnet.ora; else
echo SQLNET.CRYPTO_CHECKSUM_SERVER=REQUIRED >> $ORACLE_HOME/network/admin/sqlnet.ora;
fi
```

5.1.4 Integrity of client-to-server communications in sqlnet.ora (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `SQLNET.CRYPTO_CHECKSUM_CLIENT` setting in `sqlnet.ora` specifies the checksum requirement for the database client, which will then accept, reject, request, or require check summing for all server connections to validate that the datastream is unaltered.

Rationale:

As the lack of checksum integrity checks on traffic can make the datastream vulnerable to undetected alteration, this capability should be set according to the needs of the organization.

Audit:

```
$ grep SQLNET.CRYPTO_CHECKSUM_CLIENT \
  $ORACLE_HOME/network/admin/sqlnet.ora
```

Remediation:

```
$ if [ "`grep -i '^SQLNET.CRYPTO_CHECKSUM_CLIENT=.*'
$ORACLE_HOME/network/admin/sqlnet.ora`" ]; then awk '/^ SQLNET.CRYPTO_CHECKSUM_CLIENT/
{ $1 = "SQLNET.CRYPTO_CHECKSUM_CLIENT=REQUIRED" } {print} '
<$ORACLE_HOME/network/admin/sqlnet.ora.new> $ORACLE_HOME/ network/admin/sqlnet.ora; mv
$ORACLE_HOME/ network/admin/sqlnet.ora.new $ORACLE_HOME network/admin/sqlnet.ora; else
echo SQLNET.CRYPTO_CHECKSUM_CLIENT=REQUIRED >> $ORACLE_HOME/network/admin/sqlnet.ora;
fi
```

5.1.5 Type of server-to-client integrity checks in sqlnet.ora (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `SQLNET.CRYPTO_CHECKSUM_TYPES_SERVER` setting in `sqlnet.ora` specifies the checksum requirement type, MD5 or SHA-1, to be used for the database server integrity process.

Rationale:

As the type of checksum used, the older MD5 vs. the stronger SHA-1, can make the datastream integrity validation process stronger or weaker, this value should be set according to the needs of the organization.

Audit:


```
$ grep SQLNET.CRYPTO_CHECKSUM_TYPES_SERVER \  
$ORACLE_HOME/network/admin/sqlnet.ora
```

Remediation:

```
$ if [ "`grep -i '^SQLNET.CRYPTO_CHECKSUM_TYPES_SERVER=.*'  
$ORACLE_HOME/network/admin/sqlnet.ora`" ]; then awk '/^  
SQLNET.CRYPTO_CHECKSUM_TYPES_SERVER/ { $1 = "  
SQLNET.CRYPTO_CHECKSUM_TYPES_SERVER=(SHA1\)" } {print}'  
<$ORACLE_HOME/network/admin/sqlnet.ora> $ORACLE_HOME/ network/admin/sqlnet.ora.new; mv  
$ORACLE_HOME/ network/admin/sqlnet.ora.new $ORACLE_HOME network/admin/sqlnet.ora; else  
echo SQLNET.CRYPTO_CHECKSUM_TYPES_SERVER=(SHA1\)>>  
$ORACLE_HOME/network/admin/sqlnet.ora; fi
```

5.1.6 Type of client-to-server integrity checks in sqlnet.ora (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `SQLNET.CRYPTO_CHECKSUM_TYPES_CLIENT` setting in `sqlnet.ora` specifies the checksum requirement type, MD5 or SHA-1, to be used for the client's connections to the database server for integrity checking process.

Rationale:

As the type of checksum used, the older MD5 vs. the stronger SHA-1, can make the datastream integrity validation process stronger or weaker, this value should be set according to the needs of the organization.

Audit:

```
$ grep SQLNET.CRYPTO_CHECKSUM_TYPES_CLIENT \  
$ORACLE_HOME/network/admin/sqlnet.ora
```

Remediation:

```
$ if [ "`grep -i '^SQLNET.CRYPTO_CHECKSUM_TYPES_CLIENT=.*'  
$ORACLE_HOME/network/admin/sqlnet.ora`" ]; then awk  
'/^SQLNET.CRYPTO_CHECKSUM_TYPES_CLIENT/ { $1 = "  
SQLNET.CRYPTO_CHECKSUM_TYPES_CLIENT=(SHA1\)" } {print}'  
<$ORACLE_HOME/network/admin/sqlnet.ora> $ORACLE_HOME/network/admin/sqlnet.ora.new; mv  
$ORACLE_HOME/network/admin/sqlnet.ora.new $ORACLE_HOME/network/admin/sqlnet.ora; else  
echo SQLNET.CRYPTO_CHECKSUM_TYPES_CLIENT=(SHA1\)>>  
$ORACLE_HOME/network/admin/sqlnet.ora; fi
```

5.1.7 Encryption algorithm/strength of server-to-client connections (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `SQLNET.ENCRYPTION_TYPES_SERVER` setting in `sqlnet.ora` requires specific encryption algorithms to be used for database server connections, which can include varying strengths of DES, 3DES, and RC4.

Rationale:

As the lack of encryption on connection requests could make data traffic vulnerable network sniffers, the encryption capability should be set at a high enough value, greater than or equal to a 128-bit key to ensure privacy, according to the needs of the organization.

Audit:

```
$ grep SQLNET.ENCRYPTION_TYPES_SERVER \
  $ORACLE_HOME/network/admin/sqlnet.ora
```

Remediation:

```
$ if [ "`grep -i '^SQLNET.ENCRYPTION_TYPES_SERVER=.*'
$ORACLE_HOME/network/admin/sqlnet.ora`" ]; then awk '/^
SQLNET.ENCRYPTION_TYPES_SERVER/ { $1 = " SQLNET.ENCRYPTION_TYPES_SERVER=\ (rc4_128,
rc4_256, 3des_168\)" } {print}' <$ORACLE_HOME/network/admin/sqlnet.ora>
$ORACLE_HOME/network/admin/sqlnet.ora.new; mv
$ORACLE_HOME/network/admin/sqlnet.ora.new $ORACLE_HOME/network/admin/sqlnet.ora; else
echo SQLNET.ENCRYPTION_TYPES_SERVER=\ (rc4_128, rc4_256, 3des_168\)>>
$ORACLE_HOME/network/admin/sqlnet.ora; fi
```

5.1.8 Encryption algorithm/strength of client-to-server connections (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `SQLNET.ENCRYPTION_TYPES_CLIENT` setting in `sqlnet.ora` requires specific encryption algorithms to be used for database server connections, which can include varying strengths of DES, 3DES, and RC4.

Rationale:

As the lack of encryption on connection requests could make data traffic vulnerable to network sniffers, the encryption capability should be set at a high enough value, greater than or equal to a 128-bit key to ensure privacy, according to the needs of the organization.

Audit:

```
$ grep SQLNET.ENCRYPTION_TYPES_CLIENT \ $ORACLE_HOME/network/admin/sqlnet.ora
```

Remediation:

```
$ if [ "`grep -i '^SQLNET.ENCRYPTION_TYPES_CLIENT=.*' $ORACLE_HOME/network/admin/sqlnet.ora`" ]; then awk '/^SQLNET.ENCRYPTION_TYPES_CLIENT/{ $1 = " SQLNET.ENCRYPTION_TYPES_CLIENT=(rc4_128, rc4_256, 3des_168\)" } {print}' <$ORACLE_HOME/network/admin/sqlnet.ora> $ORACLE_HOME/network/admin/sqlnet.ora.new; mv $ORACLE_HOME/network/admin/sqlnet.ora.new $ORACLE_HOME/network/admin/sqlnet.ora; else echo SQLNET.ENCRYPTION_TYPES_CLIENT=(rc4_128, rc4_256, 3des_168\)>> $ORACLE_HOME/network/admin/sqlnet.ora; fi
```

5.1.9 Secure Sockets Layer (SSL) version setting in sqlnet.ora (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `SSL_VERSION` setting in `sqlnet.ora` requires the use of a specific release level/version of SSL to make valid connections using this type of encryption.

Rationale:

As versions of SSL earlier than 3.0 were known to have potential weaknesses in their algorithms, this value should be set according to the needs of the organization.

Audit:

```
$ grep SSL_VERSION $ORACLE_HOME/network/admin/sqlnet.ora
```

Remediation:

```
$ if [ "`grep -i '^SSL_VERSION=.*' $ORACLE_HOME/network/admin/sqlnet.ora`" ]; then awk '/^SSL_VERSION/{ $1 = "SSL_VERSION=3.0" } {print}' <$ORACLE_HOME/network/admin/sqlnet.ora> $ORACLE_HOME/network/admin/sqlnet.ora.new; mv $ORACLE_HOME/network/admin/sqlnet.ora.new $ORACLE_HOME/network/admin/sqlnet.ora; else echo SSL_VERSION=3.0>> $ORACLE_HOME/network/admin/sqlnet.ora; fi
```

5.1.10 Secure Sockets Layer (SSL) cipher suites in sqlnet.ora (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `SSL_CIPHER_SUITES` setting in `sqlnet.ora` requires the use of specific encryption algorithms and varying key strength for SSL to make valid connections and can include DES (40/56-bits) up to AES (128/256-bits).

Rationale:

As legacy versions of SSL cipher suites are known to have potential weaknesses in their algorithms due to inadequate key length, these values should be set at $X \geq 128$ bits, according to the needs of the organization.

Audit:

```
$ grep SSL_CIPHER_SUITES $ORACLE_HOME/network/admin/sqlnet.ora
```

Remediation:

```
$ if [ "`grep -i '^SSL_CIPHER_SUITES=.*' $ORACLE_HOME/network/admin/sqlnet.ora`" ];  
then awk '/^SSL_CIPHER_SUITES/ { $1 =  
"SSL_CIPHER_SUITES=(SSL_RSA_WITH_3DES_EDE_CBC_SHA, SSL_RSA_WITH_RC4_128_SHA,  
SSL_DH_anon_WITH_3DES_EDE_CBC_SHA, SSL_RSA_WITH_AES_128_CBC_SHA,  
SSL_RSA_WITH_AES_256_CBC_SHA\)" } {print}' <$ORACLE_HOME/network/admin/sqlnet.ora>  
$ORACLE_HOME/network/admin/sqlnet.ora.new; mv  
$ORACLE_HOME/network/admin/sqlnet.ora.new $ORACLE_HOME/network/admin/sqlnet.ora; else  
echo SSL_CIPHER_SUITES=(SSL_RSA_WITH_3DES_EDE_CBC_SHA, SSL_RSA_WITH_RC4_128_SHA,  
SSL_DH_anon_WITH_3DES_EDE_CBC_SHA, SSL_RSA_WITH_AES_128_CBC_SHA,  
SSL_RSA_WITH_AES_256_CBC_SHA\)>> $ORACLE_HOME/network/admin/sqlnet.ora; fi
```

5.1.11 SSL certificate Distinguished Name (DN) in sqlnet.ora (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `SSL_SEVER_CERT_DN` setting in `sqlnet.ora` provides the full Distinguished Name (DN) used in formal certificate identification, which is provided by a Certificate Authority (CA). The DN contains all of the individual names of the parent entries, going back to the root entry of the directory tree, such as CN=(Common Name), OU=(Organizational Unit),

O=(Organization), L=(Location), ST=(State/Province), C=(Country), and DC=(Directory Context). This information helps block site masquerading.

Rationale:

As the Distinguished Name provided by the Certificate Authority can help prevent site masquerading and traffic interception via host impersonation, this value should be set according to the needs of the organization.

Audit:

```
$ grep SSL_SEVER_CERT_DN $ORACLE_HOME/network/admin/tnsnames.ora
```

Remediation:

This script assumes the existence of the "net_service_name" in the tnsnames.ora "SECURITY" section.

```
$ if [ "`grep -i '^SSL_CERT_DN=.*' $ORACLE_HOME/network/admin/tnsnames.ora`" ]; then  
awk '/^SSL_CERT_DN/ { $1 = "\\(CN=$ORACLE_HOST, OU=SomeOU, C=OrgCountry, DC=some,  
DC=orgname, DC=com\\)\\)\\)" } {print}' <$ORACLE_HOME/network/admin/tnsnames.ora>  
$ORACLE_HOME/network/admin/tnsnames.ora.new; mv  
$ORACLE_HOME/network/admin/tnsnames.ora.new $ORACLE_HOME/network/admin/tnsnames.ora;  
else echo "(CN=$ORACLE_HOST, OU=SomeOU, C=OrgCountry, DC=some, DC=orgname, DC=com))"  
>> $ORACLE_HOME/network/admin/tnsnames.ora; fi
```

5.1.12 SSL Client certificate usage requirements in sqlnet.ora (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `SSL_CLIENT_AUTHENTICATION` setting in `sqlnet.ora` determines whether or not the client is required to authenticate connection requests using SSL.

Rationale:

As strong identification procedures may have limited impact on security unless the data transmission method used during the user connection procedures is equally robust, this value should be set according to the needs of the organization.

Audit:

```
$ grep SSL_CLIENT_AUTHENTICATION \ $ORACLE_HOME/network/admin/sqlnet.ora
```

Remediation:

```
if [ "`grep -i '^SSL_CLIENT_AUTHENTICATION=.*' $ORACLE_HOME/network/admin/sqlnet.ora`" ]; then awk '/^SSL_CLIENT_AUTHENTICATION/ { $1 = "SSL_CLIENT_AUTHENTICATION=TRUE" } {print}' <$ORACLE_HOME/network/admin/sqlnet.ora> $ORACLE_HOME/network/admin/sqlnet.ora.new; mv $ORACLE_HOME/network/admin/sqlnet.ora.new $ORACLE_HOME/network/admin/sqlnet.ora; else echo SSL_CLIENT_AUTHENTICATION=TRUE >> $ORACLE_HOME/network/admin/sqlnet.ora; fi
```

5.1.13 SSL certificate revocation check requirements in sqlnet.ora (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `SSL_CERT_REVOCATION` setting in `sqlnet.ora` determines whether or not certificate revocation checks are required to confirm client certificate authenticity prior to client connections.

Rationale:

As the absence of a confirmation on the current status of a Client certificate can mean that the client is no longer authorized to connect to or receive data, this value should be set according to the needs of the organization.

Audit:

```
$ grep SSL_CERT_REVOCATION \ $ORACLE_HOME/network/admin/sqlnet.ora
```

Remediation:

```
$ if [ "`grep -i '^SSL_CERT_REVOCATION=.*' $ORACLE_HOME/network/admin/sqlnet.ora`" ]; then awk '/^SSL_CERT_REVOCATION/ { $1 = "SSL_CERT_REVOCATION=REQUIRED" } {print}' <$ORACLE_HOME/network/admin/sqlnet.ora> $ORACLE_HOME/network/admin/sqlnet.ora.new; mv $ORACLE_HOME/network/admin/sqlnet.ora.new $ORACLE_HOME/network/admin/sqlnet.ora; else echo SSL_CERT_REVOCATION=REQUIRED >> $ORACLE_HOME/network/admin/sqlnet.ora; fi
```

5.1.14 SSL certificate Distinguished Name check in sqlnet.ora (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `SSL_SERVER_DN_MATCH` setting in `sqlnet.ora` determines whether or not the Distinguished Name (DN) in the certificate matches the database server's DN.

Rationale:

As the absence of a confirmation of match between the DN for the certificate and the host it resides on can mean tampering with the SSL certificates or the host, with key values in the non-matching certificate being possibly fraudulent or otherwise exposed, this value should be set according to the needs of the organization.

Audit:

```
$ grep SSL_SERVER_DN_MATCH \ $ORACLE_HOME/network/admin/sqlnet.ora
```

Remediation:

```
$ if [ "`grep -i '^SSL_SERVER_DN_MATCH=.*' \ $ORACLE_HOME/network/admin/sqlnet.ora`"
]; then awk \ '/^SSL_SERVER_DN_MATCH/ { $1 = "SSL_SERVER_DN_MATCH=YES" } {print}'
<$ORACLE_HOME/network/admin/sqlnet.ora> \ $ORACLE_HOME/network/admin/sqlnet.ora.new; \
mv $ORACLE_HOME/network/admin/sqlnet.ora.new \ $ORACLE_HOME/network/admin/sqlnet.ora;
else echo \ SSL_SERVER_DN_MATCH=YES >> \ $ORACLE_HOME/network/admin/sqlnet.ora; fi
```

5.2 FIPS-compliant communications setting in `fips.ora` (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `SSLFIPS_140` setting in `sqlnet.ora` enables/disables the requirement for applying the FIPS 140-2 standard to the database server's communications; FIPS must be enabled on both server and client for this to be effective.

Rationale:

As the application of increasing levels of FIPS 140-2 can provide increasing levels of security, including authentication, encryption, and operational conditions, this capability should be set according to the needs of the organization.

Audit:

```
$grep SSL_140 $ORACLE_HOME/network/admin/sqlnet.ora
```

Remediation:

```
$ if [ "`grep -i '^SSL_140=.*' $ORACLE_HOME/network/admin/sqlnet.ora`" ]; then awk
'/^SSL_140/ { $1 = "SSL_140=TRUE" } {print}' <$ORACLE_HOME/network/admin/sqlnet.ora>
$ORACLE_HOME/network/admin/sqlnet.ora.new; mv $ORACLE_HOME/
network/admin/sqlnet.ora.new $ORACLE_HOME/network/admin/sqlnet.ora; else echo
SSL_140=TRUE >> $ORACLE_HOME/network/admin/sqlnet.ora; fi
```

5.3 Certificate-request key size in the Oracle wallet (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle wallet is an encrypted container for storing authentication and/or signing credentials, which can include passwords, the Transparent Data Entry (TDE) master key, PKI private keys, certificates, and trusted certificates needed by SSL. The wallet can be easily configured by using the command-line sequence "\$owm" to start the Java-based GUI tool for configuration.

Rationale:

As a lack of encryption strength for the various keys associated with connection requests and data table encryption could make data more vulnerable to unauthorized access, this value should be set at a high enough value to serve the needs of the organization.

Audit:

```
$ orapki cert display -cert /certificate/path/name/cert.txt -complete
```

Remediation:

Launch the GUI utility to create certificates with a bit value >= 2048 value with the command:

```
$ owm &
```

OR via CLI script:

```
$ orapki wallet add -wallet /your/walletpath/location -dn 'CN=whatever, C=wherever' -
keysize (GE 2048)
```

5.4 Auto-login to the Oracle wallet for SSL connections (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle `wallet`, an encrypted container for storing authentication and/or signing credentials, can be enabled for automatic PKI-based access to services, allowing single sign-on (SSO) access to multiple Oracle databases, without requiring multiple password entries.

Rationale:

As the wallet storage is a secure, centralized location for encryption certificates and can facilitate single sign-on processes by using the "auto-login" feature, which restricts configuration access to the wallet to the user who created it, this value should be set at a according to the needs of the organization.

Audit:

```
Check the auto-login box using the Oracle wallet manager GUI
```

Remediation:

```
Check the box for auto-login after launching the Oracle Wallet Manager GUI
```

```
$ owm &
```

```
OR:
```

```
Use the following script to create a new wallet with auto-login
```

```
$ orapki wallet create -wallet \  
/your/walletpath/location -auto_login
```

6 Oracle client/user connection and login restrictions

The restrictions on Client/User connections to the Oracle database help block unauthorized access to data and services by setting access rules; these security measures help to ensure that successful logins cannot be easily made through brute-force password attacks or intuited by clever social engineering exploits. By the use of the base profile, e.g. "DEFAULT," then assigning this profile to a client, the database administrator can set a standard policy for password security/resource use to all users assigned the 'DEFAULT' profile; however, this policy can still be overridden by local policy. All values assigned below are the recommended minimums or maximums; higher, more restrictive values can be applied at the discretion of the organization by creating a separate profile to assign to a different user group.

6.1 Rejected - Database Profile

Set and define database profiles for the different use cases (personal user vs. technical account vs. DBA account)

6.2 Restrictions on failed login attempts via the default DB profile (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `failed_login_attempts` setting determines how many failed login attempts are permitted before the system locks the user's account. While different profiles can have different and more restrictive settings, such as `USERS` and `APPS`, the minimum(s) recommended here should be set on the `DEFAULT` profile.

Rationale:

As repeated failed login attempts can indicate the initiation of a brute-force login attack, this value should be set according to the needs of the organization (see **warning** below on a known bug that can make this security measure backfire).

Audit:

```
SQL> SELECT PROFILE, RESOURCE_NAME, LIMIT FROM DBA_PROFILES WHERE PROFILE='DEFAULT'
AND RESOURCE_NAME='FAILED_LOGIN_ATTEMPTS';
```

Remediation:

```
SQL> ALTER PROFILE DEFAULT LIMIT FAILED_LOGIN_ATTEMPTS 5;
```

6.3 Requirements for account locking via on the default DB profile (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `PASSWORD_LOCK_TIME` setting determines how many days must pass for the user's account to be unlocked after the set number of failed login attempts has occurred.

Rationale:

As locking the user account after repeated failed login attempts can block further brute-force login attacks, but can create administrative headaches as this account unlocking process always requires DBA intervention, this value should be set according to the needs of the organization.

Audit:

```
SQL> SELECT PROFILE, RESOURCE_NAME, LIMIT FROM DBA_PROFILES WHERE PROFILE='DEFAULT'
AND RESOURCE_NAME='PASSWORD_LOCK_TIME';
```

Remediation:

```
SQL> ALTER PROFILE DEFAULT LIMIT PASSWORD_LOCK_TIME 1;
```

6.4 Restrictions on password duration via the default DB profile (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `password_life_time` setting determines how long a password may be used before the user is required to be change it.

Rationale:

As allowing passwords to remain unchanged for long periods makes the success of brute-force login attacks more likely, this value should be set according to the needs of the organization.

Audit:

```
SQL> SELECT PROFILE, RESOURCE_NAME, LIMIT FROM DBA_PROFILES WHERE PROFILE='DEFAULT'
AND RESOURCE_NAME='PASSWORD_LIFE_TIME';
```

Remediation:

```
SQL> ALTER PROFILE DEFAULT LIMIT PASSWORD_LIFE_TIME 90;
```

6.5 Restrictions on password history via the default DB profile (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `password_reuse_max` setting determines how many different passwords must be used before the user is allowed to reuse a prior password.

Rationale:

As allowing reuse of a password within a short period of time after the password's initial use can make the success of both social-engineering and brute-force password-based attacks more likely, this value should be set according to the needs of the organization.

Audit:

```
SQL> SELECT PROFILE, RESOURCE_NAME, LIMIT FROM DBA_PROFILES WHERE PROFILE='DEFAULT'
AND RESOURCE_NAME='PASSWORD_REUSE_MAX';
```

Remediation:

```
SQL> ALTER PROFILE DEFAULT LIMIT PASSWORD_REUSE_MAX 20;
```

6.6 Restrictions on password use (reuse) via a DB profile (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `password_reuse_time` setting determines the amount of time in days that must pass before the same password may be reused.

Rationale:

As reusing the same password after only a short period of time has passed makes the success of brute-force login attacks more likely, this value should be set according to the needs of the organization.

Audit:

```
SQL> SELECT PROFILE, RESOURCE_NAME, LIMIT FROM DBA_PROFILES WHERE PROFILE='DEFAULT'AND
RESOURCE_NAME='PASSWORD_REUSE_TIME';
```

Remediation:

```
SQL> ALTER PROFILE DEFAULT PASSWORD_REUSE_TIME 365;
```

6.7 Requirements for account locking (grace time) via a DB profile (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `password_grace_time` setting determines how many days can pass after the user's password expires before the user's login capability is automatically locked out.

Rationale:

As locking the user account after the expiration of the password change requirement's grace period can help prevent password-based attack against a forgotten or disused accounts, while still allowing the account and its information to be accessible by DBA intervention, this value should be set according to the needs of the organization.

Audit:

```
SQL> SELECT PROFILE, RESOURCE_NAME, LIMIT FROM DBA_PROFILES WHERE PROFILE='DEFAULT'AND  
RESOURCE_NAME='PASSWORD_GRACE_TIME';
```

Remediation:

```
SQL> ALTER PROFILE DEFAULT PASSWORD_GRACE_TIME 5;
```

6.8 Requirements for limiting EXTERNAL user login capability (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `password='EXTERNAL'` setting determines whether or not a user can be authenticated by a remote OS to allow access to the database with full authorization.

Rationale:

As allowing remote OS authentication of a user to the database can potentially allow supposed "privileged users" to connect as "authenticated," even when the remote system is

compromised, these logins should be disabled/restricted according to the needs of the organization.

Audit:

```
SQL> SELECT USERNAME FROM DBA_USERS WHERE AUTHENTICATION_TYPE='EXTERNAL';
```

Remediation:

```
SQL> ALTER USER username IDENTIFIED BY password;
```

6.9 Requirement for setting the password verification function (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `password_verify_function` determines password settings requirements when a user password is changed at the SQL command prompt.

Rationale:

As requiring users to apply the 11gr2 security features in password creation, such as forcing mixed-case complexity, the blocking of simple combinations, and change/history settings can potentially thwart logins by unauthorized users, this function should be applied/enabled according to the needs of the organization.

Audit:

```
SQL> SELECT PROFILE, RESOURCE_NAME FROM DBA_PROFILES WHERE  
RESOURCE_NAME='PASSWORD_VERIFY_FUNCTION';
```

Remediation:

Change the 'utlpwdmg.sql' script to require users to apply the 'CIS_utlpwdmg.sql' requirements to new password creation from the SQL command line as given above by putting the following at the bottom of the file:

PASSWORD_GRACE_TIME 5

PASSWORD_REUSE_TIME 365

PASSWORD_REUSE_MAX 20

FAILED_LOGIN_ATTEMPTS 5

PASSWORD_LOCK_TIME 1

6.10 Rejected - Requirements for limiting user CPU resource allocations (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5
- Level 2 - 11.2 on Oracle Linux 5

Description:

The `CPU_PER_SESSION` setting determines how much access time the user's request is granted for access to the CPU's resources; it is measured in hundredth of seconds.

Rationale:

As limiting the amount of time a request can access the CPU will help prevent poorly formed requests or intentional Denial-of-Service attacks from monopolizing CPU resources, this value should be set according to the needs of the organization.

Audit:

```
SQL> SELECT PROFILE, RESOURCE_NAME, LIMIT FROM DBA_PROFILES WHERE  
RESOURCE_NAME='CPU_PER_SESSION' AND PROFILE='DEFAULT';
```

Remediation:

```
SQL> ALTER PROFILE DEFAULT LIMIT CPU_PER_SESSION 6000.
```

6.11 Rejected - Requirements for limiting System Global Area resources (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5
- Level 2 - 11.2 on Oracle Linux 5

Description:

The `PRIVATE_SGA` (Private System Global Area) setting determines how large the maximum number integer bytes can grow to become in the private space of the SGA.

Rationale:

As limiting the size of the `PRIVATE_SGA` can help prevent memory resource exhaustion by poorly formed requests or intentional Denial-of-Service attacks, this value should be set according to the needs of the organization.

Audit:

```
SQL> SELECT PROFILE, RESOURCE_NAME, LIMIT FROM DBA_PROFILES WHERE  
RESOURCE_NAME='PRIVATE_SGA' AND PROFILE='DEFAULT';
```

Remediation:

```
SQL> ALTER PROFILE DEFAULT LIMIT PRIVATE_SGA 25K;
```

6.12 Rejected - Requirements for limiting amount of disk-access per session (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5
- Level 2 - 11.2 on Oracle Linux 5

Description:

The `LOGICAL_READS_PER_SESSION` (Read limitations for disk access) setting determines the maximum number of database blocks that are allowed to be read per session.

Rationale:

As limiting the number of the `LOGICAL_READS_PER_SESSION` can help prevent memory resource exhaustion by poorly formed requests or intentional Denial-of-Service attacks, this value should be set according to the needs of the organization.

Audit:

```
SQL> SELECT PROFILE, RESOURCE_NAME, LIMIT FROM DBA_PROFILES WHERE  
RESOURCE_NAME='LOGICAL_READS_PER_SESSION' AND PROFILE='DEFAULT';
```

Remediation:

```
SQL> ALTER PROFILE DEFAULT LIMIT LOGICAL_READS_PER_SESSION 50000;
```


6.13 Requirements for limiting the number of sessions per user (Scored)

Profile Applicability:

- Level 2 - 11.2 on Oracle Linux 5

Description:

The `SESSIONS_PER_USER` (Number of sessions allowed) determines the maximum number of user sessions that are allowed to be open concurrently.

Rationale:

As limiting the number of the `SESSIONS_PER_USER` can help prevent memory resource exhaustion by poorly formed requests or intentional Denial-of-Service attacks, this value should be set according to the needs of the organization.

Audit:

```
SQL> SELECT PROFILE, RESOURCE_NAME, LIMIT FROM DBA_PROFILES WHERE  
RESOURCE_NAME='SESSIONS_PER_USER' AND PROFILE='DEFAULT';
```

Remediation:

```
SQL> ALTER PROFILE DEFAULT LIMIT SESSIONS_PER_USER 10;
```

6.14 Rejected - Requirements for limiting the connect time for users (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5
- Level 2 - 11.2 on Oracle Linux 5

Description:

The `CONNECT_TIME` (Duration of user sessions) determines the maximum number of minutes that a user session, active or idle, can be maintained before it is closed.

Rationale:

As limiting the `CONNECT_TIME` can help prevent database resource exhaustion by abandoned sessions or intentional Denial-of-Service attacks, this value should be set according to the needs of the organization.

Audit:

```
SQL> SELECT PROFILE, RESOURCE_NAME, LIMIT FROM DBA_PROFILES WHERE  
RESOURCE_NAME='CONNECT_TIME' AND PROFILE='DEFAULT';
```

Remediation:

```
SQL> ALTER PROFILE DEFAULT LIMIT CONNECT_TIME 60
```

6.15 Rejected - Requirements for limiting the idle time for users (Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5
- Level 2 - 11.2 on Oracle Linux 5

Description:

The `IDLE_TIME` (Duration of user sessions) determines the maximum number of minutes that a user session can be maintained without new input before it is closed.

Rationale:

As limiting the `IDLE_TIME` can help prevent database resource exhaustion by setting limits on apparently abandoned sessions or intentional Denial-of-Service attacks, this value should be set according to the needs of the organization.

Audit:

```
SQL> SELECT PROFILE, RESOURCE_NAME, LIMIT FROM DBA_PROFILES WHERE  
RESOURCE_NAME='IDLE_TIME' AND PROFILE='DEFAULT';
```

Remediation:

```
SQL> ALTER PROFILE DEFAULT LIMIT IDLE_TIME 60
```

7 Oracle user access and authorization restrictions

The capability to use database resources at a given level, or user authorization rules, allows for user manipulation of the various parts of the Oracle database; these authorizations must be structured to block unauthorized use and/or corruption of vital data and services, by setting restrictions on user capabilities, particularly those of the user PUBLIC; these security measures help to ensure that successful logins cannot be easily redirected.

7.1 Default Public Privileges for Packages and Object Types

Revoke default public execute privileges from powerful packages and object types

7.1.1 Privilege access for the DBMS_OBFUSCATION_TOOLKIT (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `DBMS_OBFUSCATION_TOOLKIT` settings provide one of the tools that determine the strength of the encryption algorithm used to encrypt application data and is part of the SYS schema. The DES (56-bit key) and 3DES (168-bit key) are the only two types available.

Rationale:

As allowing the PUBLIC user privileges to access this capability can be potentially harm the data storage, this access should be set according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE, TABLE_NAME FROM DBA_TAB_PRIVS WHERE  
TABLE_NAME='DBMS_OBFUSCATION_TOOLKIT';
```

Remediation:

```
SQL> REVOKE EXECUTE ON DBMS_OBFUSCATION_TOOLKIT FROM PUBLIC;
```

7.1.2 Privilege access for the DBMS_CRYPTO package (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The `DBMS_CRYPTO` settings provide a toolset that determines the strength of the encryption algorithm used to encrypt application data and is part of the SYS schema. The DES (56-bit key), 3DES (168-bit key), 3DES-2KEY (112-bit key), AES (128/192/256-bit keys), and RC4 are available.

Rationale:

As execution of these cryptography procedures by the user PUBLIC can potentially endanger portions of or all of the data storage, this value should be set according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE, TABLE_NAME FROM DBA_TAB_PRIVS WHERE  
TABLE_NAME='DBMS_CRYPTO_TOOLKIT';
```

Remediation:

```
SQL> REVOKE EXECUTE ON DBMS_CRYPTO_TOOLKIT FROM PUBLIC;
```

7.1.3 Limiting user access to the UTL_FILE package (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database UTL_FILE package can be used to read/write files located on the server where the Oracle instance is installed.

Rationale:

As use of the UTL_FILE package could allow an unauthorized user to corrupt operating system files on the instance's host, use of this package should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS where TABLE_NAME='UTL_FILE' AND  
GRANTEE NOT LIKE ('%SYS%');
```

Remediation:

```
SQL> REVOKE EXECUTE ON UTL_FILE FROM <grantee>;
```

7.1.4 Limiting user access to the UTL_TCP package (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `UTL_TCP` package can be used to read/write file to TCP sockets on the server where the Oracle instance is installed.

Rationale:

As use of the `UTL_TCP` package could allow an unauthorized user to corrupt the TCP stream used for carry the protocols that communicate with the instance's external communications, use of this package should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS WHERE TABLE_NAME='UTL_TCP';
```

Remediation:

```
SQL> REVOKE EXECUTE ON UTL_TCP FROM <grantee>;
```

7.1.5 Limiting user access to the DBMS_JOB package (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `DBMS_JOB` package schedules and manages the jobs sent to the job queue and has been superseded by the `DBMS_SCHEDULER` package, even though `DBMS_JOB` has been retained for backwards compatibility.

Rationale:

As use of the `DBMS_JOB` package could allow an unauthorized user to disable or overload the job queue and has been superseded by the `DBMS_SCHEDULER` package, this package should be disabled or restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS WHERE TABLE_NAME='DBMS_JOB' AND PRIVILEGE='EXECUTE';
```

Remediation:

```
SQL> REVOKE EXECUTE ON DBMS_JOB FROM <grantee>;
```

7.1.6 Limiting user access to the DBMS_SQL package (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `DBMS_SQL` package is shipped as undocumented and is used for replication and other products such as WebDB, providing cursor access as the user.

Rationale:

As use of the `DBMS_SQL` package could allow an unauthorized user to access the cursor during a operations, effectively gaining whatever user privileges are associated with it, use of this package should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS where TABLE_NAME='DBMS_SQL';
```

Remediation:

```
SQL> REVOKE EXECUTE ON DBMS_SQL FROM <grantee>;
```

7.1.7 Limit public access to the DBMS_RANDOM (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `DBMS_RANDOM` package is used for generating random numbers but should not be used for cryptographic purposes.

Rationale:

As assignment of use of the `DBMS_RANDOM` package can allow the unauthorized application of the random number-generating function, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE FROM DBA_TAB_PRIVS WHERE TABLE_NAME= 'DBMS_RANDOM';
```

Remediation:

```
SQL> REVOKE EXECUTE ON DBMS_BACKUP_RESTORE FROM <grantee>;
```

7.1.8 Limiting user access to the DBMS_LOB package (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `DBMS_LOB` package provides subprograms that can manipulate and read/write on BLOBs, CLOBs, NCLOBs, BFILEs, and temporary LOBs.

Rationale:

As use of the `DBMS_LOB` package could allow an unauthorized user to manipulate BLOBs, CLOBs, NCLOBs, BFILEs, and temporary LOBs on the instance, either destroying data or causing a Denial-of-Service condition due to corruption of disk space, use of this package should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS where TABLE_NAME='DBMS_LOB' AND  
GRANTEE NOT LIKE ('%SYS%');
```

Remediation:

```
REVOKE EXECUTE ON DBMS_LOB FROM <grantee>;
```

7.1.9 Limiting user access to the UTL_SMTP package (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `UTL_SMTP` package can be used to send email from the server where the Oracle instance is installed.

Rationale:

As use of the `UTL_SMTP` package could allow an unauthorized user to corrupt the SMTP function to accept or generate junk mail that can result in a Denial-of-Service condition due

to network saturation, use of this package should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS where TABLE_NAME='UTL_SMTP' and  
GRANTEE IN ('PUBLIC');
```

Remediation:

```
SQL> REVOKE EXECUTE ON UTL_SMTP FROM <grantee>;
```

7.1.10 Limiting user access to the UTL_HTTP package (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `UTL_HTTP` package can be used to read/write file to web-based applications on the server where the Oracle instance is installed.

Rationale:

As use of the `UTL_HTTP` package could allow an unauthorized user to corrupt the HTTP stream used for carry the protocols that communicate with the instance's web-based external communications, use of this package should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS where TABLE_NAME='UTL_HTTP' AND  
GRANTEE NOT LIKE ('%SYS%');
```

Remediation:

```
SQL> REVOKE EXECUTE ON UTL_HTTP FROM <grantee>;
```

7.1.11 Limiting user access to the DBMS_SCHEDULER package (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `DBMS_SCHEDULER` package schedules and manages the jobs .

Rationale:

As use of the `DBMS_JOB` package could allow an unauthorized user to disable or overload the job queue and has been superseded by the `DBMS_SCHEDULER` package, this package should be disabled or restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS WHERE TABLE_NAME='DBMS_SCHEDULER'
AND PRIVILEGE='EXECUTE' ;
```

Remediation:

- SQL> REVOKE EXECUTE ON DBMS_SCHEDULER FROM <grantee>;

7.1.12 Limiting user access to the HTTPURITYPE (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `HTTPURITYPE` object type can be used to perform HTTP-requests. This could be used to send information to the outside.

Rationale:

tbd.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS where TABLE_NAME='HTTPURITYPE' AND
GRANTEE NOT LIKE ('%SYS%') ;
```

Remediation:

```
SQL> REVOKE EXECUTE ON HTTPURITYPE FROM <grantee>;
```

7.1.13 Limiting user access to the DBMS_ADVISOR package (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database DBMS_ADVISOR package can be used to write files located on the server where the Oracle instance is installed.

Rationale:

As use of the DBMS_ADVISOR package could allow an unauthorized user to corrupt operating system files on the instance's host, use of this package should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS where TABLE_NAME='DBMS_ADVISOR' AND  
GRANTEE NOT LIKE ('%SYS%');
```

Remediation:

```
SQL> REVOKE EXECUTE ON DBMS_ADVISOR FROM <grantee>;
```

7.1.14 Limiting user access to the UTL_INADDR package (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database UTL_INADDR package can be used to create specially crafted error messages or send information via DNS to the outside.

Rationale:

As use of the UTL_INADDR package xxx.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS where TABLE_NAME='UTL_INADDR' AND  
GRANTEE NOT LIKE ('%SYS%');
```

Remediation:

```
SQL> REVOKE EXECUTE ON UTL_INADDR FROM <grantee>;
```

7.1.15 Limiting user access to the DBMS_LDAP package (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `DBMS_LDAP` package can be used to create specially crafted error messages or send information via DNS to the outside.

Rationale:

As use of the `DBMS_LDAP` package xxx.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS where TABLE_NAME='DBMS_LDAP' AND  
GRANTEE NOT LIKE ('%SYS%');
```

Remediation:

```
SQL> REVOKE EXECUTE ON DBMS_LDAP FROM <grantee>;
```

7.1.16 Limiting user access to the DBMS_XMLGEN package (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `DBMS_XMLGEN` package xxx.

Rationale:

As use of the `DBMS_XMLGEN` package cxxx.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS where TABLE_NAME='DBMS_XMLGEN';
```

Remediation:

```
SQL> REVOKE EXECUTE ON DBMS_XMLGEN FROM <grantee>;
```

7.1.17 Limiting user access to the DBMS_JAVA package (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database DBMS_JAVA package can xxx.

Rationale:

As use of the DBMS_JAVA package xxx.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS where TABLE_NAME='DBMS_JAVA' AND  
GRANTEE NOT LIKE ('%SYS%') ;
```

Remediation:

```
SQL> REVOKE EXECUTE ON DBMS_JAVA FROM <grantee>;
```

7.1.18 Limiting user access to the DBMS_JAVA_TEST package (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database DBMS_JAVA_TEST package can xxx.

Rationale:

As use of the DBMS_JAVA_TEST package xxx.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS where TABLE_NAME='DBMS_JAVA_TEST'  
AND GRANTEE NOT LIKE ('%SYS%') ;
```

Remediation:

```
SQL> REVOKE EXECUTE ON DBMS_JAVA_TEST FROM <grantee>;
```

7.1.19 Limiting user access to the DBMS_XMLQUERY package (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database DBMS_XMLQUERY package xxx.

Rationale:

As use of the DBMS_XMLQUERY package cxxx.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS where TABLE_NAME='DBMS_XMLQUERY';
```

Remediation:

```
SQL> REVOKE EXECUTE ON DBMS_XMLQUERY FROM <grantee>;
```

7.1.20 Limiting user access to the UTL_MAIL package (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database UTL_MAIL package can be used to send email from the server where the Oracle instance is installed.

Rationale:

As use of the UTL_MAIL package could allow an unauthorized user to corrupt the SMTP function to accept or generate junk mail that can result in a Denial-of-Service condition due to network saturation, use of this package should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS where TABLE_NAME='UTL_MAIL' and GRANTEE IN ('PUBLIC');
```

Remediation:

```
SQL> REVOKE EXECUTE ON UTL_MAIL FROM <grantee>;
```

7.1.21 Limiting user access to the UTL_DBWS package (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `UTL_DBWS` package can be used to read/write file to web-based applications on the server where the Oracle instance is installed.

Rationale:

As use of the `UTL_DBWS` package could allow an unauthorized user to corrupt the HTTP stream used for carry the protocols that communicate with the instance's web-based external communications, use of this package should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS where TABLE_NAME='UTL_DBWS' AND  
GRANTEE IN ('UTL_DBWS') ;
```

Remediation:

```
SQL> REVOKE EXECUTE ON UTL_DBWS FROM <grantee>;
```

7.1.22 Limiting user access to the UTL_ORAMTS package (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `UTL_ORAMTS` package can be used to read/write file to web-based applications on the server where the Oracle instance is installed.

Rationale:

As use of the `UTL_ORAMTS` package could allow an unauthorized user to corrupt the HTTP stream used for carry the protocols that communicate with the instance's web-based

external communications, use of this package should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS where TABLE_NAME='UTL_ORAMTS' AND  
GRANTEE NOT LIKE ('%SYS%');
```

Remediation:

```
SQL> REVOKE EXECUTE ON UTL_ORAMTS FROM <grantee>;
```

7.2 Non-Default Public Privileges for Packages and Object Types

Non-Default Public Privileges for Packages and Object Types

7.2.1 Limiting public user access to the DBMS_SYS_SQL package (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `DBMS_SYS_SQL` package is shipped as undocumented and is used for replication and other products such as WebDB, providing cursor access as the user.

Rationale:

As use of the `DBMS_SYS_SQL` package could allow an unauthorized user to access the cursor during a operations, effectively gaining whatever user privileges are associated with it, use of this package should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS where TABLE_NAME='DBMS_SYS_SQL';
```

Remediation:

```
SQL> REVOKE EXECUTE ON DBMS_SYS_SQL FROM <grantee>;
```

7.2.2 Limit public access to the DBMS_BACKUP_RESTORE (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `DBMS_BACKUP_RESTORE` package is used for applying PL/SQL commands to the native RMAN sequences.

Rationale:

As assignment of use of the `DBMS_BACKUP_RESTORE` package can allow RMAN backup commands via PL/SQL and potentially compromise database backup media/operations, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE FROM DBA_TAB_PRIVS WHERE TABLE_NAME= 'DBMS_BACKUP_RESTORE'
```

Remediation:

```
SQL> REVOKE EXECUTE ON DBMS_BACKUP_RESTORE FROM <grantee>;
```

7.2.3 Limiting public user access to the DBMS_AQADM_SYSCALLS package (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `DBMS_AQADM_SYSCALLS` package is shipped as undocumented and xxx

Rationale:

As use of the `DBMS_AQADM_SYSCALLS` package could allow an unauthorized user to xxx.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS where  
TABLE_NAME='DBMS_AQADM_SYSCALLS';
```

Remediation:


```
SQL> REVOKE EXECUTE ON DBMS_AQADM_SYSCALLS FROM PUBLIC;
```

7.2.4 Limiting public user access to the DBMS_REPACT_SQL_UTL package (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database DBMS_REPACT_SQL_UTL package is shipped as undocumented and xxx

Rationale:

As use of the DBMS_REPACT_SQL_UTL package could allow an unauthorized user to xxx.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS where  
TABLE_NAME='DBMS_REPACT_SQL_UTL';
```

Remediation:

```
SQL> REVOKE EXECUTE ON DBMS_REPACT_SQL_UTL FROM PUBLIC;
```

7.2.5 Limiting public user access to the INITJVMAUX package (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database INITJVMAUX package is shipped as undocumented and xxx

Rationale:

As use of the INITJVMAUX package could allow an unauthorized user to xxx.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS where TABLE_NAME='INITJVMAUX';
```

Remediation:

SQL> REVOKE EXECUTE ON INITJVMAUX FROM PUBLIC;

7.2.6 Limiting public user access to the DBMS_STREAMS_ADM_UTL package (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database DBMS_STREAMS_ADM_UTL package is shipped as undocumented and xxx

Rationale:

As use of the DBMS_STREAMS_ADM_UTL package could allow an unauthorized user to xxx.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS where  
TABLE_NAME='DBMS_STREAMS_ADM_UTL';
```

Remediation:

SQL> REVOKE EXECUTE ON DBMS_STREAMS_ADM_UTL FROM PUBLIC;

7.2.7 Limiting public user access to the DBMS_AQADM_SYS package (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database DBMS_AQADM_SYS package is shipped as undocumented and xxx

Rationale:

As use of the DBMS_AQADM_SYS package could allow an unauthorized user to xxx.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS where TABLE_NAME='DBMS_AQADM_SYS';
```

Remediation:

```
SQL> REVOKE EXECUTE ON DBMS_AQADM_SYS FROM PUBLIC;
```

7.2.8 Limiting public user access to the DBMS_STREAMS_RPC package (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database `DBMS_STREAMS_RPC` package is shipped as undocumented and xxx

Rationale:

As use of the `DBMS_STREAMS_RPC` package could allow an unauthorized user to xxx.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS where  
TABLE_NAME='DBMS_STREAMS_RPC';
```

Remediation:

```
SQL> REVOKE EXECUTE ON DBMS_STREAMS_RPC FROM PUBLIC;
```

7.2.9 Limiting public user access to the DBMS_AQADM_SYS package (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database `DBMS_AQADM_SYS` package is shipped as undocumented and xxx

Rationale:

As use of the `DBMS_AQADM_SYS` package could allow an unauthorized user to xxx.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS where TABLE_NAME='DBMS_AQADM_SYS';
```

Remediation:

```
SQL> REVOKE EXECUTE ON DBMS_AQADM_SYS FROM PUBLIC;
```

7.2.10 Limiting public user access to the DBMS_PRVTAQIM package (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database `DBMS_PRVTAQIM` package is shipped as undocumented and xxx

Rationale:

As use of the `DBMS_PRVTAQIM` package could allow an unauthorized user to xxx.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS where TABLE_NAME='DBMS_PRVTAQIM';
```

Remediation:

```
SQL> REVOKE EXECUTE ON DBMS_PRVTAQIM FROM PUBLIC;
```

7.2.11 Limiting public user access to the LTADM package (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database `LTADM` package is shipped as undocumented and xxx

Rationale:

As use of the `LTADM` package could allow an unauthorized user to xxx.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS where TABLE_NAME='LTADM';
```

Remediation:

```
SQL> REVOKE EXECUTE ON LTADM FROM PUBLIC;
```

7.2.12 Limiting public user access to the `WWV_DBMS_SQL` package (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database `WWV_DBMS_SQL` package is shipped as undocumented and xxx

Rationale:

As use of the `WWV_DBMS_SQL` package could allow an unauthorized user to xxx.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS where TABLE_NAME='WWV_DBMS_SQL';
```

Remediation:

```
SQL> REVOKE EXECUTE ON WWV_DBMS_SQL FROM PUBLIC;
```

7.2.13 Limiting public user access to the `WWV_EXECUTE_IMMEDIATE` package (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database `WWV_EXECUTE_IMMEDIATE` package is shipped as undocumented and xxx

Rationale:

As use of the `WWV_EXECUTE_IMMEDIATE` package could allow an unauthorized user to xxx.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS where  
TABLE_NAME='WWV_EXECUTE_IMMEDIATE';
```

Remediation:

```
SQL> REVOKE EXECUTE ON WWV_EXECUTE_IMMEDIATE FROM PUBLIC;
```

7.2.14 Limiting public user access to the DBMS_IJOB package (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database DBMS_IJOB package is shipped as undocumented and xxx

Rationale:

As use of the DBMS_IJOB package could allow an unauthorized user to xxx.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS where TABLE_NAME='DBMS_IJOB';
```

Remediation:

```
SQL> REVOKE EXECUTE ON DBMS_IJOB FROM PUBLIC;
```

7.2.15 Limiting public user access to the DBMS_FILE_TRANSFER package (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database DBMS_FILE_TRANSFER package is shipped as undocumented and xxx

Rationale:

As use of the DBMS_FILE_TRANSFER package could allow an unauthorized user to xxx.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME FROM DBA_TAB_PRIVS where  
TABLE_NAME='DBMS_FILE_TRANSFER';
```

Remediation:

```
SQL> REVOKE EXECUTE ON DBMS_FILE_TRANSFER FROM PUBLIC;
```

7.3 System Privileges

Revoke system privileges

7.3.1 Limiting users by restricting the *SELECT ANY DICTIONARY* privilege (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `SELECT ANY DICTIONARY` privilege allows the designated user to access SYS schema objects.

Rationale:

The Oracle database `SELECT ANY DICTIONARY` privilege allows the designated user to access SYS schema objects.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE FROM DBA_SYS_PRIVS where PRIVILEGE='SELECT ANY  
DICTIONARY' AND GRANTEE NOT IN ('DBA','DBSNMP','OLAPSYS','SYSMAN','WM SYS');
```

Remediation:

```
SQL>REVOKE SELECT_ANY_DICTIONARY from <USER/ROLE>;
```

7.3.2 Limiting users by restricting the *SELECT ANY TABLE* privilege (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `SELECT ANY TABLE` privilege allows the designated user to open any table to view it.

Rationale:

As assignment of the `SELECT ANY TABLE` privilege can allow the unauthorized viewing of sensitive data, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE FROM DBA_SYS_PRIVS where PRIVILEGE='SELECT_ANY_TABLE'
and USER not in ('SYS', 'SYSTEM');
```

Remediation:

```
SQL> REVOKE SELECT_ANY_TABLE from <grantee>;
```

7.3.3 Limiting users by restricting the AUDIT SYSTEM privilege (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `AUDIT SYSTEM` privilege allows the change auditing activities on the system.

Rationale:

As assignment of the `AUDIT SYSTEM` privilege can allow the unauthorized alteration of system audit activities, disabling the creation of audit trails, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE FROM DBA_SYS_PRIVS where
PRIVILEGE='AUDIT SYSTEM'AND GRANTEE NOT IN
('DBA', 'DATAPUMP_IMP_FULL_DATABASE', 'IMP_FULL_DATABASE', 'SYS');
```

Remediation:

```
SQL> REVOKE AUDIT SYSTEM from <grantee>;
```


7.3.4 Limiting users by restricting the EXEMPT ACCESS POLICY (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `EXEMPT ACCESS POLICY` keyword provides the user the capability to access all the table rows regardless of row-level security lockouts.

Rationale:

As assignment of the `EXEMPT ACCESS POLICY` privilege can allow an unauthorized user to potentially access/change confidential data, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_SYS_PRIVS WHERE PRIVILEGE='EXEMPT ACCESS POLICY';
```

Remediation:

```
SQL> REVOKE EXEMPT ACCESS POLICY FROM <grantee>;
```

7.3.5 Limiting users by restricting the BECOME USER privilege (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `BECOME USER` privilege allows the designated user to inherit the rights of another user.

Rationale:

As assignment of the `BECOME USER` privilege can allow the unauthorized use of another user's privileges, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE FROM DBA_SYS_PRIVS where PRIVILEGE='BECOME USER' AND  
GRANTEE NOT IN ('DBA','SYS');
```

Remediation:

```
SQL> REVOKE BECOME USER from <grantee>;
```

7.3.6 Limiting users by restricting the CREATE PROCEDURE privilege (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `CREATE PROCEDURE` privilege allows the designated user to create a stored procedure that will fire when given the correct command sequence.

Rationale:

As assignment of the `CREATE PROCEDURE` privilege can lead to severe problems in unauthorized hands, such as rogue procedures facilitating data theft or Denial-of-Service by corrupting data tables, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE FROM DBA_SYS_PRIVS where PRIVILEGE='CREATE PROCEDURE'  
and GRANTEE NOT IN ('CACHEADM',  
'DBA','DBSNMP','MDSYS','OLAPSYS','OWB$CLIENT','OWBSYS','RECOVERY_CATALOG_OWNER','SPATI  
AL_CSW_ADMIN_USR','SPATIAL_WFS_ADMIN_USR','SYS');
```

Remediation:

```
REVOKE CREATE_PROCEDURE from <grantee>;
```

7.3.7 Limiting users by restricting the ALTER SYSTEM privilege (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `ALTER SYSTEM` privilege allows the designated user to dynamically alter the instance's running operations.

Rationale:

As assignment of the `ALTER SYSTEM` privilege can lead to severe problems, such as the instance's session being killed or the stopping of redo log recording, which would make transactions unrecoverable, this capability should be severely restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE FROM DBA_SYS_PRIVS WHERE PRIVILEGE='ALTER SYSTEM' and  
GRANTEE NOT IN ('SYS','SYSTEM');
```

Remediation:

```
SQL> REVOKE ALTER SYSTEM from <grantee>;
```

7.3.8 Limiting users by restricting the CREATE LIBRARY privilege (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `CREATE LIBRARY` privilege allows the designated user to create objects that are associated to the shared libraries.

Rationale:

As assignment of the `CREATE LIBRARY` privilege can allow the creation of numerous library-associated objects and potentially corrupt the libraries' integrity, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_SYS_PRIVS where PRIVILEGE='CREATE LIBRARY' AND GRANTEE NOT IN  
('SYS','SYSTEM','DBA');
```

Remediation:

```
SQL> REVOKE CREATE LIBRARY FROM <grantee>;
```

7.3.9 Limiting users by restricting GRANT ANY OBJECT PRIVILEGE (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `GRANT ANY OBJECT PRIVILEGE` keyword provides the grantee the capability to grant access to any single or multiple combinations of objects to any grantee in the catalog of the database.

Rationale:

As authorization to use the `GRANT ANY OBJECT PRIVILEGE` capability can allow an unauthorized user to potentially access/change confidential data or damage the data catalog due to potential complete instance access, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_SYS_PRIVS WHERE PRIVILEGE='GRANT ANY OBJECT PRIVILEGE' AND  
GRANTEE NOT IN ('DBA','SYS') order by 1;
```

Remediation:

```
SQL> REVOKE GRANT ANY OBJECT PRIVILEGE FROM <grantee>
```

7.3.10 Limiting users by restricting GRANT ANY ROLE (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `GRANT ANY ROLE` keyword provides the grantee the capability to grant any single role to any grantee in the catalog of the database.

Rationale:

As authorization to use the `GRANT ANY ROLE` capability can allow an unauthorized user to potentially access/change confidential data or damage the data catalog due to potential complete instance access, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_SYS_PRIVS WHERE PRIVILEGE='GRANT ANY ROLE' AND GRANTEE NOT IN ('DBA','SYS') order by 1;
```

Remediation:

```
SQL> REVOKE GRANT ANY ROLE FROM <grantee>
```

7.3.11 Limiting users by restricting GRANT ANY PRIVILEGE (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `GRANT ANY PRIVILEGE` keyword provides the grantee the capability to grant any single privilege to any item in the catalog of the database.

Rationale:

As authorization to use the `GRANT ANY PRIVILEGE` capability can allow an unauthorized user to potentially access/change confidential data or damage the data catalog due to potential complete instance access, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_SYS_PRIVS WHERE PRIVILEGE='GRANT ANY PRIVILEGE' AND GRANTEE NOT IN ('DBA','SYS') order by 1;
```

Remediation:

```
SQL> REVOKE GRANT ANY PRIVILEGE FROM <grantee>
```

7.3.12 Limiting users by restricting GRANT ALL PRIVILEGES (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `GRANT ALL PRIVILEGES` keyword provides the user the capability to grant all privileges to any item in the catalog of the database simultaneously.

Rationale:

As authorization to use the `GRANT ALL PRIVILEGES` capability can allow an unauthorized user to potentially access/change confidential data or damage the data catalog due to complete instance access, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_SYS_PRIVS WHERE PRIVILEGE='GRANT_ALL_PRIVILEGES' and GRANTEE not in ('SYS', 'SYSTEM') order by 1;
```

Remediation:

```
SQL> REVOKE GRANT ALL PRIVILEGES FROM <grantee>
```

7.4 Role Privileges

Revoke powerful roles

7.4.1 Limiting user authorizations for the `DELETE_CATALOG_ROLE` (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `DELETE_CATALOG_ROLE` provides `DELETE` privileges for the records in the system's audit table (`AUD$`).

Rationale:

As permitting unauthorized access to the `DELETE_CATALOG_ROLE` can allow the destruction of audit records vital to the forensic investigation of unauthorized activities, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE, TABLE_NAME FROM DBA_TAB_PRIVS WHERE TABLE_NAME LIKE '%CATALOG%' AND PRIVILEGE='DELETE';
```

Remediation:

```
SQL> REVOKE DELETE ON <catalog_table_name> FROM <Non-SYS grantee>;
```

7.4.2 Limiting user authorizations for the SELECT_CATALOG_ROLE (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database SELECT_CATALOG_ROLE provides SELECT privileges on all data dictionary views held in the SYS schema.

Rationale:

As permitting unauthorized access to the SELECT_CATALOG_ROLE can allow the disclosure of all dictionary data, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE, TABLE_NAME FROM DBA_TAB_PRIVS WHERE TABLE_NAME LIKE '%CATALOG%' AND PRIVILEGE='SELECT';
```

Remediation:

```
SQL> REVOKE SELECT ON <catalog_table_name> FROM <Non-SYS grantee>;
```

7.4.3 Limiting user authorizations for the EXECUTE_CATALOG role (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database EXECUTE_CATALOG_ROLE provides EXECUTE privileges for a number of packages and procedures in the data dictionary in the SYS schema.

Rationale:

As permitting unauthorized access to the `EXECUTE_CATALOG_ROLE` can allow the disruption of operations by initialization of rogue procedures, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE, TABLE_NAME FROM DBA_TAB_PRIVS WHERE TABLE_NAME LIKE '%CATALOG%' AND PRIVILEGE='EXECUTE';
```

Remediation:

```
SQL> REVOKE EXECUTE ON <catalog_table_name> FROM <Non-SYS grantee>;
```

7.4.4 Limiting users by restricting the DBA role (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database DBA role is a "sample" database administrator role provided for the allocation of administrative privileges.

Rationale:

As assignment of the DBA role to an ordinary user can provide a great number of unnecessary privileges to that user and opens the door to data breaches, integrity violations, and Denial-of-Service conditions, application of this role should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, GRANTED_ROLE FROM DBA_ROLE_PRIVS WHERE GRANTED_ROLE='DBA' AND GRANTEE NOT IN ('SYS','SYSTEM');
```

Remediation:

```
SQL> REVOKE DBA from <grantee>;
```

7.5 Table and View privileges

Revoke table and view privileges

7.5.1 Limiting authorizations for the SYS.AUD\$ table (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `SYS.AUD$` table contains all the audit records for the database of the non-Data Manipulation Language (DML) events, such as `ALTER`, `DROP`, `CREATE`, and so forth. (DML changes need trigger-based audit events to record data alterations.)

Rationale:

As permitting non-privileged users the authorization to manipulate the `SYS_AUD$` table can allow distortion of the audit records, hiding unauthorized activities, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE FROM DBA_TAB_PRIVS WHERE TABLE_NAME='AUD$';
```

Remediation:

```
SQL> REVOKE ALL ON AUD$ FROM <grantee>;
```

7.5.2 Limiting authorizations for the SYS.USER_HISTORY\$ table (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `SYS.USER_HISTORY$` table contains all the audit records for the user's password change history. (This table gets updated by password changes if the user has an assigned profile that has password reuse limit set, e.g., `PASSWORD_REUSE_TIME` set to other than `UNLIMITED`.)

Rationale:

As permitting non-privileged users the authorization to manipulate the records in the `SYS.USER_HISTORY$` table can allow distortion of the audit trail, potentially hiding

unauthorized data confidentiality attacks or integrity changes, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE FROM DBA_TAB_PRIVS WHERE TABLE_NAME='USER_HISTORY';
```

Remediation:

```
SQL> REVOKE ALL ON USER_HISTORY$ FROM <username>;
```

7.5.3 Limiting authorizations for the SYS.LINK\$ table (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `SYS.LINK$` table contains all the user's password information and data table link information.

Rationale:

As permitting non-privileged users to manipulate or view the `SYS.LINK$` table can allow capture of password information and/or corrupt the primary database linkages, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE FROM DBA_TAB_PRIVS WHERE TABLE_NAME='LINK$';
```

Remediation:

```
SQL> REVOKE ALL ON LINK$ FROM <grantee>;
```

7.5.4 Limiting authorizations for the SYS.USER\$ table (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database `SYS.USER$` table contains the users' hashed password information.

Rationale:

As permitting non-privileged users the authorization to open the `SYS.USER$` table can allow the capture of password hashes for the later application of password cracking algorithms to breach confidentiality, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE FROM DBA_TAB_PRIVS WHERE TABLE_NAME='USER$';
```

Remediation:

```
SQL> REVOKE ALL ON SYS.USER$ FROM <username>;
```

7.5.5 Rejected - Limiting authorizations for the SYS.SOURCE\$ table (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database `SYS.SOURCE$` table contains the linkages between the OBJ\$ (Object ID), LINE (Line Number), and SOURCE (Source code line).

Rationale:

As permitting users the authorization to manipulate the `SYS.USER$` table can render the references to source code in the data dictionary useless and destroy database integrity, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE FROM DBA_TAB_PRIVS WHERE TABLE_NAME='SOURCE$';
```

Remediation:

```
SQL> REVOKE ALL ON SYS.SOURCE$ FROM <username>;
```

7.5.6 Limiting user authorizations for the \$X tables (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database \$X tables are the SQL interface for viewing the database's memory allocations associated with database operations, such as the "cursor," as this process is operationalized in the SGA and the type and number of the tables can vary in number according to the database installation type.

Rationale:

As permitting users the authorization to manipulate the \$X tables can expose sensitive database operations to interference or destruction, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE TABLE_NAME FROM DBA_TAB_PRIVS WHERE TABLE_NAME LIKE ('X$%');
```

Remediation:

```
SQL> REVOKE ALL ON X$ <table_name> FROM <grantee>;
```

7.5.7 Limiting user authorizations for the DBA_% views (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database DBA_ views are the SQL interface for viewing the database's memory allocations associated with database operations, such as the "cursor," as this process is operationalized in the SGA and the type and number of the tables can vary in number according to the database installation type.

Rationale:

As permitting users the authorization to manipulate the DBA_ views can expose sensitive database operations to interference or destruction, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DICT WHERE TABLE_NAME LIKE ('DBA_%') and user not in ('SYS',  
'SYSTEM') ORDER BY TABLE_NAME;
```

Remediation:

```
SQL> REVOKE ALL ON DBA_<table_name> FROM <Non-DBA/SYS grantee>;
```

7.5.8 Limiting user authorizations for the \$V_ views (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database \$v_ views provide a continually updated look at internal database statistics, with 467 possible views in Oracle 11gr2, including all SQL statements running: The V\$ views are sometimes referred to as "Dynamic performance views or tables" for this reason.

Rationale:

As permitting users the authorization to read the \$v_ views can expose sensitive database operations that hold information that can facilitate system attacks, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE, TABLE_NAME FROM DBA_TAB_PRIVS WHERE TABLE_NAME LIKE  
'V$_%' AND GRANTEE NOT IN ('DBA') ORDER BY 1,2;
```

Remediation:

```
SQL> REVOKE ALL ON TABLENAME LIKE 'V$_' FROM <Non-DBA grantee>;
```

7.5.9 Rejected - Limiting user authorizations for the \$V synonym(s) (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database \$v_ synonyms are the pointers used to access the \$v_ views and provide a continually updated look at internal database statistics, with 467 possible views

in Oracle 11gr2, including all SQL statements currently running: The \$v_ views are sometimes referred to as "Dynamic performance views or tables" for this reason.

Rationale:

As permitting users the authorization to read the \$v synonyms can expose sensitive database operations that hold information that can facilitate attacks, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE, TABLE_NAME FROM DBA_TAB_PRIVS WHERE TABLE_NAME LIKE 'V$_%' AND GRANTEE NOT IN ('SYS', 'DBA') ORDER BY 3;
```

Remediation:

```
SQL> REVOKE ALL ON TABLE_NAME LIKE 'V$_' FROM <Non-SYS grantee>;
```

7.5.10 Limiting authorizations for the SCHEDULER\$_CREDENTIAL table (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The Oracle database SCHEDULER\$_CREDENTIAL table contains the database scheduler credential information.

Rationale:

As permitting non-privileged users the authorization to open the SYS.SCHEDULER\$_CREDENTIAL table.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE FROM DBA_TAB_PRIVS WHERE TABLE_NAME='SCHEDULER$_CREDENTIAL';
```

Remediation:

```
SQL> REVOKE ALL ON SYS.SCHEDULER$_CREDENTIAL FROM <username>;
```

7.5.11 Drop table sys.user\$mig (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

The table sys.user\$mig is created during the migration and contains the Oracle password hashes before the migration starts.

Rationale:

The table sys.user\$mig is not deleted after the migration. An attacker could access this table containing the Oracle password hashes.

Audit:

```
select * from all_table where table_name='USER$MIG'
```

Remediation:

```
drop table sys.user$mig;
```

7.6 Other Privileges

Revoke other privileges

7.6.1 Access to ACL privileges (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

Review access to Oracle network ACLs.

Rationale:

Oracle network ACLs control who can connect to which port/ip.

Audit:

Remediation:

Revoke unneeded privileges.

7.7 Limiting user authorizations for the SYSTEM tablespace (Not Scored)

Profile Applicability:

- Level 2 - 11.2 on Oracle Linux 5

Description:

The `SYSTEM` tablespace contains all the basic system objects for the database, such as the data dictionary tables.

Rationale:

As allowing any user other than SYS to use the `SYSTEM` tablespace can potentially allow disk resource exhaustion (Denial-of-Service) conditions to occur or data dictionary corruption, requiring a tablespace reconstruction from backups, authorization to use the `SYSTEM` tablespace should be limited according to the needs of the organization.

Audit:

```
SQL> SELECT USERNAME, DEFAULT_TABLESPACE FROM DBA_USERS WHERE  
DEFAULT_TABLESPACE='SYSTEM';
```

Remediation:

```
SQL> ALTER user DEFAULT_TABLESPACE tablename;
```

7.8 Rejected - Limiting application/developer resources on a tablespace (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5
- Level 2 - 11.2 on Oracle Linux 5

Description:

The production tablespace(s) for users contains all the system space set aside for application users or developers to read/write data to the production database instance.

Rationale:

As allowing any application user or developer user unlimited write capability on an assigned tablespace can potentially allow a disk resource exhaustion (Denial-of-Service) condition, quotas for disk space should set according to the needs of the organization.

Audit:

```
SQL> SELECT USERNAME, TABLESPACE_NAME, BYTES, MAX_BYTES
FROM DBA_TS_QUOTAS WHERE MAX_BYTES = -1 AND TABLESPACE_NAME NOT LIKE 'SYS%' order by
1;

OR (To check for unlimited tablespace on a 'SYS'-type of table:

SQL> SELECT USERNAME, TABLESPACE_NAME, BYTES, MAX_BYTES
FROM DBA_TS_QUOTAS WHERE MAX_BYTES = -1 AND TABLESPACE_NAME LIKE 'SYS%' order by 1;
```

Remediation:

```
SQL> ALTER USER <username> QUOTA <value> ON <tablespace_name>;
```

7.9 Rejected - Limiting authorizations for edition-based upgrade versioning (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle 11gr2 database can have multiple versions of required PL/SQL objects, views, synonyms and triggers within a single schema. This allows database upgrades without significant database down time.

Rationale:

As allowing a non-privileged user the capability to launch the `EDITION` sequence can potentially invalidate all of the PL/SQL code, with the exception of triggers, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE from DBA_SYS_PRIVS where PRIVILEGE LIKE '%EDITION' and
GRANTEE not in ('SYS','DBA');
```

Remediation:

```
SQL> REVOKE <privilege> from <grantee> ;
```

7.10 Rejected - Limiting authorizations for the PERFSTAT.STATS\$SQLTEXT table (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database `PERFSTAT.STATS$SQL_SUMMARY` table contains the full text of all executed SQL statements.

Rationale:

As permitting users the authorization to read the `PERFSTAT.STATS$SQL_SUMMARY` table can expose sensitive information such as schema/tablespace names, user IDs, and valid queries/views, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE FROM DBA_TAB_PRIVS WHERE  
TABLE_NAME=' PERFSTAT.STATS$SQLTEXT';
```

Remediation:

```
SQL> REVOKE ALL ON PERFSTAT.STATS$SQLTEXT FROM <grantee>;
```

7.11 Rejected - Limiting authorizations to PERFSTAT.STATS\$SQL_SUMMARY table (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database `PERFSTAT.STATS$SQL_SUMMARY` table contains the full text of the STATSPACK-generated database activities, which, according to level and threshold setting, can include performance data, rollback data, and many other activity indicators.

Rationale:

As permitting users the authorization to read the `PERFSTAT.STATS$SQL_SUMMARY` table can expose sensitive information such as rollback information, schema/tablespace names, user IDs, and associated queries/views, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE, TABLE_NAME FROM DBA_TAB_PRIVS WHERE  
TABLE_NAME='STATS$SQLSUM';
```

Remediation:

```
SQL> REVOKE ALL ON PERFSTAT.STATS$SQLSUM FROM <grantee>;
```

7.12 Rejected - Limiting user authorizations for the `ALL_SOURCE` view (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database `ALL_SOURCE` view describes the "Text source" of the stored objects available to the current user.

Rationale:

As permitting unauthorized viewing of a user's available text source can expose sensitive data, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE, TABLE_NAME FROM DBA_TAB_PRIVS WHERE  
TABLE_NAME='ALL_SOURCE' AND GRANTEE NOT IN ('DBA') ORDER BY TABLE_NAME;
```

Remediation:

```
SQL> REVOKE ALL ON ALL_SOURCE FROM <Non-DBA grantee>;
```

7.13 Rejected - Limiting user authorizations for the `DBA_ROLES` view (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database `DBA_ROLES` view lists all the roles that exist in the database.

Rationale:

As permitting unauthorized access to the `DBA_ROLES` can allow the alteration of sensitive data or bring down the data instance, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE, TABLE_NAME FROM DBA_TAB_PRIVS WHERE
TABLE_NAME='DBA_ROLES';
```

Remediation:

```
SQL> REVOKE ALL ON DBA_ROLES FROM <Non-dba/SYS grantee>;
```

7.14 Rejected - Limiting user authorizations for the `DBA_SYS_PRIVS` view (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database `DBA_SYS_PRIV` view lists the system privileges granted to users and roles that exist in the database.

Rationale:

As permitting unauthorized access to the `DBA_SYS_PRIV` view can allow the disclosure of sensitive data, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE, TABLE_NAME FROM DBA_TAB_PRIVS WHERE
TABLE_NAME='DBA_SYS_PRIVS';
```

Remediation:

```
SQL> REVOKE ALL ON DBA_SYS_PRIVS FROM <Non-SYS grantee>;
```

7.15 Rejected - Limiting user authorizations for the DBA_ROLE_PRIVS view (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database `DBA_ROLE_PRIVS` view lists the privileges for all the roles that exist in the database.

Rationale:

As permitting unauthorized access to the `DBA_ROLE_PRIV` view can allow the disclosure of sensitive data, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE, TABLE_NAME FROM DBA_TAB_PRIVS WHERE  
TABLE_NAME='DBA_ROLE_PRIVS';
```

Remediation:

```
SQL> REVOKE ALL ON DBA_ROLE_PRIV FROM <Non-SYS/DBA grantee>;
```

7.16 Rejected - Limiting user authorizations for the DBA_TAB_PRIV view (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database `DBA_TAB_PRIV` view lists the user privileges for all the tables that exist in the database.

Rationale:

As permitting unauthorized access to the `DBA_TAB_PRIVS` view can allow the disclosure of sensitive data, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE, TABLE_NAME FROM DBA_TAB_PRIVS WHERE  
TABLE_NAME='DBA_ROLE_PRIVS';
```

Remediation:

```
SQL> REVOKE ALL ON DBA_ROLE_PRIVS FROM <Non-SYS/grantee>;
```

7.17 Rejected - Limiting user authorizations for the `ROLE_ROLE_PRIVS` view (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database `ROLE_ROLE_PRIVS` view lists all the roles granted to other roles and is limited to the roles which the current user can access.

Rationale:

As permitting unauthorized access to the `ROLE_ROLE_PRIVS` view can allow the disclosure of sensitive data, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE, TABLE_NAME FROM DBA_TAB_PRIVS WHERE  
TABLE_NAME='ROLE_ROLE_PRIVS';
```

Remediation:

```
SQL> REVOKE ALL ON ROLE_ROLE_PRIVS FROM <Non-SYS/DBA grantee>;
```

7.18 Rejected - Limiting user authorizations for the `USER_TAB_PRIVS` view (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database `USER_TAB_PRIVS` view lists all the granted table privileges for all users in the database.

Rationale:

As permitting unauthorized access to the `USER_TAB_PRIVS` view can allow the disclosure of sensitive data, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE, TABLE_NAME FROM DBA_TAB_PRIVS WHERE  
TABLE_NAME='USER_TAB_PRIVS';
```

Remediation:

```
SQL> REVOKE ALL ON USER_TAB_PRIVS FROM <Non-SYS/DBA grantee >;
```

7.19 Rejected - Limiting user authorizations for the USER_ROLE_PRIVS view (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database `USER_ROLE_PRIVS` view lists all the granted role privileges for all users in the database.

Rationale:

As permitting unauthorized access to the `USER_ROLE_PRIVS` view can allow the disclosure of sensitive data, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE, TABLE_NAME FROM DBA_TAB_PRIVS WHERE  
TABLE_NAME='USER_ROLE_PRIVS';
```

Remediation:

```
SQL> REVOKE ALL PRIVILEGES ON USER_ROLE_PRIVS FROM <Non-SYS grantee>;
```

7.20 Rejected - Limiting user authorizations for the RECOVERY_CATALOG_OWNER (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database `RECOVERY_CATALOG_OWNER` provides full privileges to the `RECOVERY_CATALOG`, which is a database schema that tracks backups and stores the commands used for RMAN-based backup and recovery situations.

Rationale:

As permitting unauthorized access to the `RECOVERY_CATALOG_OWNER` can allow the covert or overt destruction of system backup data and procedures, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, PRIVILEGE, TABLE_NAME FROM DBA_TAB_PRIVS WHERE  
TABLE_NAME='RECOVER_CATALOG_OWNER';
```

Remediation:

```
SQL> REVOKE ALL ON RECOVER_CATALOG_OWNER FROM <Non-SYS grantee>;
```

7.21 Rejected - Limiting basic user privileges to CREATE_SESSION (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database `CREATE_SESSION` privilege provides basic connection capabilities for the standard "Application User" to establish a session with the database so that further specific privileges for DDL, written into the application routines, can take over; when running the "`select * from dba_sys_privs`" statement on a default installation of Oracle 11gr2 Enterprise, it can return more than 700 rows of privilege assignments.

Rationale:

As access to the gateway of myriad privileges beyond `CREATE SESSION` can allow an unauthorized user to potentially view confidential data or do harm to the database instance(s), `CREATE SESSION` privileges should be permitted as the only default permission, or restricted according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_SYS_PRIVS WHERE PRIVILEGE='CREATE SESSION' AND GRANTEE NOT IN ('DBA', 'SYS', 'SYSTEM') order by 1;
```

Remediation:

```
SQL> REVOKE CREATE SESSION FROM <grantee>;
```

7.22 Limiting basic user privileges to restrict the ANY keyword (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database `ANY` keyword provides the user the capability to alter any item in the catalog of the database, such as `USER` or `SESSION`.

Rationale:

As authorization to use the `ANY` expansion of a privilege can allow an unauthorized user to potentially change confidential data or damage the data catalog, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_SYS_PRIVS WHERE PRIVILEGE LIKE '%ANY%' AND GRANTEE NOT IN ('AQ_ADMINISTRATOR_ROLE', 'CACHEADM', 'DBA', 'DBSNMP', 'EXFSYS', 'EXP_FULL_DATABASE', 'IMP_FULL_DATABASE', 'DATAPUMP_IMP_FULL_DATABASE', 'JAVADEBUGPRIV', 'MDSYS', 'OEM_MONITOR', 'OLAPSYS', 'OLAP_DBA', 'ORACLE_OCM', 'OUTLN', 'OWB$CLIENT', 'OWBSYS', 'SCHEDULER_ADMIN', 'SPATIAL_CSW_ADMIN_USR', 'SPATIAL_WFS_ADMIN_USR', 'SYS', 'SYSMAN', 'SYSTEM', 'WMSYS', 'XDBEXT', 'XDBPM', 'XFILES') ORDER BY 1;
```

Remediation:

```
REVOKE ALL ON '%ANY%' FROM <grantee>;
```

7.23 Limiting users by restricting the *WITH_ADMIN* privilege (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database *WITH_ADMIN* privilege allows the designated user to grant another user the same privileges.

Rationale:

As assignment of the *WITH_ADMIN* privilege can allow the granting of a restricted privilege to an unauthorized user, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_SYS_PRIVS WHERE ADMIN_OPTION='YES' and GRANTEE not in  
( 'AQ_ADMINISTRATOR_ROLE', 'DBA', 'OWBSYS', 'SCHEDULER_ADMIN', 'SYS', 'SYSTEM', 'WMSYS' )  
ORDER BY 1;
```

Remediation:

```
SQL> REVOKE <privilege> FROM <grantee>;
```

7.24 Limiting *PUBLIC* by restricting the *WITH_GRANT (SELECT)* privilege (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database *WITH_GRANT (SELECT)* privilege allows the designated grantee to grant to another user the same privilege(s) to execute a command that the original grantee holds.

Rationale:

As assignment of the `WITH_GRANT (SELECT)` privilege to `PUBLIC` can allow the granting of a restricted privilege to an unauthorized user that permits viewing the contents potentially restricted data tables, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME, PRIVILEGE, GRANTABLE FROM DBA_TAB_PRIVS WHERE  
GRANTABLE='YES' AND GRANTEE='PUBLIC' AND PRIVILEGE='SELECT' order by 1,2;
```

Remediation:

```
SQL> REVOKE SELECT from <grantee>;
```

7.25 Limiting PUBLIC by restricting the WITH_GRANT (EXECUTABLE) privilege (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database `WITH_GRANT (executable)` privilege allows the designated grantee to grant to another user the same privilege(s) to execute a command that the original grantee holds.

Rationale:

As assignment of the `WITH_GRANT (executable)` privilege to `PUBLIC` can allow the granting of a restricted privilege to an unauthorized user, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, TABLE_NAME, PRIVILEGE, GRANTABLE FROM DBA_TAB_PRIVS WHERE  
GRANTABLE='YES' AND GRANTEE='PUBLIC' AND PRIVILEGE='EXECUTE' order by 1,2;
```

Remediation:

```
SQL> REVOKE SELECT from <grantee>;
```

7.26 Rejected - Limiting users by restricting the CREATE privilege (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database `CREATE` privilege allows the designated grantee to create tables, objects, and views.

Rationale:

As assignment of the `CREATE` privilege can allow the creation of numerous database objects and potentially lead to a Denial-of-Service condition, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_SYS_PRIVS WHERE PRIVILEGE LIKE 'CREATE%' AND GRANTEE NOT IN
('APPQOSSYS','AQ_ADMINISTRATOR_ROLE',
'CACHEADM','CONNECT','CTXSYS','DATAPUMP_EXP_FULL_DATABASE','DATAPUMP_IMP_FULL_DATABASE',
'DBA','DBSNMP','EXFSYS','EXP_FULL_DATABASE','FLOWS_FILES','IMP_FULL_DATABASE','MGMT_
USER','MDSYS','OBE','OLAPSYS','OEM_ADVISOR','OEM_MONITOR','OLAP_DBA','OLAP_USER',
'OWBSYS','OWB$CLIENT','OWBSYS_AUDIT','OUTLN','RECOVERY_CATALOG_OWNER','RESOURCE','SCHE
DULER_ADMIN','SH','SPATIAL_CSW_ADMIN_USR','SPATIAL_WFS_ADMIN_USR','SYS','SYSMAN','SYST
EM','WMSYS','XDB','XDBEXT') ORDER BY 1;
```

Remediation:

```
REVOKE CREATE from <grantee>;
```

7.27 Rejected - Limiting users by restricting privileges on PUBLIC (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database `PUBLIC` user privileges are granted to all users that connect successfully to the database instance.

Rationale:

As assignment of any privileges to `PUBLIC` can provide the ingress point for unauthorized attempts to manipulate the system, these capabilities should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, GRANTED_ROLE FROM DBA_ROLE_PRIVS where GRANTEE='PUBLIC';
```

Remediation:

```
SQL> REVOKE <granted_role> from <PUBLIC>;
```

7.28 Rejected - Limiting users by restricting the RESOURCE role (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database `RESOURCE` role provides the user the `CREATE CLUSTER`, `CREATE INDEXTYPE`, `CREATE OPERATOR`, `CREATE PROCEDURE`, `CREATE SEQUENCE`, `CREATE TABLE`, `CREATE TRIGGER`, `CREATE TYPE` capabilities and is for compatibility with previous releases of Oracle Database.

Rationale:

As assignment of the `RESOURCE` role to a user can provide a great number of unnecessary privileges to ordinary users, application of this role should be restricted according to the needs of the organization.

Audit:

```
SELECT * FROM DBA_ROLE_PRIVS where GRANTED_ROLE='RESOURCE';
```

Remediation:

```
REVOKE RESOURCE from <grantee>;
```

7.29 Rejected - Limit public access to views beginning with ALL_ (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database `ALL_` prefix allows the designated user to view the totality of the database objects attached to the prefix.

Rationale:

As assignment of the `ALL_` prefix can allow access to view any object and potentially compromise database confidentiality/integrity, this capability should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT TABLE_NAME, PRIVILEGE, GRANTEE FROM DBA_TAB_PRIVS WHERE TABLE_NAME LIKE ('ALL_%') AND GRANTEE='PUBLIC';
```

Remediation:

```
SQL> REVOKE ALL ON ALL_<name> from <grantee>;
```

7.30 Rejected - Limit access to standard database roles (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The Oracle database `roles` are used for assigning one or more privileges or roles together administer user privileges on the database.

Rationale:

As the inappropriate assignment of user `roles` can allow unauthorized access to confidential information or violate database integrity, these capabilities should be restricted according to the needs of the organization.

Audit:

```
SQL> SELECT * FROM DBA_ROLES WHERE PASSWORD_REQUIRED='NO';
```

Remediation:

```
SQL. SET ROLE <role> IDENTIFIED BY <password>;
```

7.31 Limit direct privileges for proxy user (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

Do not grant privileges directly to proxy users

Rationale:

A proxy user should only have the ability to connect to the database.

Audit:

tbd

Remediation:

revoke privilege from <proxy_user>

7.32 Revoke execute any procedure from user OUTLN (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

Remove unneeded privileges from OUTLN

Rationale:

Migrated OUTLN users have more privileges than required.

Audit:

tbd

Remediation:

revoke EXECUTE ANY PROCEDURE from OUTLN;

7.33 Revoke execute any procedure from user DBSNMP (Not Scored)

Profile Applicability:

- Level 1 - 11.x on any platform

Description:

Remove unneeded privileges from DBSNMP

Rationale:

Migrated DBSNMP users have more privileges than required.

Audit:

tbd

Remediation:

revoke EXECUTE ANY PROCEDURE from DBSNMP;

8 Rejected - General Policies and Procedures

There are number of general policies that cross multiple database environments or platform tiers and would have a significant impact on the instance and system's security profile.

8.1 Prohibit the database accessing a Public network interface card (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

Directly accessible public Network Interface Cards (NIC) allow any Internet-based user to attempt connection access to database services , such as the Listener, through the standard ports, e.g. 1521.

Rationale:

As having the database services directly accessible from the Internet without a firewall filter and private IP addressing can facilitate unauthorized connections, which at *minimum* would lead to Denial-of-Service attacks, IP addressing on the database host should be restricted according to the needs of the organization.

Audit:

```
# /sbin/ifconfig -a (this will show attached NICs and loopback)

OR

# /sbin/ifconfig (adapter name, e.g 'hme0')

The private ip address result should be within the range of: 10.0.0.0-10.255.255.255,
172.16.0.0-172.31.255.255, or 192.168.0.0-192.168.255.255
```

Remediation:

```
# ifconfig (adapater) 192.168.168.168 netmask 255.255.255.0 up
```

8.2 Permissions for database creation scripts (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

When creating an Oracle database and its configuration elements, the user is given the options to either save the creation script, a `CREATE DATABASE` statement that is a SQL statement to be run as a template, or run the setup immediately.

Rationale:

As having the database template SQL scripts, for example "prod_db.sql," accessible by unauthorized users can facilitate attacks against the database data dictionary and structure, access to these templates should be restricted according to the needs of the organization.

Audit:

```
$ ls -al $ORACLE_HOME/rdbms/admin/dbname.sql
```

Remediation:

```
$ chown oracle $ORACLE_HOME/rdbms/admin/dbname.sql
$ chgrp oracle $ORACLE_HOME/rdbms/admin/dbname.sql
$ chmod 644 $ORACLE_HOME/rdbms/admin/dbname.sql
```

8.3 Limit membership in the DBA users group (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

During the creation of an Oracle database and its data dictionary/connections, the most powerful database users are the default machine users SYS and SYSTEM. SYS can connect "as SYSDBA," taking on a role as with the same level of privileges as "root" in Unix or "administrator" in Windows, making this user/role combination arguably the most powerful on the system. The "human" users who need to function as database administrators can be granted the "DBA" role, which contains by default all database system privileges and must have at least one user; these DBA privileges can also be subdivided and granted to new administrative DBA roles with fewer privileges, as well as having security administrators and network administrators.

Rationale:

As having the database's default DBA role assigned to all database administrators can lead to unintentional (and otherwise) access/damage to the instance, its data dictionary, and the data content, the full DBA role should be subdivided among multiple administrators or be otherwise restricted according to the needs of the organization.

Audit:

```
SQL> SELECT GRANTEE, GRANTED_ROLE FROM DBA_ROLE_PRIVS WHERE GRANTED_ROLE='DBA' AND
GRANTEE NOT IN ('SYS','SYSTEM');
```

GRANTEE	GRANTED_ROLE
-----	-----
PHPDEMO	DBA

Remediation:

```
SQL> REVOKE DBA FROM <grantee>;
```

8.4 Remove the username "oracle" from software account ownership (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

During the creation of an Oracle database the username "oracle" is the default name assigned to the ownership of the Oracle software account.

Rationale:

As leaving the database's default account name value as the well-known value "oracle" can facilitate attacks by unauthorized users, this username should be set according to the needs of the organization.

Audit:

```
# cat /etc/passwd | grep oracle
# oracle:x:500:500:oracle:/home/oracle:/bin/bash
```

Remediation:

```
SQL> CREATE USER notorauser IDENTIFIED BY passwd;

OS (This useradd command can be expanded):
# useradd -c oracle sfwe account -d /home/oracle -G oinstall, osdba -s
/bin/bash notorauser
```

9 Audit/Logging Policies and Procedures

The ability to audit system logs, to determine the result of user actions that have potentially resulted in the loss or violations of availability, confidentiality, and/or integrity is among the most important of all database security features. Decisions must be made regarding the breadth/depth of the logging activity, as greater detail produces larger log files. Measures must also be taken to protect the log files themselves, for these may be targeted for alteration or destruction to hide unauthorized activity. There are numerous command sequences for AUDIT, some of which are applicable to most database objects, such as CREATE, ALTER, DROP, while others are limited to a few database objects, such as GRANT, TRUNCATE, SET, SYSTEM AUDIT, and SYSTEM GRANT. The commands that apply to larger numbers of objects will be addressed object by object after the primary connection commands are dealt with.

9.1 Audit all CREATE SESSION (logon/logoff) activities (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The logging of all CREATE SESSION activities, the logon/logoff equivalent to remote database access, will provide an audit trail of user connection; this is the minimum privilege required to request access to run operations against the database.

Rationale:

As the logging of user connections to the database via logon/logoff activity can provide forensic evidence of the initiation of a pattern of unauthorized activities, this capability should be set according to the needs of the organization.

Audit:

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='CREATE SESSION';
```

Remediation:

```
AUDIT CREATE SESSION;
```

9.2 Rejected - Audit all user CLUSTER activities/requests (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `CLUSTER` privilege provides for the creation of interconnected computers/servers that appear as if they are one, increasing resource availability for a single instance.

Rationale:

As the logging of user connections to the database for the purpose of the creation, alteration, dropping, or truncation of a `CLUSTER` can provide forensic evidence of the initiation of a pattern of unauthorized activities, this capability should be audited according to the needs of the organization.

Audit:

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='CREATE CLUSTER';

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='ALTER CLUSTER';

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='DROP ANY CLUSTER';

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='TRUNCATE CLUSTER';
```

Remediation:

```
AUDIT CLUSTER BY ACCESS;

AUDIT ALTER ANY CLUSTER BY ACCESS;

AUDIT DROP ANY CLUSTER BY ACCESS;

AUDIT TRUNCATE ANY CLUSTER BY ACCESS;
```

9.3 Rejected - Audit all user CONTEXT activities/requests (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `CONTEXT` object allows for the creation of a set of application-defined attributes that can validate and/or secure a specific application.

Rationale:

As the logging of user activities involving the creation, replacement, or dropping of a `CONTEXT` can provide forensic evidence about a pattern of unauthorized activities, the audit capability should be set according to the needs of the organization.

Audit:

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='CREATE
CONTEXT '

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='DROP
CONTEXT '
```

Remediation:

```
AUDIT CONTEXT BY ACCESS WHENEVER NOT SUCCESSFUL;
```

9.4 Audit all user DATABASE LINK activities/requests (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `DATABASE LINK` object allows for the creation of a link, either private or public, from an application-based "user" to the database for connections/session creation.

Rationale:

As the logging of user activities involving the creation, alteration, or dropping of a `DATABASE LINK` can provide forensic evidence about a pattern of unauthorized activities, the audit capability should be set according to the needs of the organization.

Audit:

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='CREATE DATABASE LINK';

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='ALTER DATABASE LINK';

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='DROP DATABASE LINK';
```

Remediation:

```
AUDIT DATABASE LINK BY ACCESS;
```

9.5 Audit all user *SELECT ANY DICTIONARY* activities/requests (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The *SELECT ANY DICTIONARY* capability allows the user to view the definitions of all schema objects in the database.

Rationale:

As the logging of user activities involving the capability to access the description of all schema objects in the database can provide forensic evidence about a pattern of unauthorized activities, the audit capability should be set according to the needs of the organization.

Audit:

```
SELECT * FROM DBA_STMT_AUDIT_OPTS WHERE AUDIT_OPTION='SELECT ANY DICTIONARY';
```

Remediation:

```
AUDIT SELECT ANY DICTIONARY BY ACCESS;
```

9.6 Rejected - Audit all user *DIMENSION* activities/requests (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The *DIMENSION* defines a parent-child relationship between pairs of column sets, where all of the columns of a given column set must come from the same table, but can be the source columns can come from different tables.

Rationale:

As the logging of user activities involving the creation, alteration, or dropping of a *DIMENSION* can provide forensic evidence about a pattern of unauthorized activities, the audit capability should be set according to the needs of the organization.

Audit:

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='CREATE
DIMENSION';

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='ALTER
DIMENSION';

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='DROP
DIMENSION';
```

Remediation:

```
AUDIT DIMENSION BY ACCESS;
```

9.7 Audit all user *DIRECTORY* activities/requests (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `DIRECTORY` object allows for the creation of a directory object that specifies an alias for a directory on the server file system, where the external binary file LOBs (BFILEs)/ table data are located.

Rationale:

As the logging of user activities involving the creation or dropping of a `DIRECTORY` can provide forensic evidence about a pattern of unauthorized activities, the audit capability should be set according to the needs of the organization.

Audit:

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='CREATE
DIRECTORY'

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='DROP
DIRECTORY'

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='GRANT
DIRECTORY'
```

Remediation:

```
AUDIT DIRECTORY BY ACCESS;

AUDIT GRANT DIRECTORY BY ACCESS;
```

9.8 Rejected - Audit all user INDEX activities/requests (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `INDEX` object allows for the creation of a column (or columns) that reference data in a given data table, to increase the speed of data retrieval.

Rationale:

As the logging of user activities involving the creation, alter, or replacement of an `INDEX` can provide forensic evidence about a pattern of unauthorized activities, the audit capability should be set according to the needs of the organization.

Audit:

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='CREATE INDEX';

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='ALTER INDEX';

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='DROP INDEX';
```

Remediation:

```
AUDIT CREATE ANY INDEX BY ACCESS;

AUDIT ALTER ANY INDEX BY ACCESS;

AUDIT DROP ANY INDEX BY ACCESS;
```

9.9 Rejected - Audit all user MATERIALIZED VIEW activities/requests (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `MATERIALIZED VIEW` object allows for the creation of a "Materialized view," which is a database object that can consist of the results gleaned from a query against data tables, views, or other materialized views.

Rationale:

As the logging of user activities involving the creation, alteration, or dropping of a `MATERIALIZED VIEW` can provide forensic evidence about a pattern of unauthorized activities, this audit capability should be set according to the needs of the organization.

Audit:

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='CREATE
MATERIALIZED VIEW';

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='ALTER
MATERIALIZED VIEW';

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='DROP
MATERIALIZED VIEW';
```

Remediation:

```
AUDIT CREATE ANY MATERIALIZED VIEW BY ACCESS;

AUDIT ALTER ANY MATERIALIZED VIEW BY ACCESS;

AUDIT DROP ANY MATERIALIZED VIEW BY ACCESS;
```

9.10 Audit all user GRANT ANY OBJECT PRIVILEGE activities/requests (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `GRANT ANY OBJECT PRIVILEGE` allows for the granting of any `OBJECT` privilege, which includes directories, flashbacks, mining models, etc.

Rationale:

As the logging of privilege grants that can lead to the creation, alteration, or dropping of tables, users and other critical system components is critical to forensic investigations, this audit capability should be set according to the needs of the organization.

Audit:

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_STMT_AUDIT_OPTS WHERE PRIVILEGE='GRANT ANY OBJECT PRIVILEGE';
```

Remediation:

```
AUDIT GRANT ANY OBJECT PRIVILEGE BY ACCESS;
```

9.11 Audit all user GRANT ANY PRIVILEGE activities/requests (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `GRANT ANY PRIVILEGE` allows for the granting of any privilege, including those at the DBA level, so that the entire range of DBA capabilities is open to the grantee.

Rationale:

As the logging of privilege grants that can lead to the creation, alteration, or dropping of tables, users and other critical system components, this audit capability should be set according to the needs of the organization.

Audit:

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_STMT_AUDIT_OPTS WHERE PRIVILEGE='GRANT ANY PRIVILEGE';
```

Remediation:

```
AUDIT GRANT ANY PRIVILEGE BY ACCESS;
```

9.12 Audit all user PROCEDURE activities/requests (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `AUDIT PROCEDURE` audit command allows for the tracking a number of user activities, including the:

`FUNCTION`, the creation/dropping of a standalone stored function or a "Call specification" that is like a procedure, except functions return values to its original environment and can be in Java or other 3GL languages;

`LIBRARY`, which is the creation/dropping of a schema object associated with an operating-system shared library;

`PACKAGE`, which is the creation/dropping of a locally stored collection of related procedures, functions, and potentially other program objects stored together; and

`PROCEDURE`, which is the creation/dropping of a procedure--this is a subprogram that performs a specified action that is stored in the database.

Rationale:

As the logging of user activities involving the creation, alteration, or dropping of a `PROCEDURE` and its related activities can provide forensic evidence about a pattern of unauthorized activities, this audit capability should be set according to the needs of the organization.

Audit:

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='CREATE FUNCTION';
```

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='DROP FUNCTION';
```

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='CREATE ANY LIBRARY';
```

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='DROP LIBRARY';
```

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='CREATE PACKAGE';
```

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='DROP PACKAGE';
```

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='CREATE  
PROCEDURE';  
  
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='DROP  
PROCEDURE';
```

Remediation:

```
AUDIT CREATE PROCEDURE BY ACCESS;  
  
AUDIT ALTER ANY PROCEDURE BY ACCESS;  
  
AUDIT DROP ANY PROCEDURE BY ACCESS;  
  
AUDIT EXECUTE ANY PROCEDURE WHENEVER NOT SUCCESSFUL;  
  
AUDIT CREATE ANY LIBRARY BY ACCESS;  
  
AUDIT DROP ANY LIBRARY BY ACCESS;
```

9.13 Audit all user PROFILE activities/requests (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `PROFILE` object allows for the creation of a set of database resource limits that can be assigned to a user, so that that user cannot exceed those resource limitations.

Rationale:

As the logging of user activities involving the creation, alteration, or dropping of a `PROFILE` can provide forensic evidence about a pattern of unauthorized activities, the audit capability should be set according to the needs of the organization.

Audit:

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='CREATE  
PROFILE';
```

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='ALTER  
PROFILE';
```

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='DROP  
PROFILE';
```

Remediation:

```
AUDIT CREATE PROFILE BY ACCESS;
```

```
AUDIT ALTER PROFILE BY ACCESS;
```

```
AUDIT DROP PROFILE BY ACCESS;
```

9.14 Audit all user PUBLIC DATABASE LINK activities/requests (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `PUBLIC DATABASE LINK` object allows for the creation of a public link for an application-based "user" to access the database for connections/session creation.

Rationale:

As the logging of user activities involving the creation, alteration, or dropping of a `PUBLIC DATABASE LINK` can provide forensic evidence about a pattern of unauthorized activities, the audit capability should be set according to the needs of the organization.

Audit:

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='CREATE  
PUBLIC DATABASE LINK';
```

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='ALTER  
PUBLIC DATABASE LINK';
```

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='DROP  
PUBLIC DATABASE LINK';
```

Remediation:

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='CREATE  
PUBLIC DATABASE LINK';
```

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='ALTER  
PUBLIC DATABASE LINK';
```

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='DROP  
PUBLIC DATABASE LINK';
```

9.15 Audit all user PUBLIC SYNONYM activities/requests (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `PUBLIC SYNONYM` object allows for the creation of an alternate description of an object and public synonyms are accessible by all users that have the appropriate privileges to the underlying object.

Rationale:

As the logging of user activities involving the creation or dropping of a `PUBLIC SYNONYM` can provide forensic evidence about a pattern of unauthorized activities, the audit capability should be set according to the needs of the organization.

Audit:


```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='CREATE  
PUBLIC SYNONYM';
```

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='DROP  
PUBLIC SYNONYM';
```

Remediation:

```
AUDIT CREATE PUBLIC SYNONYM BY ACCESS;
```

```
AUDIT DROP PUBLIC SYNONYM BY ACCESS;
```

9.16 Audit all user *ROLE* activities/requests (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The *ROLE* object allows for the creation of a set of privileges that can be granted to users/ other roles, both for application connection and database administrative purposes.

Rationale:

As the logging of user activities involving the creation, alteration, setting or dropping of a *ROLE* can provide forensic evidence about a pattern of suspect/unauthorized activities, the audit capability should be set according to the needs of the organization.

Audit:

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='CREATE  
ROLE';
```

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='ALTER  
ROLE';
```

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='SET  
ROLE';
```

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='DROP
ROLE';

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='DROP
ROLE';

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='GRANT ANY
ROLE';
```

Remediation:

```
AUDIT CREATE ROLE BY ACCESS;

AUDIT ALTER ANY ROLE BY ACCESS;

AUDIT DROP ANY ROLE BY ACCESS;

AUDIT GRANT ANY ROLE BY ACCESS;
```

9.17 Rejected - Audit all user ROLLBACK SEGMENT activities/requests (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `ROLLBACK SEGMENT` object allows for the creation of an object that the Oracle Database will use to store whatever data is required to undo, changes made by prior transactions.

Rationale:

As the logging of user activities involving the creation, alteration, or dropping of a `ROLLBACK SEGMENT` can provide forensic evidence about a pattern of suspect/unauthorized activities, the audit capability should be set according to the needs of the organization.

Audit:

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='CREATE
ROLLBACK SEGMENT';

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='ALTER
ROLLBACK SEGMENT';

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='DROP
ROLLBACK SEGMENT';
```

Remediation:

```
AUDIT CREATE ROLLBACK SEGMENT BY ACCESS;

AUDIT ALTER ROLLBACK SEGMENT BY ACCESS;

AUDIT DROP ROLLBACK SEGMENT BY ACCESS;
```

9.18 Rejected - Audit all user SEQUENCE activities/requests (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `SEQUENCE` operation allows for the creation of a database object that allows multiple users to generate unique integers that can be used to create primary key values automatically.

Rationale:

As the logging of user activities involving the creation or dropping of a `SEQUENCE` can provide forensic evidence about a pattern of suspect/unauthorized activities, the audit capability should be set according to the needs of the organization.

Audit:

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='CREATE
SEQUENCE';

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='DROP
SEQUENCE';
```

Remediation:

```
AUDIT SEQUENCE BY ACCESS WHENEVER NOT SUCCESSFUL;
```

9.19 Audit all user SYNONYM activities/requests (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `SYNONYM` operation allows for the creation of an alternative name for a database object such as a Java class schema object, materialized view, operator, package, procedure, sequence, stored function, table, view, user-defined object type, even another synonym; this synonym puts a dependency on its target and is rendered invalid if the target object is changed/dropped.

Rationale:

As the logging of user activities involving the creation or dropping of a `SYNONYM` can provide forensic evidence about a pattern of suspect/unauthorized activities, the audit capability should be set according to the needs of the organization.

Audit:

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='CREATE SYNONYM';

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='DROP SYNONYM';
```

Remediation:

```
AUDIT SYNONYM BY ACCESS;
```

9.20 Rejected - Audit all user TABLE activities/requests (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `TABLE` object is the "base" of the relational database and holds user/schema data that is used as the source to create relationships between the data inside. (This data can be stored as alphanumeric or binary.)

Rationale:

As the logging of user activities involving the creation, truncation, or dropping of a `TABLE` can provide forensic evidence about a pattern of suspect/unauthorized activities, the audit capability should be set according to the needs of the organization.

Audit:

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='CREATE TABLE';

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='TRUNCATE TABLE';

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='DROP ANY TABLE';
```

Remediation:

```
AUDIT TABLE BY ACCESS;
```

9.21 Rejected - Audit all user `TABLESPACE` activities/requests (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `TABLESPACE` object is a *logical* unit that holds indexes and/or tables of user/schema data in a *physical* location on a disk. The tablespace functions as the bridge or connection between the database itself and the physical file system which holds the table(s) or index(es).

Rationale:

As the logging of user activities involving the creation, truncation, or dropping of a `TABLESPACE` can provide forensic evidence about a pattern of suspect/unauthorized activities, the audit capability should be set according to the needs of the organization.

Audit:

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='CREATE
TABLESPACE';

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='TRUNCATE
TABLESPACE';

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='DROP
TABLESPACE';
```

Remediation:

```
AUDIT TABLESPACE BY ACCESS;

AUDIT CREATE TABLESPACE BY ACCESS;

AUDIT DROP TABLESPACE BY ACCESS;
```

9.22 Audit all user *TRIGGER* activities/requests (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `TRIGGER` object for the Oracle database is analogous to an "if/then" condition in computer code; these procedures are stored in the database and will run if a certain condition is met or an event occurs.

Rationale:

As the logging of user activities involving the creation, alteration, or dropping of a `TRIGGER` can provide forensic evidence about a pattern of suspect/unauthorized activities, the audit capability should be set according to the needs of the organization.

Audit:

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='CREATE TRIGGER';

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='ALTER TRIGGER';

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='DROP TRIGGER';
```

Remediation:

```
AUDIT CREATE ANY TRIGGER BY ACCESS;

AUDIT ALTER ANY TRIGGER BY ACCESS;

AUDIT DROP ANY TRIGGER BY ACCESS;
```

9.23 Rejected - Audit all user TYPE activities/requests (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `TYPE` object for the Oracle database is specifications of an object type, which can be a SQLJ object type, a named varying array (varray), a nested table type, object reference types, or even an incomplete object type.

Rationale:

As the logging of user activities involving the creation, alteration, or dropping of a `TYPE` can provide forensic evidence about a pattern of suspect/unauthorized activities, the audit capability should be set according to the needs of the organization.

Audit:

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='CREATE TYPE';
```

```

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='CREATE
TYPE BODY';

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='ALTER
TYPE';

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='DROP
TYPE';

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='DROP TYPE
BODY';

```

Remediation:

```

AUDIT CREATE ANY TYPE BY ACCESS;

AUDIT ALTER ANY TYPE BY ACCESS;
AUDIT DROP ANY TYPE BY ACCESS;

```

9.24 Audit all USER object activities/requests (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `USER` object for the Oracle database is a specification of an object which is an account through which either a human or an application can connect to, via a JDBC or log into, via a CLI, and interact with the database instance according to the roles and privileges allotted to account.

Rationale:

As the logging of user activities involving the creation, alteration, or dropping of a `USER` can provide forensic evidence about a pattern of suspect/unauthorized activities, the audit capability should be set according to the needs of the organization.

Audit:

```

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='CREATE
USER';

SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='ALTER
USER';

```



```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='DROP USER';
```

Remediation:

```
AUDIT CREATE USER BY ACCESS;  
AUDIT ALTER USER BY ACCESS;  
AUDIT DROP USER BY ACCESS;
```

9.25 Rejected - Audit all VIEW object activities/requests (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The `VIEW` object for the Oracle database is a logical table that has been created from a compilation of one or more base tables or views, which is equal in sensitivity to the source data, but still contains no original data, only that has come from its input sources.

Rationale:

As the logging of user activities involving the creation, alteration, or dropping of a `VIEW` can provide forensic evidence about a pattern of suspect/unauthorized activities, the audit capability should be set according to the needs of the organization.

Audit:

```
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='CREATE VIEW';  
  
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='ALTER VIEW';  
  
SELECT USER_NAME, SUCCESS, FAILURE FROM DBA_PRIV_AUDIT_OPTS WHERE PRIVILEGE='DROP VIEW';
```

Remediation:

```
AUDIT CREATE VIEW BY ACCESS;  
AUDIT ALTER VIEW BY ACCESS;  
AUDIT DROP VIEW BY ACCESS;
```

9.26 Rejected - Audit all unsuccessful table SELECT activities (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The logging of unsuccessful attempts to `SELECT` (open for read/update/delete/view) various tables audit will provide an audit trail of user connection activities that may indicate unauthorized attempts to access the data tables.

Rationale:

As the logging of unsuccessful attempts to initiate a `SELECT` command can provide forensic evidence of the initiation of a pattern of unauthorized activities, this logging capability should be set according to the needs of the organization.

Audit:

```
SELECT * FROM DBA_OBJ_AUDIT_OPTS WHERE OBJECT_NAME='<OBJECT_NAME>';
```

Remediation:

```
AUDIT SELECT ON TABLE WHENEVER NOT SUCCESSFUL
```

9.27 Rejected - Audit all SELECT ANY TRANSACTION activities (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The logging of all `SELECT ANY TRANSACTION` (open for read/ view) shows the contents of the `FLASHBACK_TRANSACTION_QUERY` view, which can view all data in the database, including past data.

Rationale:

As the logging of `SELECT ANY TRANSACTION` command can provide forensic evidence on the initiation of a pattern of unauthorized activities, this logging capability should be set according to the needs of the organization.

Audit:

```
SELECT * FROM DBA_OBJ_AUDIT_OPTS WHERE OBJECT_NAME='< SELECT ANY TRANSACTION >';
```

Remediation:

```
AUDIT SELECT ANY TRANSACTION;
```

9.28 Set AUDIT ALL ON SYS.AUD\$ activities (Not Scored)

Profile Applicability:

- Level 1 - 11.2 on Oracle Linux 5

Description:

The logging of attempts to alter the audit trail in the `SYS.AUD$` table (open for read/update/delete/view) will provide a record of any activities that may indicate unauthorized attempts to access the audit trail.

Rationale:

As the logging of attempts to alter the `SYS.AUD$` table can provide forensic evidence of the initiation of a pattern of unauthorized activities, this logging capability should be set according to the needs of the organization.

Audit:

```
SELECT * from DBA_OBJ_AUDIT_OPTS where OBJECT_NAME='AUD$';
```

Remediation:

```
AUDIT ALL on SYS.AUD$ BY ACCESS;
```


Appendix: Change History

Date	Version	Changes for this version
11-15-2012	1.0.0	Initial release.